



HIPAA Security Rule (NIST SP 800-66 R2)

VMware Cloud Foundation 9.1

June 23, 2026

Table of Contents

Disclaimer.....3

Version.....4

Introduction.....4

Additional Resources4

Third Party Identifiers and Mappings4

Coverage Levels4

Controls..... 6

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260623-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations working toward compliance with the HIPAA Security Rule, using the implementation guidance in NIST SP 800-66 Revision 2. The HIPAA Security Rule establishes standards for protecting electronic protected health information (ePHI) through administrative, physical, and technical safeguards. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for performing risk analysis and safeguarding ePHI remains with the covered entity or business associate.

<https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C>

This guidance evolves. Please check the current revision at: <https://brcm.tech/vcf-compliance>

Additional Resources

This is one of a library of companion guides that map VMware Cloud Foundation and its advanced services to security and compliance frameworks. For each framework, the guide is published as a spreadsheet, a CSV data file, a Markdown document, and a PDF, together with a Security Configuration Guide crosswalk that identifies the VCF technical hardening settings relevant to that framework. The companion guide library, the VMware Cloud Foundation Security Configuration Guide, and related security documentation, sample scripts, and Q&A are available at <https://brcm.tech/vcf-security>.

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.

- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control 164.306(a)(1)

General requirements. Covered entities and business associates must do the following: Ensure the confidentiality, integrity, and availability of all electronic protected health information the covered entity or business associate creates, receives, maintains, or transmits

SCF Controls: GOV-01, GOV-15, GOV-15.1, GOV-15.2, GOV-15.3, GOV-15.4, GOV-15.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(a)(2)

General requirements. Covered entities and business associates must do the following: Protect against any reasonably anticipated threats or hazards to the security or integrity of such information.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(a)(3)

General requirements. Covered entities and business associates must do the following: Protect against any reasonably anticipated uses or disclosures of such information that are not permitted or required under subpart E of this part.

SCF Controls: DCH-01, GOV-01, RSK-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful

workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The etcdctl snapshot save command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During kubeadm upgrades, backup folders for etcd state and cluster manifests are written automatically to /etc/kubernetes/tmp with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides VolumeSnapshotContent and VolumeSnapshot resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a PersistentVolumeClaim using a VolumeSnapshotClass that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new PersistentVolumeClaim with the target VolumeSnapshot as its dataSource, referenced via the snapshot.storage.k8s.io API group. Kubernetes PersistentVolumes have a configurable reclaim policy; setting the policy to Retain preserves volume data in a Released state after the associated PersistentVolumeClaim is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation

issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control 164.306(b)(1)

Covered entities and business associates may use any security measures that allow the covered entity or business associate to reasonably and appropriately implement the standards and implementation specifications as specified in this subpart.

SCF Controls: GOV-09, GOV-15, SEA-01, SEA-02, SEA-03

Aggregate Coverage: Meets

VCF (Meets)

VCF implements security as a layered architecture where each layer operates independently and does not depend on the correctness of layers above it. These layers span hardware-rooted trust at the physical host, network isolation, hypervisor-level encryption and access controls, identity and certificate management, encrypted communications, distributed security enforcement, workload-level policy propagation, and compliance assessment.

At the physical and network layer, VCF supports traffic separation through distributed switch models that isolate management, vMotion, vSAN, and workload traffic onto separate physical or logical networks. These models can be selected based on design qualities including availability, performance, and security. Dedicated distributed switches for vSAN traffic, for example, separate storage traffic from all other traffic types, while the Single Distributed Switch Model does not provide network traffic separation to another physical network fabric, making the choice of switch model a meaningful security design decision. This physical separation provides a foundational security boundary that operates independently of any software-defined overlay. NSX extends this with software-defined routing, switching, and segmentation using overlay-backed segments that do not require segment-specific physical infrastructure configuration. Network profiles support further isolation through subnets, security groups, and VLAN transport zones.

At the hypervisor layer, VMware ESX hosts support hardware-rooted security capabilities. TPM-based measured boot produces event logs that can be retrieved and validated by an attestation service, verifying the integrity of the boot process. UEFI Secure Boot verifies firmware and hypervisor integrity before the operating system loads. The Security Configuration Guide provides recommendations for enabling Secure Boot and TPM on ESX hosts as part of host hardening. ESX enforces local access controls, firewall rules (with per-service rulesets and allowed-host specifications), and resource isolation. The ESX host client enables management of the host even when VMware vCenter is not available, so these host-level protections continue to function independently of centralized management.

At the storage and encryption layer, vSAN provides data-at-rest encryption using a key management server, encrypting all data written to the vSAN datastore. VM encryption operates at the hypervisor level, protecting virtual machine disk files, NVRAM, swap files, snapshot files, and core dump files regardless of the guest operating system. These encryption controls function at the infrastructure layer without depending on application-level security. vSphere also supports Virtualization Based Security (VBS), which uses hardware virtualization capabilities to isolate key guest OS security services so they are protected against manipulation from within the guest environment. For workloads with data-in-use protection requirements, vSphere supports Intel Trust Domain Extension (TDX), a hardware-based mechanism that allows virtual machines to perform computations within a hardware-isolated trusted execution environment.

At the network security layer, VMware vDefend (a separate product that extends NSX and requires additional licensing) provides distributed security functions including Distributed Firewall (DFW) policies with Layer 2 through Layer 7 firewalling, Distributed IDS/IPS, Identity Firewall, Layer 7 Application Identification, Fully Qualified Domain Name filtering, and Guest Introspection. These security functions are enforced in the hypervisor kernel at the virtual NIC level, operating below the guest operating system and outside the reach of workloads running within virtual machines. NSX Projects enable isolation of networking and security configurations across departments within a single deployment, allowing delegation of configuration management to specific sets of users while restricting visibility to only project-scoped objects.

At the identity and access layer, VCF SSO provides centralized authentication as a single point of user verification for vCenter clients. Role-based access control (RBAC) restricts access across all VCF components. NSX provides granular RBAC with distinct roles including Enterprise Admin, Network Admin, Security Admin, Cloud Admin, and Cloud Project Admin, among

others, separating administrative privileges so that network administrators, security administrators, and workload operators have distinct permission sets. VCF implements security roles and management of security functions aligned with global compliance frameworks. The VMware Certificate Authority (VMCA), a purpose-built internal certificate authority integral to vSphere, issues certificates for service-to-service authentication between platform components. A dedicated No Cryptography Administrator role supports all Administrator privileges except for Cryptographic Operations, enabling separation of duties between infrastructure management and encryption key management.

At the communications layer, all management interfaces and API endpoints use TLS encryption. NSX Manager supports configurable TLS protocol versions and cipher suites, with older TLS versions deactivated by default.

At the Kubernetes and consumption layer, VMware Kubernetes Service (VKS), the native Kubernetes platform within VCF, implements multiple independent security enforcement points at distinct positions in the Kubernetes stack. All access to the Kubernetes API server requires TLS-encrypted transport, followed by authentication via OIDC, X.509 client certificates, or service account tokens, and then authorization via Kubernetes RBAC. Admission controllers, including validating and mutating webhooks, operate as a third independent check before any object is persisted, so a principal that passes authentication can still be rejected by RBAC or by an admission webhook. The Kubernetes cluster infrastructure is designed to provide the security supports that higher application layers expect, consistent with the principle that lower layers do not depend on higher-layer correctness.

VKS Cluster Management Security Policies can be applied at the cluster, project, or organization level and propagate downward through the resource hierarchy so that all clusters within a project inherit the project's security policy. These policies are implemented using the Gatekeeper project from Open Policy Agent (OPA), maintaining a consistent security posture across workload layers without requiring each layer to independently define its own controls. A Baseline pod security template is available that mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads; custom security policy templates allow fine-tuning of individual security context parameters to support organizational requirements. Individual pods can be further constrained through security contexts that configure fields such as `runAsUser`, `allowPrivilegeEscalation`, Linux capabilities, `readOnlyRootFilesystem`, and `seccomp` or `AppArmor` profiles. `Seccomp` profiles reduce the Linux kernel syscall attack surface available within containers using BPF-based allow or deny lists, and Linux kernel security features including `AppArmor` and `SELinux` can be applied to pods and containers through `SecurityContext` configuration, providing a security boundary below the container runtime that operates regardless of the container's contents. The Supervisor secret injection agent itself drops all Linux capabilities and enforces a `RuntimeDefault` `seccomp` profile to restrict the system calls available to it, minimizing its own attack surface.

At the namespace and network layer within VKS, Kubernetes network policies restrict ingress and egress traffic per namespace. VKS supports Antrea and NSX-based network policy enforcement as well as Cilium, which enforces policies at OSI layers 3 through 7 using an identity-based model decoupled from IP addressing. Service meshes available on VKS clusters provide OSI Layer 7 policies based on workload identity and mutual TLS encryption, protecting data in transit even in the presence of a compromised node. These controls operate independently of what applications within the namespace do.

At the secrets and credential layer within VKS, the Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants separately from the application workloads that consume secrets, so that access to a running application does not by itself yield access to stored credentials.

At the supply chain and pipeline layer, Harbor Registry secures container images with artifact security policies and RBAC before images reach the runtime environment. Harness CI/CD, available on VKS, incorporates integrated security scanning and secrets management, including pre-deployment vulnerability scanning and post-deployment performance verification, applied before artifacts are promoted. Argo CD deployments use network segmentation to secure inter-component communication. Security Technical Implementation Guides (STIGs) for system components, including Supervisor and VKR components, are available through Tanzu STIG Hardening to guide layer-by-layer hardening of the Kubernetes environment.

At the compliance and assessment layer, the VCF Security Baseline provides a consolidated, out-of-the-box benchmark that evaluates both default and non-default configurations. This baseline is designed and validated to tailor security settings without impacting VCF's ability to meet its design objectives. VCF Operations surfaces a security dashboard that complements

the compliance capability, and each component has its own Security Configuration Guide with hardening recommendations aligned with DISA STIG guidance. These assessment and monitoring functions operate as an independent verification layer above the controls they measure.

VMware vDefend (Contributes)

VMware vDefend (vDefend) implements multiple independent security layers within its own architecture, contributing to a defense-in-depth strategy at the network security tier of VCF. The vDefend security model is structured as a Security Journey, a staged approach that allows organizations to progressively adopt a Zero Trust posture, moving from initial assessment through increasing levels of microsegmentation and policy enforcement. Each stage can be deployed and validated independently, with lower-level enforcement mechanisms remaining operational regardless of higher-level policy states.

At the network enforcement layer, the vDefend distributed firewall provides Layer 2 through Layer 7 traffic inspection and policy enforcement at the hypervisor level. The Applied-To field defines precisely where security rules are enforced, enabling scoped enforcement boundaries within the environment. Security profiles are organized per Project, and Security Strategies are collections of policies and rules applied at the project level, allowing discrete enforcement boundaries to be maintained across the environment. Bare Metal Security extends this enforcement model to physical servers, applying Layer 3/4 Distributed Firewall policies outside the virtualization stack through a workflow that onboards physical servers to the Bare Metal Orchestrator for policy propagation and enforcement.

At the threat detection layer, vDefend IDS/IPS provides signature-based intrusion detection and prevention. Gateway Firewall TLS Inspection allows encrypted traffic flows to be analyzed before reaching their destination. Advanced Threat Prevention (ATP) adds malware analysis as a distinct layer operating on file content extracted from network flows.

At the segmentation planning layer, Security Intelligence and the Security Services Platform (SSP) provide traffic flow analysis, security posture assessment, and policy lifecycle management. The Security Segmentation hierarchy is structured as Region, Zone, Environment, Application, and Tier, enabling granular segmentation planning across the environment. Security Intelligence provides targeted policy recommendations organized within Distributed Firewall categories, supporting administrators in planning and verifying segmentation coverage.

The Security Segmentation Score assessment calculates security posture by evaluating Distributed Firewall configuration and traffic rules, and generates a Blast Radius Report that provides a qualitative view of segmentation posture. The Security Segmentation Report identifies vulnerable workloads that could be exploited for lateral movement and presents recommendations for strengthening defenses. The score breakdown details total environments and pairs, protection rule actions, and highlights environment pairs lacking inter-environment policies, giving operators visibility into coverage gaps between enforcement layers.

Administrative access to the Security Services Platform itself is governed by role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. This role structure means that policy authorship, audit review, and operational support functions are distinct within the platform's control plane, adding an administrative separation layer on top of the enforcement architecture.

Taken together, these layers, including packet filtering, threat detection, malware analysis, encrypted traffic inspection, and segmentation assessment, are designed so that each layer makes enforcement decisions based on its own analysis without relying on the correctness of adjacent layers. A misconfiguration or gap in one layer does not disable enforcement in others.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements its security controls as distinct, layered mechanisms that map to different tiers of the database-as-a-service architecture. This layered structure means that a failure or bypass at one level does not automatically compromise the controls operating at other levels.

At the network layer, DSM requires VDS and N-VDS port groups to be available for host component isolation. Infrastructure policies define the compute, storage, and networking resources for each database deployment, including IP pool configuration with subnet-scoped addressing. This creates a defined, bounded network environment for database workloads that is configured by administrators independently of the database consumers who use those workloads. DSM also detects

and blocks network overlap between infrastructure policy IP ranges and system configuration networks, a check that stops subnet conflicts before they affect database network isolation.

At the authentication and identity layer, DSM requires Lightweight Directory Access Protocol over TLS (LDAPS) for all directory service communication. There is no option to connect a directory service without transport encryption. MySQL deployments support Active Directory Secure/SSL Global Catalog on port 3269 for multi-domain controller environments. For local accounts, DSM supports automatic authentication secret generation with rootCA certificate configuration in the Supervisor Service, providing a credential layer for endpoint-to-endpoint communication that is generated rather than administrator-managed.

At the access control layer, DSM applies role-based access control at two scopes. DSM Admin roles govern platform-wide configuration. DSM User role assignments can be scoped to one or more specific namespaces, so that a given user can access only the databases and resources within their assigned namespace and no others. Namespaces themselves enforce this access boundary, and role assignments are visible and manageable through the DSM administrator UI.

At the database engine layer, DSM isolates management operations from user-accessible database operations through engine-specific mechanisms. For SQL Server, the `dsm_mgmt` internal management login confines administrative operations to a secure, isolated context; users cannot access or modify system-level objects through this channel. User-defined DDL triggers that execute during DSM management operations run within a restricted database-level security context, which blocks those triggers from accessing the server-level permissions held by the internal management account. PostgreSQL deployments support the `pgcrypto` extension, which provides cryptographic functions as an additional data security layer within the database engine.

At the resource governance layer, infrastructure policies act as guardrails that restrict the type and quantity of compute, memory, storage, and networking resources that DSM users can request when provisioning databases. These policies are configured by administrators and presented to users as a curated set of options. Storage policies within an infrastructure policy are filtered to show only those compatible with the specified compute resources, reducing the chance that a user provisions a database in a configuration that violates organizational standards. Data service policies can be applied uniformly across tenants, maintaining a consistent security posture at scale.

Network perimeter controls, workload traffic inspection, host-level security, and the organizational design decisions that govern how layers interact across the broader platform are addressed by other components of VCF or by organizational policy. DSM operates as one layer within a broader security architecture rather than defining or enforcing that architecture on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to a Defense-in-Depth (DiD) architecture by acting as the application delivery and inspection layer within VCF. Avi's security enforcement mechanisms are organized as distinct, ordered tiers within the application delivery path, each operating independently without relying on the correctness of the network layers beneath them.

The Virtual Service Policy framework is the primary structural mechanism for applying layered controls. Policies are applied in ordered stages covering network-layer security, HTTP security, HTTP request handling, and HTTP response handling, allowing administrators to apply different security controls at the appropriate point in the traffic-processing pipeline. Network Security Policies provide L4 access control across UDP, TCP, and Layer 7 virtual services, with IP Group references enabling IP-based filtering rules that scale across multiple virtual services without per-rule manual maintenance. NSX security groups can be defined once in NSX and reused across Avi Virtual Service security policies, eliminating the need to maintain duplicate IP address lists. These network-layer policies function independently of the HTTP-layer controls, preserving the separation between tiers. The System-Secure-HTTP application profile provides a pre-configured baseline that enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior. Front-end security for each Virtual IP can be enforced using network security policies on the virtual service. Virtual Service Policies are configured under the Virtual Service settings in the Avi Controller UI or via the Avi API.

At the application layer, Avi's Web Application Firewall (WAF) provides two independent security models that can be combined. The negative security model uses Application Rules to detect known attack patterns through signature matching. The Positive Security model, configured under Virtual Service > Positive Security Policy, works differently: it uses a decoupled Learning function to gather application behavior data and then promotes verified patterns to rules that restrict traffic to known-good requests. WAF Policies attach a Positive Security group to apply learned data for security and to define hit and miss actions. Together, these models represent distinct enforcement mechanisms within the application inspection tier, each addressing a different class of attack pattern without depending on the other. In VMware Kubernetes Service (VKS) environments, the Avi Kubernetes Operator (AKO) provides WAF integration for application-layer security in VKS clusters. The AKO also supports a SecurityPolicy custom resource definition that enables virtual services to reference a security policy for Distributed Denial of Service (DDoS) attack mitigation, bringing Kubernetes-native policy control to application delivery security.

TLS termination is handled by configurable SSL/TLS profiles applied at the Virtual Service level. Profiles control cipher suite selection, protocol version, and certificate assignment, with trade-offs between security, compatibility, and computational cost. The Avi Controller integrates with external Hardware Security Modules, specifically Thales Luna HSMs, to separate key management and cryptographic operations from application processing. This separation provides an additional boundary within the cryptographic control plane that is independent of the application and network policy tiers.

The Avi Service Engine's data-plane architecture isolates attacks on the data plane to the data plane alone, avoiding impact to management interfaces. The Avi control plane provides visibility into data-plane attacks through management interfaces and can help secure the data plane from certain attack types. This control-plane and data-plane separation is itself a layering boundary that preserves the integrity of management operations even under active attack conditions. The Service Engine detects and mitigates a wide range of Layer 4 through Layer 7 network attacks.

Avi's denial-of-service protection spans both Layer 4 and Layer 7 as distinct monitoring and enforcement tiers. The DDoS Policy, accessible via the Network Security policy on the virtual service, detects and mitigates a wide range of Layer 4 through Layer 7 network attacks. The Avi Service Engine tracks and breaks down attack data separately for Layer 4 and Layer 7 through DDoS Insights, displayed on the default security page in the Avi Controller. The application profile includes a DDoS tab for configuring custom Layer 7 attack limits.

Auditors should verify that Virtual Service Policies are configured with appropriate Network Security Policies for each service, that WAF policies include both Application Rules and Positive Security policies calibrated to the application's known-good traffic profile, that SSL/TLS profiles enforce the organization's required protocol and cipher standards, and that DDoS thresholds are set according to the organization's risk profile. The DiD architecture as a whole requires design and integration across VCF, which provides infrastructure-level security controls, and VMware vDefend, which provides network-level enforcement through its distributed firewall and inspection capabilities.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.306(b)(2)(i)

In deciding which security measures to use, a covered entity or business associate must take into account the following factors: The size, complexity, and capabilities of the covered entity or business associate.

SCF Controls: GOV-08, PRM-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(b)(2)(ii)

The covered entity's or the business associate's technical infrastructure, hardware, and software security capabilities.

SCF Controls: PRM-05, SEA-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(b)(2)(iii)

The costs of security measures.

SCF Controls: PRM-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(b)(2)(iv)

The probability and criticality of potential risks to electronic protected health information.

SCF Controls: RSK-01, RSK-01.1, RSK-02, RSK-03, RSK-03.1, RSK-04, THR-09, THR-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(c)

Standards. A covered entity or business associate must comply with the applicable standards as provided in this section and in 164.308, 164.310, 164.312, 164.314 and 164.316 with respect to all electronic protected health information.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(d)(1)

Implementation specifications are required or addressable. If an implementation specification is required, the word "Required" appears in parentheses after the title of the implementation specification. If an implementation specification is addressable, the word "Addressable" appears in parentheses after the title of the implementation specification.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(d)(2)

When a standard adopted in 164.308, 164.310, 164.312, 164.314, or 164.316 includes required implementation specifications, a covered entity or business associate must implement the implementation specifications.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(d)(3)(i)

When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes addressable implementation specifications, a covered entity or business associate must- Assess whether each implementation specification is a reasonable and appropriate safeguard in its environment, when analyzed with reference to the likely contribution to protecting electronic protected health information; and

SCF Controls: CPL-02, CPL-03, CPL-03.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.306(d)(3)(ii)(A)

When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes addressable implementation specifications, a covered entity or business associate must- As applicable to the covered entity or business associate- Implement the implementation specification if reasonable and appropriate; or

SCF Controls: GOV-15.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(d)(3)(ii)(B)(1)

When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes addressable implementation specifications, a covered entity or business associate must- As applicable to the covered entity or business associate- If implementing the implementation specification is not reasonable and appropriate: Document why it would not be reasonable and appropriate to implement the implementation specification;

SCF Controls: GOV-02.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(d)(3)(ii)(B)(2)

When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes addressable implementation specifications, a covered entity or business associate must- As applicable to the covered entity or business associate- If implementing the implementation specification is not reasonable and appropriate- Implement an equivalent alternative measure if reasonable and appropriate.

SCF Controls: RSK-06.2

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend provides a layered set of technical mechanisms that organizations can deploy as compensating countermeasures to reduce risk exposure and limit the impact of threats at the network security layer. In addition to core preventive controls such as Distributed Firewall microsegmentation, Distributed IDS/IPS, TLS Inspection, URL filtering, and malware prevention, vDefend includes identification and response capabilities that support the compensating countermeasure lifecycle.

The vDefend distributed firewall (DFW) supports targeted policy enforcement using the Applied To field to scope policies to specific workload groups, zones, tenants, or applications without affecting other policies. Stage 2 of the vDefend Zero Trust journey (Infrastructure Services Protection) prioritizes securing critical infrastructure services such as DNS with specific deny rules scoped to infrastructure groups, providing a risk reduction approach that does not require a full Zero Trust policy deployment. DFW policies applied globally allow sources or destinations to be any object without span restrictions, supporting broad or targeted countermeasure scope as needed.

vDefend Distributed IDS/IPS provides intrusion detection and prevention capabilities and supports custom signature creation, allowing administrators to address threats from custom applications and zero-day vulnerabilities beyond standard signature coverage. The Oversubscription setting for Distributed IDS/IPS lets administrators configure whether excess traffic is dropped or bypassed when the IDS/IPS engine is overloaded, providing operational control over inspection behavior under high load.

The Security Services Platform supports investigation of individual threat events and correlated campaigns, enabling security teams to assess impact, identify root causes, and take mitigation actions. Campaign impact scoring within the Security Services Platform helps administrators prioritize which threats to address first. Comparing the ratio of detected versus prevented events in Security Intelligence informs administrators about how well current controls are protecting infrastructure, supporting identification of areas where additional countermeasures may be warranted.

vDefend Advanced Threat Prevention includes Network Detection and Response (NDR) as an activatable feature, providing supplemental threat detection coverage that complements preventive controls.

Formal compensating control documentation and organizational approval processes remain outside vDefend's scope; this control requires those organizational governance processes in addition to the technical mechanisms vDefend supplies.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.306(e)

When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes addressable implementation specifications, a covered entity or business associate must- Maintenance. A covered entity or business associate must review and modify the security measures implemented under this subpart as needed to continue provision of reasonable and appropriate protection of electronic protected health information, and update documentation of such security measures in accordance with § 164.316(b)(2)(iii).

SCF Controls: CPL-03.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(1)(i)

A covered entity or business associate must, in accordance with § 164.306: Standard: Security management process. Implement policies and procedures to prevent, detect, contain, and correct security violations.

SCF Controls: CFG-01, CHG-01, GOV-02, IRO-01, MON-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by

default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes system:monitoring RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF

Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the `PAISConfiguration` custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over `http/protobuf` or `gRPC`, providing distributed tracing for AI model inference activity. The `observability.llmTraces` configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The `controller-pod-metrics-streaming` setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the `vmware-system-monitoring` namespace uses a `telegraf-user-config` ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports configuration management by providing structured mechanisms for defining, applying, and monitoring the configuration of database infrastructure components. Administrators interact with DSM through two primary interfaces: the Provider UI for system-wide settings and the vSphere Client for infrastructure configuration. The Settings view in the Provider interface is the central location for managing system-wide settings, including LDAPS integration, SMTP configuration, and directory service settings. The Administrator Dashboard displays at-a-glance metrics covering the number of configured users, their assigned roles, and the types and counts of provisioned database services, giving administrators a current view of deployment state.

Infrastructure configuration in DSM is governed by infrastructure policies. These policies define which VM classes are available for database VMs, which storage policies apply, and which vSphere clusters and namespaces are used during provisioning. Infrastructure policy configuration requires that placements, storage policies, VM classes, and IP ranges be correctly configured for valid policy status. Policies that are actively in use by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added; unused policies can be changed at any time. VM classes are configurable resource profiles that specify vCPU cores and memory allocation, and can be defined to match

organizational capacity standards. Infrastructure policies also establish guardrails that restrict the quantity and quality of resources DSM users can consume from vSphere clusters. Configuration tasks performed during initial deployment include configuring IP pools, defining VM classes, assigning user permissions, creating infrastructure policies, and selecting storage policies.

Database-level configuration is managed through the database instance settings. DSM allows configuration of database instances using either custom or default configuration profiles, with configuration properties varying by database type (PostgreSQL, MySQL, MinIO, or SQL Server). DSM automates provisioning, backups, and security patch application for managed database instances. After initial provisioning, database VM resource configuration can be adjusted at runtime. Optional database configuration parameters for PostgreSQL and MySQL databases can be added or removed after database creation. Maintenance windows can be configured to control when software updates and database option changes are applied, providing a mechanism for scheduled, controlled configuration changes.

DSM provides a Maintenance Policy editor, accessible from the Version & Upgrade section under the DSM System tab, for configuring automatic software updates of the DSM plug-in within defined maintenance windows. The DSM controller manages component and feature dependencies through status monitoring and automated remediation.

When integrated with VCF Automation, DSM supports data service policies that define and enforce configurations for each tenant or organization. These policies can be enforced across different namespaces and namespace labels to maintain a uniform configuration posture. The Consumption Operator automates database deployments based on predefined infrastructure and backup policies, reducing the scope for manual configuration drift.

DSM provides visibility into configuration activity through the Operations tab, which displays the progress of database configuration changes, resource changes, and disk extension tasks. A support bundle can be created and downloaded to collect diagnostic information for troubleshooting system configuration failures. DSM system configuration is also managed through a `dsmsystemconfig` Custom Resource within the gateway, which can be inspected via SSH access to the appliance VM to review directory service status and configuration details.

DSM's contribution to a configuration management program is at the platform level: it provides technical mechanisms for defining baseline configurations through policies and VM classes, enforcing them during provisioning, and tracking changes through operational visibility. The broader configuration management program, including change control processes, configuration baseline documentation and approval, configuration audits against external standards, and periodic review cycles, must be established and maintained by the organization.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides several mechanisms that support the implementation of configuration management controls across the application delivery layer.

The Controller maintains a centralized Configuration Database that stores all configuration information including tenants, virtual services, pools, policies, and accounts. This is the single source of truth for all system settings. When an administrator makes a change through the web interface, CLI, or REST API, that change is automatically propagated to all Controller cluster members, so any node can assume leadership with a complete and current configuration.

The Controller CLI provides direct access to the full configuration surface. The ``configure systemconfiguration`` command allows administrators to modify system-wide parameters including DNS, NTP, portal settings, and cryptographic algorithm configuration, with changes synchronized to Service Engines. The ``configure`` command covers a broad range of objects including virtual services, pools, health monitors, authentication profiles, application profiles, and policy sets, and supports creation, modification, and deletion of those objects. The REST API exposes comparable capabilities programmatically, including the ``PUT api/systemconfiguration`` endpoint for system-wide settings and the ``/api/cloud`` endpoint for cloud configuration resources.

Configuration management in Avi can be automated through the Ansible ``aviconfig`` role, which allows configurations to be expressed as structured dictionaries and applied in a repeatable manner, reducing the need for multiple individual task

definitions. The Controller supports on-demand configuration backup and restore, enabling disaster recovery and configuration migration across Controller instances.

In the 9.1 VCF integration, Avi distinguishes between two operational modes: Provider-Managed Mode, where the provider administrator manages Service Engine Group settings including scale-out, CPU, and memory configurations; and Organization-Managed Mode, where the organization administrator manages their own Service Engine Group configurations and infrastructure settings. This separation clarifies ownership and scope of configuration responsibilities within a shared VCF deployment. After upgrading Avi components, a drift check should be performed against VCF Operations, vCenter, and NSX Manager to verify configuration consistency across the stack.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) configuration is customized through the AddonConfig resource, a Supervisor namespace-scoped resource that supports modification of parameters such as logging level and shard virtual service size.

The Config Events overlay in the Service Engine Analytics view allows operators to correlate configuration changes with observed traffic behavior, supporting investigation of the impact of individual changes. Avi Load Balancer events provide the building blocks for configuration automation workflows.

Organizations should define change control procedures, assign ownership of configuration baselines, and determine which changes require approval before these mechanisms can function within a formal configuration management program. Avi provides the technical instruments; the program structure requires organizational governance.

Control 164.308(a)(1)(ii)(A)

A covered entity or business associate must, in accordance with § 164.306: Implementation specifications: Risk analysis (Required). Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of electronic protected health information held by the covered entity or business associate.

SCF Controls: RSK-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(1)(ii)(B)

A covered entity or business associate must, in accordance with § 164.306: Implementation specifications: Risk management (Required). Implement security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level to comply with § 164.306(a).

SCF Controls: GOV-09, GOV-15.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(1)(ii)(C)

A covered entity or business associate must, in accordance with § 164.306: Implementation specifications: Sanction policy (Required). Apply appropriate sanctions against workforce members who fail to comply with the security policies and procedures of the covered entity or business associate.

SCF Controls: HRS-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(1)(ii)(D)

A covered entity or business associate must, in accordance with § 164.306: Implementation specifications: Information system activity review (Required). Implement procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking reports.

SCF Controls: IRO-09, MON-01, MON-01.8

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides layered event logging, continuous monitoring, and alerting capabilities across all platform components, supporting ongoing review of security events and incident escalation.

VCF Operations delivers continuous monitoring through its event auditing capability, which provides visibility into platform interaction changes across the infrastructure and surfaces suspicious access events and policy violations. Audit events tracked by VCF Operations include user searches, logins, logouts, capability checks, and configuration modifications, with each interaction generating a corresponding audit record. A dedicated audit events view gives operators a consolidated perspective on authentication and security-related activity across the environment. The audit events framework captures interactions across vSphere, vSAN, and NSX resources, so security-relevant actions are registered for review.

Centralized log collection is handled by VCF Log Management, which collects log data from VMware vCenter, VMware ESX hosts, NSX, and other VCF components. Administrators can search and filter log events by timestamp, source, text, and structured fields. VCF Log Management includes content packs for VCF components that provide pre-built dashboards, alerts, and queries organized by use case, giving immediate visibility into authentication failures, privilege changes, configuration modifications, and other security-relevant events. A dedicated NSX content pack provides alerts for NSX environment monitoring. VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, providing a direct path to external SIEM or log management systems. ESX hosts support configurable syslog log levels and can forward syslog messages to a remote log server using `esxcli` commands. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote syslog host defined by `Syslog.global.logHost`, allowing auditors to verify that security-relevant audit records reach the centralized log collection infrastructure. NSX components record security-related events in audit logs stored at `/var/log/audit/audit.log` and send audit logs directly to configured remote syslog servers. NSX also provides security compliance events documented in the NSX Event Catalog. VCF Operations integrates its own audit log with syslog and can forward user activity audit logs to an external syslog server to support security auditing requirements.

Within VMware Kubernetes Service (VKS) clusters and vSphere Supervisor, the Kubernetes API server produces structured audit records for all API interactions. Each audit event captures the audit level, a unique audit ID, the requesting user, the target resource and namespace, the source IP address, the operation performed, and the stage of request handling at the time the record was generated. An audit policy controls which verbs and resource types are recorded and at what level of detail, allowing administrators to scope coverage to security-relevant operations. The Kubernetes audit logger records actions taken by the API for later analysis. Audit records can be written to a local file by mounting a policy at `/etc/kubernetes/audit-policy.yaml` with logs written to `/var/log/kubernetes/audit/`, and node log agents can collect and forward them to a central log store as part of the observability pipeline. Kubernetes system component logs, including those from the API server, controller manager, and scheduler, record cluster events with configurable verbosity, providing coarse-grained error reporting up to fine-grained step-by-step traces. Application and system logs together give a chronological record of events inside workloads and security-related activities, and should be routed to an external SIEM or log management platform to make ongoing review feasible at scale. Pod Security Admission, when configured in audit mode for VKS clusters running VKr 1.25 and later, adds an audit annotation to the audit log entry for each security policy violation without blocking the workload, creating a reviewable trail of policy deviations. The Kubernetes seccomp facility supports the `SCMP_ACT_LOG` action, which allows syscalls to

execute while logging each to syslog or auditd; an audit.json seccomp profile can log all syscalls of a process for detailed syscall-level visibility. Audit rules can be written to alert on specific security-relevant events, such as concurrent reading of multiple Secrets by a single user.

For log forwarding from the VKS and consumption layer, administrators can apply the LogAgentConfiguration Custom Resource to a vSphere Namespace to stream workload logs to a remote syslog server. Syslog messages from vSphere Pods include metadata fields for namespace name, pod UID, pod name, container name, and ESX host name, providing the context needed to correlate pod events with platform-level audit records. VKS clusters support the Fluent Bit standard package, which can forward logs to Syslog, HTTP, Elasticsearch, Kafka, and Splunk endpoints, giving operators a direct path to route VKS log streams into external SIEM or log management systems alongside VCF platform logs. Fluent Bit on VKS clusters collects Kubernetes API Server audit logs in JSON format, Linux authentication logs, and container runtime interface logs through configurable parsers and filters. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit output from /var/log/vmware/audit/kube-apiserver.log using the tag audit.apiserver.*, with local buffering at /var/log/vmware/fluentbit/flb_audit_apiserver before forwarding to configured destinations. VM Operator logs within VKS clusters record reconciliation events for VirtualMachineService resources and VM creation failures, extending operational event visibility to the workload layer.

For alerting and escalation, VCF Operations classifies alerts by impact into three categories: Health alerts indicate problems requiring immediate attention, Risk alerts indicate problems that must be addressed before they become health issues, and Efficiency alerts identify areas where resources can be reclaimed or optimized. The Platform Health Alerts page provides a centralized view of all health-related alerts across data sources and infrastructure nodes, and alerts can be filtered and sorted by severity on the dashboard. Alert definitions can be created against log events and metrics, and when an alert fires, it presents the triggering symptoms along with recommendations for resolution so operators can evaluate the event and take action. Custom alert definitions allow organizations to tailor monitoring to their specific escalation criteria. VCF Operations also activates alert definitions within compliance policies, assessing objects against selected compliance standards and triggering alerts when deviations are detected. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the alerting posture to organizational requirements.

VCF Operations supports multiple outbound notification methods for incident escalation: Standard Email, SNMP Trap, Webhook Notification, Slack, and ServiceNow Notification plug-ins all support notification rules. Notification rules can be configured with payload templates to route specific alert types to the appropriate teams or external incident management systems. Syslog forwarding from all VCF components enables integration with external SIEM platforms for organizations that centralize event review and incident escalation in those systems.

The Troubleshooting Incidents page provides a summary of all incidents, including status, entity counts for in-progress incidents, and counts of top root causes, giving operators a consolidated view for ongoing event review. Predefined dashboards are complemented with out-of-the-box customizable alerts and reports to assist with operational awareness.

VMware vDefend (Contributes)

VMware vDefend generates security event logs across its Distributed Firewall (DFW), Gateway Firewall (GFW), and IDS/IPS components. In 9.1, vDefend integrates with VCF Log Management, which collects Unified Security Logs covering DFW, GFW, Identity Firewall, FQDN Analysis, TLS Inspection, IDPS, and URL Filtering events in a consolidated stream suitable for forwarding to external SIEM platforms.

The Security Overview Dashboard's Threat Event Monitoring tab provides ongoing visibility into security issues across the data center, displaying statistics on Malicious IPs, Top Blocked IPs, Top VMs Accessing Malicious IPs, and Top Blocked Categories. Administrators can filter the view by All Traffic, Distributed Only, or Gateway Only events, and a trend graph shows intrusion events over time categorized by Intrusion Severity.

The dedicated IDS/IPS Security Dashboard supports event monitoring for both Distributed and Gateway deployments. Intrusion events can be filtered by Attack Target, Attack Type, and CVSS score threshold to focus review on the highest-priority activity. IDS/IPS events can also be exported directly to syslog by enabling the ids_events_to_syslog setting on ESX hosts, providing centralized log collection through existing syslog infrastructure independent of the NDR component; this

setting is disabled by default and must be explicitly enabled. In 9.1, vDefend IDS/IPS and Network Detection and Response (NDR) support date range filtering for event detail review through the Intelligent Assist triage interface, enabling temporal analysis of security events and intrusion attempts.

Security Intelligence, accessible through Security Explorer, provides a View Full Event History capability that surfaces all events associated with a given signature ID along with their intrusion severity, supporting focused review of specific threat patterns. File event statistics are available through the Threat Monitoring dashboard in Security Services Platform, with graphs filterable by configurable time period.

NDR collects and analyzes security event data for real-time monitoring and supports SIEM integration for centralized event management. The organizational processes of reviewing logs on an ongoing basis and escalating incidents in accordance with defined timelines and procedures must be established and managed outside vDefend through SIEM tooling and documented response procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates structured audit events and alarm notifications across its disaster recovery components, providing the event sources and escalation mechanisms that support ongoing security event monitoring.

PNR supports event logging where each event type has a corresponding alarm that can trigger when the event occurs. Events carry three severity levels: Info for normal operational information, Warning for conditions requiring attention that do not affect system operation, and Error for failed operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Audit events for user actions include the event name, user identity, and source IP address. vSphere Replication maintains a dedicated audit log at `/opt/vmware/support/logs/hms/hms-audit.log` and records login events with timestamps, user identity, session keys, and locale information. Authorization error messages include timestamps and component information to support security event tracking.

PNR audits changes to protection configurations: it logs when consistency groups are added to protection groups as Info-level events and when protected consistency groups enter error or warning states as Error-level events. PNR monitors connections between sites by sending periodic ping requests and logging Site Status Events that reflect the connection state between protected and recovery sites. vSphere Replication generates typed audit events when virtual machines and hosts are configured or unconfigured for replication. The PNR health monitor service checks each health finding every five minutes and raises Warning-status alerts for expired snapshot schedules, replication errors such as missing VMs, and site connectivity issues.

Alarms can be configured to send email notifications, SNMP traps, or execute scripts when specified event conditions are met, allowing DR events to feed into established incident response and escalation procedures. PNR maintains an Alarms list that provides a searchable, severity-filterable history of notifications that required attention, supporting periodic review.

VCF Operations collects configuration, component health, and usage information from PNR servers and site pairs to populate Protection and Recovery dashboards. These dashboards display alerts about configurations requiring attention and health status for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites. The Inventory view provides object-level monitoring of health status, metrics, and alerts across all protected objects.

The Clean Room Orchestrator maintains a global collection of events, tasks, and alarms for ransomware recovery operations. Event forwarding from PNR to VCF Log Management (version 9.0 and above) is supported for centralized log collection and review.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several capabilities that support ongoing event log review. The primary interface for reviewing non-database-related operations is the System Audit Events view, accessible through the System Audit section of the Provider interface. This view records and displays DSM management-plane operations in a structured format, including the Component field (which DSM component performed the operation), Event Type (the type of audited event or operation), Event Details (operation-specific details for the event), Event Time in UTC, Status, and Source. The Source field

records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user intervention. Administrators can review these events directly in the UI or export them in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view. Exports include all audit events visible to the reviewing user, regardless of how many events appear on a single page, enabling complete off-platform analysis and reporting.

In addition to the System Audit Events view, DSM provides Gateway Audit Logs accessible through the Audit Logs section. Gateway Audit Logs track user read and write operations to DSM data services and infrastructure objects performed in the DSM UI or the DSM Gateway Kubernetes interface. Gateway audit log files are stored on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and are retained for the last five days on the Provider VM. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit," supporting log retention for ongoing and retrospective review. The gateway audit logs contain standard Kubernetes audit events but do not record the content of secrets.

DSM generates a structured set of alerts to support proactive monitoring and help surface conditions that may require investigation. At the infrastructure level, DSM raises an `INFRASTRUCTURE_POLICY_VC_ALARMS` alert when one or more active infrastructure resource alarms are detected in VMware vCenter, and generates alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates a `VCENTER_CONNECTIVITY` alert when vCenter connectivity fails; troubleshooting steps include verifying vCenter connectivity, checking vCenter authentication logs, and verifying that the service account is not locked. At the database level, DSM provides an Alerts pane in the Monitoring tab where administrators can monitor alerts triggered on databases, covering conditions such as CPU Health, Data Disk Health, System Disk Health, Max Connections, Custom Config Health, and Database Engine Health. Administrators can configure and edit alert threshold values and time limits for warning and critical severities on these conditions, allowing organizations to tune alerting sensitivity to their operational requirements. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations, enabling integration with external notification systems.

Organizations that deploy the VCF Operations integration can extend monitoring visibility. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state, displays active alerts and inventory items on the Data Services View dashboard, and surfaces performance data at three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for database-specific metrics such as Active Connections, Commits, Rollbacks, and Deadlocks.

DSM provides the audit event records, alert generation, export capabilities, log archival, and optional VCF Operations integration needed to support a log review program. The review cadence, escalation thresholds, escalation workflows, and incident management procedures are organizational responsibilities that must be defined and operated separately. Integration with a SIEM or centralized log management platform is also an organizational decision.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a multi-layer event logging and alerting infrastructure that gives organizations the data needed to support ongoing security event review and incident escalation.

Avi's Event Logs record detailed information about system activities, configuration changes, and operational events, including the identity of users who made configuration changes and the timestamps of those changes. The Config Audit Trail provides a filtered view of this event stream, isolating configuration changes and user activity events over a selectable time period to support both real-time review and retrospective audit. The Avi Controller and Service Engine track health score changes and SSL certificate expiration events, extending automated monitoring beyond configuration activity.

At the application layer, the WAF captures security events through App Log Analytics when a WAF Application Rule is triggered, recording information about the type of attack detected. WAF logging supports granular audit log parts, including matched XSS data with variable name and matched content (using the `ctl:auditLogParts=+E` configuration). Avi DataScript supports logging of security events such as blocklisted IP access attempts using the `log()` function, enabling custom event capture for virtual services. Avi Controller also logs denial-of-service attack events with event details including event identifier, attack count, threshold values, and alert level.

For external integration, Avi forwards events to SIEM platforms and monitoring systems through multiple channels. The Syslog-Audit-Persistence alert action template streams audit events to external syslog servers to support audit compliance requirements. Alert notifications can be delivered by email, SNMP trap, or custom API webhooks, notifying administrators of security events as they occur. Avi Controller and Service Engine log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk. The Avi Application Security Report gives security teams a consolidated view of overall security posture, threat monitoring, and audit-ready records.

Administrators should be aware that debug logs and Event Logs are not forwarded through OS-level syslog configuration; Event Logs require the Avi-specific Syslog-Audit-Persistence mechanism to reach external syslog servers. Syslog notifications push alerts to syslog servers but do not automatically export virtual service logs; those must be pulled via API or scripted for delivery from the Controller to a remote log server.

Control 164.308(a)(2)

Standard: Assigned security responsibility. Identify the security official who is responsible for the development and implementation of the policies and procedures required by this subpart for the covered entity or business associate.

SCF Controls: GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(3)(i)

Standard: Workforce security. Implement policies and procedures to ensure that all members of its workforce have appropriate access to electronic protected health information, as provided under paragraph (a)(4) of this section, and to prevent those workforce members who do not have access under paragraph (a)(4) of this section from obtaining access to electronic protected health information.

SCF Controls: CFG-08, GOV-02, IAC-01, IAC-08, IAC-21

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization namespace, administrators populate the authorizedGroups setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the oidc-groups-claim setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS

requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types, and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the `oidc-extra-audiences` setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend contributes to restricting access to sensitive data workloads at the network layer through microsegmentation and firewall policy. The Distributed Firewall enforces both inter-application and intra-application tier access controls, restricting which workloads and users can communicate with sensitive systems such as DNS, DHCP, NTP, and LDAP infrastructure servers to reduce exposure to unauthorized access and data exfiltration. The Distributed Firewall supports consistent enforcement of Layer 2 through Layer 7 access policies, including FQDN filtering to restrict access to sensitive network destinations by domain name.

Privileged labels provide a tamper-proof mechanism for anchoring Distributed Firewall rules to immutable labels that restrict virtual machines from being removed from their assigned security groups, supporting stable enforcement of access policies on sensitive workloads. The Identity Firewall can be enabled to enforce access controls based on user identity, supplementing workload-based segmentation with user-aware policies that follow identity across the environment.

The vDefend gateway firewall supports isolation between organizational projects by denying all inter-project communication except for essential infrastructure protocols such as DHCP, DNS, NTP, and ICMP, restricting lateral access to sensitive systems. URL filtering applies access control policies to both encrypted and non-encrypted web traffic, allowing administrators to restrict web-based access to sensitive resources.

Security Services Platform (SSP) extends enforcement to bare metal servers, with security policies defined, propagated, and enforced consistently across both virtualized and physical infrastructure. Security Intelligence within SSP generates granular application-level rules that allow only authorized traffic between environments and recommends restricting risky application protocols that carry data in clear text. Segmentation Monitoring identifies servers and services not fully protected by security rules, allowing administrators to prioritize coverage of sensitive assets. Initial policy recommendations can be deployed in a monitoring mode that allows traffic while administrators verify that rules do not disrupt legitimate operations before full enforcement.

Data-level access controls such as encryption, data loss prevention, and database access management are outside vDefend's scope and must be addressed by complementary data protection tools.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For

SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control 164.308(a)(3)(ii)(A)

Implementation specifications: Authorization and/or supervision (Addressable). Implement procedures for the authorization and/or supervision of workforce members who work with electronic protected health information or in locations where it might be accessed.

SCF Controls: HRS-01, IAC-07.1, IAC-08, IAC-28.1

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization namespace, administrators populate the authorizedGroups setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the oidc-groups-claim setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types,

and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the `oidc-extra-audiences` setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration

rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control 164.308(a)(3)(ii)(B)

Implementation specifications: Workforce clearance procedure (Addressable). Implement procedures to determine that the access of a workforce member to electronic protected health information is appropriate.

SCF Controls: HRS-02, HRS-03, IAC-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support periodic review of account privileges, though the organizational process of scheduling and conducting those reviews remains a customer responsibility.

VCF's role-based access control model structures privileges as fine-grained access controls that can be grouped into roles and mapped to users or groups. This model applies across VCF components including VMware vCenter, NSX, VCF Automation, and Avi Load Balancer. Administrators can define custom roles containing only the minimum set of required privileges, and VCF documentation recommends that user accounts be given the minimal number of privileges on the system that they require to do their jobs. This least-privilege foundation makes periodic reviews more tractable by providing well-defined privilege boundaries to evaluate against. For VMware ESX hosts specifically, vSphere documentation recommends creating individual accounts for administrative access rather than shared accounts, which provides the per-account audit traceability needed to conduct meaningful privilege reviews at the host level.

VCF Operations generates User Permissions Audit reports that provide traceability of user accounts, their roles, access groups, and access privileges. These reports give reviewers a consolidated view of who has access to what across the environment, directly supporting the periodic review process. VCF Operations Access Control also maintains audit records of the last person to update a user account and the last time the user account was updated, which helps reviewers identify stale accounts or recently changed privilege assignments that warrant closer inspection. System administrators can change account attributes, revoke previously granted access, and delete accounts when reviews determine that privileges are no longer needed.

For deeper analysis of privilege usage, vCenter includes a Privilege Checks Recorder feature that monitors and records the privileges checked during vCenter operations. Administrators can retrieve recorded privilege checks through the vCenter Management API, filtering results by managed object IDs, request operation IDs, privilege names, sessions, and user or group identities. This data allows reviewers to compare assigned privileges against actually exercised privileges, identifying cases where accounts hold more access than they use. The PrivilegeChecks service interface provides operations for retrieving the latest privilege checks along with corresponding sessions, users, managed objects, and operation IDs. The recorded privilege check data can also be used to create scripts that automatically build roles with the minimum privileges required for specific workflows, helping enforce least-privilege assignments as an outcome of periodic reviews. Note that the Privilege Checks Recorder is available only through the API and supports scripted workflows; it does not provide a graphical interface, so organizations should plan for scripted or automated retrieval of privilege check data when incorporating this capability into review processes.

For service accounts specifically, VCF Automation allows system administrators to manage service account attributes, revoke previously granted access, and delete service accounts entirely. Service account creation requires specific administrative privileges (View Service Accounts and Manage Service Accounts), restricting who can provision these accounts. Service accounts are granted access using the Request Service Account Authorization process, which restricts token access so that only the authorized application can use it. During platform upgrades, VCF automatically deletes old service account privileges and replaces them with predefined privileges, providing a form of automated privilege realignment.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and VCF Services, extends the privilege review surface to Kubernetes workloads. Kubernetes RBAC structures permissions through Roles and ClusterRoles that define discrete permission sets, and RoleBindings and ClusterRoleBindings that attach those permissions to users, groups, and ServiceAccounts. This declarative model allows cluster administrators to enumerate all

privilege assignments at any point in time using standard Kubernetes API tools such as `kubectl auth can-i`, `kubectl get rolebindings`, and `kubectl get clusterrolebindings`. Kubernetes documentation specifically recommends periodically reviewing RBAC settings for redundant entries and possible privilege escalation paths, and recommends that cluster administrators avoid using cluster-admin accounts except where specifically required, instead using low-privileged accounts for routine operations and reserving broader access for break-glass emergency scenarios. VKS cluster security guidance calls for scoping IAM role trust policies to specific service accounts and namespaces to enforce least privilege at the workload level.

For Kubernetes service accounts, Kubernetes separates ServiceAccount objects from human user identities, and VCF Consumption documentation notes that auditing considerations for humans and service accounts may differ; this separation makes it easier to apply differentiated audit strategies and to review workload permissions independently of human access reviews. Each in-cluster service should be configured with a dedicated ServiceAccount with only the permissions required for its function, and granting cluster-wide roles to all service accounts should be avoided in favor of per-namespace RoleBindings. The LegacyServiceAccountTokenCleanup feature gate enables automatic cleanup of Secret-based service account tokens that are not used within a configurable period (with a default retention of one year), reducing the risk of stale service account credentials persisting beyond their useful lifetime. Kubernetes audit logging records API server interactions including RBAC-related operations, and organizations can configure the Kubernetes audit policy to capture reads and modifications of Role, ClusterRole, RoleBinding, and ClusterRoleBinding resources, supporting an audit trail for privilege changes between review cycles.

The vSphere Supervisor adds platform-level privilege gates that are subject to periodic review. The Manage Supervisor Services privilege is required to delete or deactivate a Supervisor Service, and the SupervisorServices.Install privilege is required to install, upgrade, or uninstall service instances on the Supervisor; these privileges are managed through VCF SSO and vCenter RBAC, which integrates with Supervisor namespace permissions. VCF Services consumed through the Tenant Portal and Content Hub can surface RBAC controls through Argo CD, where RBAC policy rules control account permissions including the ability to grant admin roles to specific local accounts and assign accounts to role groups through group mappings, supporting review of GitOps-layer access assignments.

VCF Automation also supports an access request approval workflow where access requests require approval before granting OAuth token access. This provides a checkpoint for new privilege grants that complements periodic reviews of existing privileges.

NSX Manager audits any user account change, providing an audit trail that reviewers can use to track privilege modifications over time and verify that changes follow approved processes.

VCF does not include automated recertification workflows or scheduled access review campaigns. Organizations should use external identity governance tools for the scheduling and tracking aspects of periodic privilege reviews, using the audit and reporting data that VCF and its Consumption layer provide as input to those reviews.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) supports periodic review of user privileges within its own management plane by providing an admin interface where role assignments for both local and directory-managed accounts can be reviewed and updated. In 9.1, SSP implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. The Enterprise Admin role grants full access to all platform operations, including User Management, while the Auditor role is scoped to read-only access, allowing holders to view information and track activity without the ability to make changes. The predefined local Auditor account provides API and service access for auditing purposes rather than administrative control. Access to User Management and modification of role assignments requires Admin privileges; administrators can review and adjust which accounts hold each role through the SSP interface. When removing an identity source from SSP, all associated user role assignments must first be deleted, which provides a built-in enforcement point for confirming that access has been cleaned up before the identity source is removed. vDefend's contribution is limited to privilege review within its own management interfaces; periodic review of privileges across the broader organizational environment, including service accounts and other systems, requires organizational governance processes outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to periodic privilege review through its role-based access model, defined database-level privilege baselines, and audit logging capabilities, though the periodic review process itself is an organizational responsibility.

DSM organizes administrative access through two distinct roles: the DSM Admin role and the DSM User role. The Admin role carries broader capabilities across the environment, while the DSM User role is scoped to the user's own objects within their namespace. This role separation allows administrators to identify which users hold elevated access by reviewing the DSM user list and confirming that role assignments remain appropriate. Deleting a user in DSM revokes their access to the system. When access must be suspended while keeping databases running, administrators can reset the user password and delegate database management to a different account instead.

DSM maintains service account rotation logs that can be checked to verify service account management activities, including those for vCenter authentication. Service account expiry triggers an alert, supporting investigations into whether continued access remains needed.

For database-level privilege management, DSM defines and enforces a documented privilege baseline across its supported database engines. The default MySQL database user is not a superuser; DSM grants specific data and schema operation privileges while explicitly revoking create and update privileges on the mysql.system schema. MySQL users authenticated through LDAPS can be granted specific privileges using the GRANT command to restrict access to designated databases. For PostgreSQL, host-based authentication requires database administrators to grant specific privileges to LDAPS users. For SQL Server clusters, DSM restricts the cluster administrator login to read-only privileges and specific ALTER permissions for server management and auditing rather than full administrative access. DSM also deactivates the default sa account and uses a reserved internal management account for its own operations, reducing the number of high-privilege accounts requiring review.

DSM adds configurable audit logging for SQL Server clusters. Administrators can select the level of audit logging for system logins and set the log retention period. Preset server audit configurations support login tracking, providing a record of login activity that can inform periodic access reviews.

To satisfy the full requirements of this control, organizations must establish a periodic review process that formally schedules reviews, documents approvals, and records privilege changes. DSM does not automate the review cycle or generate access certification reports, so an access governance program or external identity management tool is needed to drive the review cadence and produce the evidence that auditors typically require.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a role-based access control (RBAC) framework within the Avi Controller that gives administrators the mechanisms to view, assign, modify, and revoke account privileges for all users and service accounts across all tenants. Access to account management functions is governed by the Accounts section write privilege: any administrator holding that privilege can reactivate or deactivate other user accounts, modify role assignments, and adjust tenant scoping.

Avi enforces RBAC through Tenant and Role assignment, restricting each user account to specific areas of the system at account creation. Accounts can be scoped to specific tenants and granted different roles within each tenant, supporting the granular privilege model needed for periodic access reviews. The system ships with predefined roles. A Super User privilege level grants the same privileges as the admin account and is selectable via a checkbox during user account creation.

Administrators can also create custom user account profiles with configurable security thresholds covering password history, login failure behavior, session limits, and credential timeout policies. Write privilege at the Controller level grants full access to create, read, modify, and delete resources, while more narrowly scoped roles can be assigned per tenant.

For CLI access, the admin account is the standard administrative account and is maintained as a locally authenticated account even in systems configured for remote authentication. Non-admin users access the Avi Load Balancer Linux CLI through an SSH client under distinct privilege boundaries, providing separation between elevated shell access and read-only log inspection.

For service account and API access patterns, the Avi Controller supports temporary token authentication. A system administrator can issue a token with a defined expiration time (the token-expiration setting), after which the token automatically expires without requiring explicit revocation. This bounds the duration of any granted service account access and reduces exposure from stale credentials. In VCF-integrated deployments, Avi manages two user accounts for password updates, admin and vcfops-admin, and the Controller provides a REST API endpoint for service account password rotation via POST to the reverse-proxy/password-update endpoint, requiring the username, old password, and new password. For Avi SaaS Controller deployments, authorization tokens can be generated to enable service account authentication.

The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization. Administrators can suspend and reactivate accounts as needed. The periodic cadence of privilege reviews, the criteria for determining whether a privilege remains necessary, and the organizational decision to reassign or remove access are processes that Avi's account management tooling supports but does not schedule or automate.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(3)(ii)(C)

Implementation specifications: Termination procedures (Addressable). Implement procedures for terminating access to electronic protected health information when the employment of, or other arrangement with, a workforce member ends or as required by determinations made as specified in paragraph (a)(3)(ii)(B) of this section.

SCF Controls: HRS-08, HRS-09, IAC-07, IAC-07.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical mechanisms that support timely revocation of user access rights, though the organizational process of triggering these actions upon termination of employment or contract remains outside the platform itself.

VCF relies on federated identity sources such as Active Directory, LDAP, SAML, and OIDC for authentication and authorization through VCF SSO. When a user is disabled or removed in the organization's identity provider, that user can no longer authenticate to VCF components. Role-based access control (RBAC) ties privileges to federated group membership, so changes to group membership in the identity provider are reflected across VCF without requiring per-component updates. NSX implements RBAC to restrict system access to authorized users by assigning roles with specific permissions. For environments that integrate with Active Directory, administrators should force a logout when group membership is modified so that removing a terminated user from AD groups takes effect without waiting for the session to expire naturally. At the VMware ESX host level, however, users who are logged in and removed from the domain retain their host permissions until the host is restarted, creating a potential window of continued access that administrators should account for in offboarding procedures. At the VMware vCenter layer, when a user is removed from the domain, all permissions assigned to that user are removed automatically when the next validation cycle occurs.

The Consumption layer of VCF, encompassing VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends this identity-based revocation model into workload environments. Supervisor namespaces authenticate users through VCF SSO, so disabling or removing a user's VCF SSO identity, or the upstream LDAP or Active Directory identity it references, revokes that user's ability to authenticate to Supervisor namespaces. Within namespaces, access is governed by Kubernetes RoleBindings and ClusterRoleBindings that associate user identities with defined Roles. Administrators can delete these bindings through the Kubernetes API or through VMware vCenter to remove a specific user's access without affecting other users. For Windows VKS node pools, Supervisor integrates with Active Directory and enforces access control rules that restrict computer object management to a designated Kubernetes service account identity, meaning Windows-based workload identities are subject to Active Directory lifecycle management and are revoked when the associated AD identity is removed.

Supervisor Services enforce their own RBAC policies layered on top of namespace access. The Secret Store service enforces role-based access for administrators, DevOps engineers, and application tenants, requiring that each role assignment be explicitly granted and therefore explicitly revocable. The Argo CD Supervisor Service implements RBAC through policy rules defining permissions for accounts and group mappings, with local account authentication subject to global RBAC policies. Access to Supervisor Service management operations, such as deleting services, requires the Manage Supervisor Services privilege assigned in VMware vCenter; removing that privilege assignment revokes the user's ability to perform those operations. Kubernetes ServiceAccount tokens, used for workload and automation access, can be deleted or rotated independently of human user accounts, so deleting a ServiceAccount or its associated token secrets immediately invalidates API access for that workload identity. Kubernetes audit logging records API server activity by authenticated user identity, providing a record of access events that supports verification that revocation has taken effect. Administrators should ensure that user account creation prevents reuse of deleted usernames, since Kubernetes RBAC bindings reference usernames by string and a newly created account with the same name as a deleted user could automatically inherit any bindings that were not cleaned up after the original account was removed.

For accounts managed directly within VCF components, administrators have tools to revoke access at multiple levels. VCF Automation provides an Access Control interface where administrators can deactivate or delete user accounts and revoke individual access tokens. Disabling a user in VCF Automation removes their active access immediately while preserving the account for potential reactivation. System administrators with the Manage General ACL right can also create, modify, and remove specific access control lists through the accessControls API, enabling scripted or automated access removal as part of an offboarding workflow. At the vCenter layer, the AuthorizationManager provides the RemoveAuthorizationRole method, which allows administrators to programmatically remove role assignments from users and groups. In NSX, the admin user or any user with the Enterprise Admin role can activate or deactivate local user accounts. Enterprise Administrators can also modify or delete objects owned by principal identities, which addresses access tied to service integrations rather than individual user accounts.

Access tokens in VCF Automation have a default lifetime of one hour, based on refresh tokens that last 90 days. Refresh tokens can be revoked earlier than their expiry, and for service accounts, tokens rotate after each use. The refresh token can optionally be rotated with each access, giving administrators the ability to cut off service account access promptly when needed. In the Kubernetes layer, industry-standard practices recommend using an authentication provider that supports configurable token lifetimes with short lifetimes where possible; the Kubernetes TokenRequest API supports short-lived token issuance for service authentication, reducing the window of access following credential invalidation.

VCF Automation also supports revoking access at the organizational level. Deactivating an organization prevents all users from logging in and immediately terminates the sessions of any users currently logged in. While this is a broader action than individual user revocation, it is relevant for contract termination scenarios where an entire tenant or partner organization's access must be cut off. Similarly, unpublishing a role removes it from selected organizations, so any users holding that role lose the associated rights.

VCF Automation enforces deployment lease policies that automatically shut down and destroy deployments after a configurable lease period expires. If no lease policies are defined, deployments never expire and must be manually destroyed. When a lease expires, the deployment is shut down and destroyed after a grace period. These lease policies provide an additional safeguard against lingering resource access when user offboarding is delayed.

These capabilities collectively provide the technical mechanisms for timely access revocation across the VCF platform, including the Consumption and Kubernetes workload layers. However, VCF does not include an HR integration, automated offboarding workflow engine, or termination event trigger. The organization must implement processes that connect its HR or identity governance systems to VCF's access management interfaces so that termination events result in prompt execution of account disabling, token revocation, RoleBinding deletion, and role removal across all VCF components.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides direct mechanisms for revoking access to the DSM platform when a user's employment or contract ends. Administrator users can delete local user accounts through the user management interface, and deleting a user immediately revokes their access to DSM. Role assignments and namespace access for existing local users can also be modified through the same interface, which allows administrators to narrow or suspend access without full deletion if circumstances require it.

The account removal workflow for local users follows a defined sequence of steps. Before deleting a user, an administrator must reset that user's DSM password to block further authentication, then delegate management of any databases owned by that user to another active user. This handoff is required because DSM does not allow deletion of a user account while the user still owns running databases. Once the databases are reassigned, the account can be deleted and access is fully revoked. DSM user accounts also maintain account state attributes, including failed login count, last failed login time, locked state start time, and a force-password-change flag, which the platform uses to enforce account lockout policies and support credential management during the offboarding sequence.

The offboarding process requires administrator action to be triggered and completed. DSM does not natively integrate with HR systems or identity governance platforms to detect termination events and initiate access revocation automatically. The timeliness of access revocation therefore depends on the organization's offboarding procedures, including how promptly the

termination is communicated to DSM administrators. Organizations should maintain clear internal procedures that specify who is responsible for initiating the DSM offboarding workflow and what the expected response window is following a termination event.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support the timely revocation of user access rights upon termination, within the scope of its local user account and session management.

For local user accounts, administrators with write access to the Accounts section can deactivate or delete accounts directly. Deactivation is reversible, allowing an account to be reactivated if needed; account deletion uses the DELETE API operation to remove the account entirely. Both operations are available through the Avi Controller's user account management interface.

Avi's token-based authentication model supports access termination through time-limited tokens. The Avi Controller system administrator can create a temporary token for a user with a defined expiration window; once the token expires, the user loses access automatically without requiring explicit token deletion. The CLI's `configure show jobs` command displays all duration-based jobs pending expiry, giving administrators visibility into outstanding token lifetimes.

For federated or externally authenticated users, the Avi Controller's Auth Mapping profile provides a mechanism to revoke access at login time: updating an Auth Mapping rule to deny privileges to a specific user prevents that user from obtaining any roles or tenants upon the next login attempt, even if the external identity provider still authenticates them. Session termination for REST API users is enforced: when a session ends through logout or timeout, subsequent API calls fail validation and the session is closed.

For Kubernetes environments using the Avi Kubernetes Operator (AKO), the `/oauth/logout` endpoint is available for explicit OAuth session termination, supporting access removal in AKO-managed application delivery contexts.

Timely revocation upon employment termination is an organizational process. Avi provides account suspension, deletion, token expiration, Auth Mapping access denial, and session termination mechanisms, but an administrator must initiate the action when employment ends; Avi does not integrate with HR or employee lifecycle systems to trigger revocation automatically when a user's status changes.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(4)(i)

Standard: Information access management. Implement policies and procedures for authorizing access to electronic protected health information that are consistent with the applicable requirements of subpart E of this part.

SCF Controls: GOV-02, IAC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcidentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID

Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given

database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(4)(ii)(A)

Implementation specifications: Isolating health care clearinghouse functions (Required). If a health care clearinghouse is part of a larger organization, the clearinghouse must implement policies and procedures that protect the electronic protected health information of the clearinghouse from unauthorized access by the larger organization.

SCF Controls: GOV-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(4)(ii)(B)

Implementation specifications: Access authorization (Addressable). Implement policies and procedures for granting access to electronic protected health information, for example, through access to a workstation, transaction, program, process, or other mechanism.

SCF Controls: IAC-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcidentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID

Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given

database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(4)(ii)(C)

Implementation specifications: Access establishment and modification (Addressable). Implement policies and procedures that, based upon the covered entity's or the business associate's access authorization policies, establish, document, review, and modify a user's right of access to a workstation, transaction, program, or process.

SCF Controls: IAC-08

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization namespace, administrators populate the authorizedGroups setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the oidc-groups-claim setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS

requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types, and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the `oidc-extra-audiences` setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration

rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control 164.308(a)(5)(i)

Standard: Security awareness and training. Implement a security awareness and training program for all members of its workforce (including management).

SCF Controls: SAT-01, SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(5)(ii)(A)

Implementation specifications. Implement: Security reminders (Addressable). Periodic security updates.

SCF Controls: SAT-03.6

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(5)(ii)(B)

Implementation specifications. Implement: Protection from malicious software (Addressable). Procedures for guarding against, detecting, and reporting malicious software.

SCF Controls: SAT-03.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(5)(ii)(C)

Implementation specifications. Implement: Log-in monitoring (Addressable). Procedures for monitoring log-in attempts and reporting discrepancies.

SCF Controls: SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(5)(ii)(D)

Implementation specifications. Implement: Password management (Addressable). Procedures for creating, changing, and safeguarding passwords.

SCF Controls: SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(6)(i)

Standard: Security incident procedures. Implement policies and procedures to address security incidents.

SCF Controls: GOV-02, IRO-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis; results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(6)(ii)

Implementation specification: Response and reporting (Required). Identify and respond to suspected or known security incidents; mitigate, to the extent practicable, harmful effects of security incidents that are known to the covered entity or business associate; and document security incidents and their outcomes.

SCF Controls: IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(7)(i)

Standard: Contingency plan. Establish (and implement as needed) policies and procedures for responding to an emergency or other occurrence (for example, fire, vandalism, system failure, and natural disaster) that damages systems that contain electronic protected health information.

SCF Controls: BCD-01, GOV-02, IRO-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to incident response operations by providing integrated threat detection, investigation, correlation, and remediation capabilities within the network security layer of VCF. Security Services Platform defines a Security Operator role specifically for monitoring security systems and responding to security incidents, providing a built-in responsibility model for incident response activities at the network security layer.

Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take appropriate mitigation actions. The Campaign Blueprint feature visualizes correlated security events and key actors within a campaign, simplifying triage and investigation to reduce mean time to detection. Campaign correlation surfaces multi-stage attack patterns: a drive-by infection event followed by a command-and-control event on the same workload is linked into a single campaign view. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions.

Network Detection and Response (NDR) provides security analysts with capabilities to understand security events, triage them, and remediate by creating policies. NDR includes Suspicious Traffic detectors that collect and display suspicious traffic detections as events. Each detection event receives an impact score calculated from Confidence and Severity; informational events with scores from 1 to 24 indicate activity that is not essentially malicious and help teams focus attention on higher-priority events.

Security Services Platform generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, helping teams assess the potential scope and lateral spread of an incident. The Rule Analysis feature generates downloadable CSV reports of anomaly analysis results, with separate files for each detected anomaly type. Security Services Platform provides metrics for Malware Prevention Service events, including malware family, non-benign indicators, process inspection events, and process state data, accessible through the API.

For remediation, the Response and Remediation feature in Security Services Platform performs automated policy creation based on user role and permissions. Intelligent Assist supports two remediation strategies, Targeted (surgical, with potentially lower breadth) and Comprehensive (broader scope), allowing teams to select the appropriate approach for each incident. Security Services Platform collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations. Objects generated during NDR remediation that encounter errors require manual cleanup in Intelligent Assist.

These capabilities support detection, investigation, and remediation phases of an incident response lifecycle at the network security layer. vDefend does not govern organization-wide incident response processes, maintain incident response documentation, or manage incident tracking and status coordination functions. Those organizational and process governance functions fall outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between

emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(7)(ii)(A)

Implementation specifications: Data backup plan (Required). Establish and implement procedures to create and maintain retrievable exact copies of electronic protected health information.

SCF Controls: BCD-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly

started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the

retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period.

PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy

Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control 164.308(a)(7)(ii)(B)

Implementation specifications: Disaster recovery plan (Required). Establish (and implement as needed) procedures to restore any loss of data.

SCF Controls: BCD-12

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides built-in capabilities for secure recovery and reconstitution of infrastructure and workloads to a known state after a disruption, compromise, or failure. These capabilities span compute-level high availability, storage-level data protection, structured backup and restore workflows for management components, and disaster recovery across sites.

At the compute layer, vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts following a physical machine failure, restoring workloads to their prior operational state. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure with no data loss or downtime. Proactive HA supports maintenance mode as a remediation method, allowing the platform to respond to hardware degradation indicators. On TPM-equipped hosts, VMware ESX supports a Secure ESX Configuration recovery key that is required to restore the host configuration following TPM failure, TPM reset, motherboard replacement, or TPM device replacement; administrators can retrieve and store this key using ``esxcli system settings encryption recovery list`` and should keep it in a secure, off-host location.

At the storage layer, vSAN fault domains distribute data according to storage policy so that it remains available even when hardware failures occur. vSAN stretched clusters extend a cluster across two availability zones, providing site-level resiliency against the loss of an entire availability zone. When one site becomes unavailable, the surviving site continues operations, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSAN Data Protection uses native snapshots stored locally on a vSAN Express Storage Architecture (ESA) cluster to support point-in-time recovery from operational failures or ransomware attacks. Changed Block Tracking (CBT) tracks changes on disk sectors, enabling incremental backups through VADP-integrated partner backup solutions.

For large-scale disruptions, Application Disaster Recovery enables failover to a secondary site, with data replication so recovery options exist in the event of catastrophic failure. Disaster recovery can also be implemented for fleet-level components, covering the management plane itself. VCF documentation recommends planning and testing disaster recovery strategies regularly to validate that recovery time objectives (RTO) and recovery point objectives (RPO) can be met.

VCF includes structured backup and restore workflows for its management components. Administrators create a series of backup jobs that capture the state of related components, including VCF Operations, NSX Manager, and VMware vCenter, at a common point in time. VCF Operations backup is configured to take a backup on state change. VMware vCenter supports both file-based and image-based backup methods. The file-based restore procedure is a two-stage operation: stage 1 deploys a new vCenter appliance, and stage 2 transfers data from the backup location to that appliance; the restored appliance operates in non-HA mode, so vCenter High Availability must be reconfigured after recovery completes. Simultaneous backups of VCF Operations fleet management component nodes support restoring the nodes to a logically consistent state, so further integrity remediation is not required after a restore. The platform also recommends backing up the management domain vCenter and VCF Identity Broker appliance following any substantial modifications to the identity source configuration, such as a VCF SSO reset, to preserve a known-good recovery point.

For VMware vCenter specifically, the vCenter Management API provides a unified restore process that handles multiple vCenter components in a single operation. After a file-based or image-based restore, the reconciliation API checks whether vCenter partners in embedded linked mode are available, synchronizes vCenter data and services with the partners, and runs vCenter services. The appliance recovery API exposes a restore client interface for programmatic restore operations, supporting automation of recovery workflows.

VCF Operations supports image-based backup and restore as a recovery process for single node, primary node, replica node, data node, and collector failures. VCF Operations for Networks supports backup and restore of its deployment data to enable recovery when the existing setup is unrecoverable. VCF Operations HCX provides backup and restore operations through its appliance management interface, and its Mobility Groups support workload migration with state tracking, retry capabilities, and reverse migration from destination back to the original source.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere namespaces, and VCF Services consumption, extends recovery and reconstitution capabilities to containerized workloads and self-service deployments. At the Kubernetes control-plane level, ReplicaSets and Deployment controllers continuously monitor pod health and reschedule workloads to healthy nodes when pods or nodes fail. Liveness probes detect application-level failures and trigger container restarts; readiness probes gate traffic until a workload recovers from transient faults or overloads. These self-healing mechanisms operate without manual intervention for transient failures. Pod Disruption Budgets allow administrators to define minimum availability constraints that the platform respects during voluntary disruptive actions such as node upgrades or certificate rotations, so those operations proceed without taking down an entire service.

VKS clusters support structured backup and restore through VKS Cluster Management and Velero-based mechanisms. VKS Cluster Management backup operations can capture an entire cluster or a subset of data resources, and restore operations allow the operator to specify the scope of resources to recover. Restore operations include file system backups by default; CSI volume snapshots can be optionally selected for restoration. CSI Volume Snapshots deliver crash-consistent backups with support for block mode and file system mode, incremental backups, deduplication, compression, and encryption, and provide a resilient safety net for VKS clusters when primary storage infrastructure fails. CloneFromSnapshot custom resources expose a status.phase field that tracks restore progress through multiple phases, giving operators visibility into the state of ongoing recovery operations. The Velero plugin for vSphere supports backup and restore of vSphere pods, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

Deploying workloads across multiple failure zones using the Cluster API defines worker nodes across multiple failure domains with automatic healing rules that reschedule workloads when a zone becomes unavailable. Replicating control plane components across at least three failure zones limits the impact of a single-zone failure on the Kubernetes control plane itself. For VM Service workloads, the IaaS Services Console and Local Consumption Interface provide a Resources tab where users can create snapshots with optional memory capture and guest file system quiescence, and can revert a VM to a prior snapshot to restore it to a known state.

Deployment rollback is available natively in Kubernetes through Deployments with revision history, allowing administrators to return to a previous known-good revision when a newly deployed version fails. The Harness CI/CD Supervisor Service extends this with automated rollback capabilities that can revert to a previous stable state when deployment failures are detected.

Immutable infrastructure patterns supported by Kubernetes, combined with infrastructure-as-code stored in version control, provide a reproducible mechanism for reconstituting a cluster to a known, authorized state. Every change to the declared state is recorded in version control, and the cluster can be rebuilt from that record after a compromise or failure. VKS Cluster Management Policy Insights expose Sync signals that indicate when policy definitions fail to propagate from the management plane to the targeted VKS cluster estate, helping operators detect and remediate policy drift before it affects recovery posture.

Restore operations require that the target infrastructure be in place before a restore can proceed. VCF documentation recommends implementing a consistent backup strategy to safeguard the infrastructure against unforeseen disruptions and to support effective disaster recovery.

VMware vDefend (Contributes)

VMware vDefend contributes to secure recovery and reconstitution through backup and restore capabilities for its own security infrastructure, and through disaster recovery features that maintain security policy continuity across site failover events.

The Security Services Platform provides backup and restore functionality, accessible through the System > Backup and Restore interface, that allows recovery of a platform instance to its previous configuration when the current instance is in a

non-recoverable state. The backup scope includes the full system inventory: tokens, Bare Metal servers, and Bare Metal server interfaces are captured as part of inventory backup, and required certificates from the backup server are restored automatically during the restore process. The platform must be in a healthy state to perform backup operations; backup and restore cannot proceed when the platform is unhealthy. Certificate consistency between backup and restored Security Services Platform environments must be maintained to avoid NDR Sensor disruptions. Backup and restore operations enter a failed state after 30 minutes if internal services are restarted manually or due to failure. Administrators should back up the Security Services Platform before performing scale-out operations, and Bare Metal Service operations (onboarding, offboarding, or upgrading Bare Metal servers) should not be performed while backup or restore is in progress.

The Security Services Platform can be deployed on vSAN stretched configurations, which supports recovery from site failures and reduces recovery time at the infrastructure level.

For disaster recovery scenarios, NSX Federation maintains security posture during workload migration and site failover by propagating Distributed Firewall rules, security groups, and microsegmentation policies across multiple sites. When workloads fail over from a protected site to a recovery site, the vDefend security policies governing east-west traffic at the destination site are already in place. vSphere HA can be configured to handle host-level failures affecting Security Services Platform appliances.

The broader recovery of compute infrastructure, storage, virtual machines, and application workloads to a known state is handled by other VCF components such as Protection and Recovery, vSAN Data Protection, vSphere Replication, and vCenter backup and restore.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides mechanisms for secure recovery and reconstitution of virtual machine workloads to a known state after a disruption, compromise, or failure.

Recovery is organized through protection groups and recovery plans. Protection groups define which virtual machines are protected, while recovery plans orchestrate the sequence of steps required to recover those workloads at the recovery site. The state of a recovery plan is determined by the states of the protection groups within it, and the plan state governs which operations are permitted at each stage of the DR lifecycle. Recovery plans support two primary modes: planned migration for orderly, scheduled failover, and disaster recovery for unplanned site failures. A single recovery plan can also be configured to serve both disaster recovery and cyber recovery operations, allowing organizations to maintain consistent recovery procedures across different incident types.

Recovery plan testing is a built-in capability. Recovery plans should be tested before use for planned migration or disaster recovery to validate their functionality. This confirms that the recovery process will bring protected virtual machines online at the recovery site and that inventory mappings correctly place workloads on the appropriate networks, storage, and compute resources.

Cyber Recovery extends reconstitution capabilities with an Isolated Recovery Environment (IRE) designed for compromise scenarios such as ransomware incidents. The IRE provides a dedicated, isolated segment of the recovery environment that blocks direct private network connections from production, allowing compromised workloads to be analyzed and validated before being returned to production. Cyber Recovery transitions virtual machines through a controlled sequence of states, including Entering validated, Validated, Staging, and Staged, to prepare them for recovery. This state-based workflow supports data integrity validation prior to production restoration.

Recovery plan compliance checks verify that protection groups are actively replicating, that sufficient point-in-time snapshots are available for each virtual machine in the plan, and that all workflow steps can execute without conflict. Continuous compliance monitoring provides warnings when VM configuration status deviates from expected state.

The Configuration Import/Export Tool enables administrators to export PNR server configuration data, including inventory mappings, placeholder datastores, advanced settings, array manager configurations, and protection group definitions. This capability supports configuration backup and reconstitution of the PNR environment itself after a failure or migration.

PNR integrates with VCF Operations for recovery plan lifecycle visibility. The Recovery Plans Details dashboard shows the current phase of the DR lifecycle, including whether a plan is ready, whether a test is in progress, and whether incomplete recovery or cleanup operations require attention. PNR also supports recovery of VCF Automation and VCF Operations services: when a disaster event affects the management domain containing these services, PNR enables service recovery in another management domain.

All communications between PNR and VMware vCenter instances use TLS certificates and private keys. The PNR Appliance supports importing server certificates signed by a certificate authority to establish secure communications across both protected and recovery sites.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the secure recovery and reconstitution of database services to a known state following a disruption, compromise, or failure.

For backup-based recovery, DSM supports point-in-time recovery (PITR), which restores a backup to a newly created database VM. During the restore operation, the administrator can specify the database name, choose the target datastore location, and configure management settings. DSM supports restoring backups from either local or cloud-compatible (S3-compatible) storage, with restoration permitted to any point in time within the configured backup retention period. When restoring a deleted database, DSM's Archives tab allows users to access databases with retained backups and create a new database VM from a selected restore point, including options to restore to the most recent available timestamp or a custom point in time. PITR coverage extends across PostgreSQL, MySQL, and SQL Server database engines. For SQL Server, DSM automatically manages the database recovery model based on backup status, using Full Recovery for databases with automated backups enabled and Simple Recovery otherwise. Cloning a MySQL or PostgreSQL database is functionally equivalent to PITR to the latest available time, giving operators an additional path for rebuilding a known-good database instance. For failed clusters, DSM supports restoration to a different cluster with the option to target either the latest available time or a specific custom restore point.

For active recovery and failover of PostgreSQL databases, DSM provides a multi-site disaster recovery deployment model in which a secondary instance replicates from the primary across sites. When a failover is needed, DSM provides a switchover workflow that reverses the roles of instances, redirecting the secondary to become the new primary and restoring the database service to a fully operational state. DSM also provides a switchover workflow for failback, allowing operators to reverse instance roles again after the primary site is restored. DSM requires trust validation of the new primary database certificate when redirecting secondary instances during disaster recovery switchover, and operators with the DSM user role must manually establish trust between primary and secondary instances by retrieving the Certificate Authority from the primary and adding it to the Provider VM that will host the secondary. For backup-location certificates, DSM supports a Trust On First Use (TOFU) configuration that extracts and trusts certificates for specific backup locations, and at least one backup location must be configured with a trusted root certificate when a data service policy requires or allows automated backups. DSM also preserves the backing virtual machines of removed database nodes in an idle state until an instance is promoted again, maintaining infrastructure capacity for disaster recovery operations.

The resiliency of the DSM Provider Appliance itself is supplied by the underlying VCF platform (see VCF Coverage); DSM relies on vSphere High Availability to restart the appliance on another host in the event of a host failure, and does not add a separate management-plane HA mechanism. If a DSM provider restore fails for any reason, the documented procedure is to re-deploy the appliance and then follow the recovery procedure again rather than re-attempting the restore workflow on the same appliance.

DSM tracks recovery operations through its audit and operations interfaces. Event logs record Provider Restore Success events with timestamps, allowing operators to verify that recovery operations completed. Restore operation progress is visible in the Operations tab and Operations view, and a new entry appears in the Databases view table when a restore completes. To support integrity of recovery artifacts, the DSM Consumption Operator deployment includes Signature Verification of packages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer recovery and reconstitution mechanisms at the load balancing and application delivery tier.

The Avi Controller cluster can be deployed across two availability zones, with defined failure scenarios and documented recovery actions for each zone-loss case. Availability zones should be configured based on fault domains associated with shared power supplies, shared networking devices, or other common infrastructure to reduce the risk of virtual service unavailability. When the cluster enters manual recovery state following a failure or compromise, Avi automatically revokes all Service Engine secure channel credentials and causes Service Engines to reboot themselves, halting all application traffic delivery. This returns the data plane to a controlled, known state. Service Engines that subsequently re-establish connectivity to a recovered Controller node reconfigure themselves automatically to connect only to that node.

If all three Controller cluster nodes are permanently unavailable, recovery must be performed using a backup and restore procedure. When a Controller node fails but is not permanently lost, it can be recovered by bringing the existing node back online, which is transparent to existing data traffic, or by rebuilding a new Controller node, which is disruptive to existing connections. Factory reset recovery is irreversible and deletes all Controller configuration, requiring the database to be recreated from the configuration archive. When a Service Engine is compromised or rebooted independently, all configurations including private keys and public certificates are wiped from the Service Engine, providing a clean starting state for reconstitution.

Elastic High Availability (Elastic HA) provides fast recovery for individual virtual services following the failure of a Service Engine, redistributing workloads to surviving Service Engines without requiring a full cluster-level recovery event. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, so application services are restored in a defined sequence.

Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling global-level recovery and reconstitution for applications served across multiple sites.

Avi provides configuration backup and restore capabilities for the Controller. A remote backup destination should be specified to protect against non-recoverable Controller cluster failures. The Controller checks and obtains user consent prior to performing a restore operation. After a storage failure requiring a full restore, the Controller is restored from the configuration archive. The restore process follows a defined sequence: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Post-restore validation verifies the count of restored configuration objects, including clouds and Service Engine groups, confirming that the reconstituted state matches the backup. Restore operations report state information including the operation type, image version, and cluster node name. The Controller logs restore completion events with timestamps, node IP addresses, task status, and success or failure messages for audit trail purposes.

Avi's recovery mechanisms address the application delivery tier. VM-level backup and restore for the Controller and Service Engine VMs, storage-level recovery, and infrastructure reconstitution depend on the underlying VCF platform. See VCF Coverage for those mechanisms.

Control 164.308(a)(7)(ii)(C)

Implementation specifications: Emergency mode operation plan (Required). Establish (and implement as needed) procedures to enable continuation of critical business processes for protection of the security of electronic protected health information while operating in emergency mode.

SCF Controls: BCD-01, BCD-02.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's ability to continue essential missions and business functions during disruptions, though sustaining operational continuity with minimal loss requires organizational planning and processes beyond what the platform alone delivers.

Host and workload availability

vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts after a physical host failure. Admission control policies reserve sufficient capacity within a cluster for restart operations, and dedicated failover hosts can be reserved exclusively for this purpose. Proactive HA integrates with hardware health providers to detect degrading components and places hosts into maintenance mode before a failure occurs, allowing VMs to be evacuated proactively. vSAN Proactive Hardware Management informs administrators of dying devices based on disk predictive failure events generated by equipment vendors, enabling preemptive action. vSphere Fault Tolerance provides continuous availability by maintaining a live shadow instance of a VM on a separate host, enabling zero-downtime failover for individual workloads with no data loss.

Site-level resilience

vSAN stretched clusters extend a single logical cluster across two availability zones. When one site fails, the surviving site continues storage and compute operations. The site disaster tolerance rule can be configured for site mirroring, and the cluster can tolerate a witness host failure when one site is unavailable. After cluster expansion, the host failure cluster tolerates setting must be updated to reflect the number of hosts in the remaining availability zone. vSAN fault domains provide rack-level resilience within single-site deployments, enabling the environment to tolerate entire rack failures in addition to individual host, capacity device, network link, or switch failures. Configuring fault domains of smaller sizes reduces the impact of a potential rack failure.

Data protection and backup

vSAN Data Protection provides snapshot-based recovery through protection groups with configurable snapshot scheduling intervals and retention policies. Native snapshots in vSAN Express Storage Architecture (ESA) are faster than traditional vSphere snapshots, allowing more frequent backups and faster recovery. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated backup partner solutions, reducing backup windows and storage requirements. VADP-based solutions can automatically perform backup, full restore, and registration of VM Service VMs on a Supervisor.

Management component backup and restore

VCF provides structured backup and restore procedures for its management components, including VCF Operations, NSX Manager, and VMware vCenter. VCF Operations backup is configured to take a backup on state change. Backup jobs for these components should be created to capture the state of related components at a common point in time. VCF Operations supports configurable backup job retention periods and simultaneous backup of fleet management component nodes, so that restored components are in a logically consistent state. VCF Operations backup jobs should be scheduled to run on a daily basis. VCF Automation and VCF Identity Broker each support on-demand backups that should be taken before maintenance activities such as upgrades. VCF Operations for Networks supports backup and restore of deployment data to enable recovery when an existing setup is unrecoverable. VCF Operations administrators can take regular backups of custom and out-of-the-box content to address operational or regulatory needs.

Restore sequencing is documented for dependent management components. vCenter, VCF Operations, and VCF Operations fleet management must be available before proceeding with the restore of VCF Automation. Following these dependency chains is important for meeting recovery time targets, as restoring components out of order can introduce delays. VCF Operations supports export of dashboards, views, reports, alert definitions, and other configuration content, so operational tooling can be restored alongside the infrastructure.

If both the active and standby NSX Global Manager instances fail, documented recovery procedures must be initiated to restore network management functions. The platform recommends performing test recoveries to validate that recovery plans work as expected, which is a standard practice for verifying that recovery time targets can be met in an actual disruption.

Disaster recovery and workload mobility

Application Disaster Recovery enables failover to a secondary site to maintain operations during major disruptions. Application Disaster Recovery with data replication replicates data to a secondary site, providing recovery options in case of catastrophic failure. Once a planned migration or disaster recovery event completes, the recovered system becomes operational at the secondary location. Organizations must have in-place infrastructure for restore operations at the recovery site, meaning pre-provisioned capacity and network connectivity at an alternate location are prerequisites for this capability to function. Some data loss may occur during failover depending on the configured Recovery Point Objective (RPO). NSX supports disaster recovery deployments where a secondary site stands by to take over networking if a catastrophic failure occurs at the primary site.

VCF integrates with VMware Live Site Recovery, which provides the ability to create recovery plans on a designated recovery site. Recovery plans define the sequencing and automation of failover and failback operations for protected virtual machines, directly supporting the ability to resume workloads within target recovery times. The platform also supports delta synchronization with configurable recovery point objectives during planned migrations and failover scenarios.

VCF Operations HCX provides workload mobility for migrating VMs between sites. HCX uses the Mobility Agent service to perform vMotion, Cold, and Replication Assisted vMotion (RAV) migrations, with Mobility Groups that track workload migration states and support scheduled transfers and switchovers for bulk migration scenarios.

Business application modeling

VCF Operations provides constructs for modeling business-critical applications. Business Applications can be assigned environment types including DR, Development, Production, Staging, and Test, allowing administrators to define and monitor the health of applications that support essential missions. Operational policies in VCF Operations can be configured to reflect the priorities and alert tolerances specific to business-critical workloads, helping teams identify and respond to issues that affect essential functions.

Containerized workload recovery

VMware Kubernetes Service (VKS) and the vSphere Supervisor platform extend business continuity capabilities to containerized workloads through several built-in mechanisms.

Kubernetes Deployments and ReplicaSets continuously monitor pod health and automatically reschedule pods on available nodes when failures occur. A failed Deployment supports the same operational actions as a healthy one, including scaling, rollback to a prior revision, and pausing for incremental changes, which reduces the window of unavailability for containerized workloads. Kubernetes Deployment status can serve as an indicator that a rollout has become stuck, allowing administrators to detect and respond to stalled updates before they affect service availability. Deployment rollouts can be paused before applying multiple fixes and resumed once all changes are ready to be applied together, providing controlled update management.

For stateful workloads, vSAN Data Persistence workloads can be deployed across a multi-zone Supervisor to achieve cluster-level high availability. Applications configured with the appropriate storage class and zone topology can survive the loss of an availability zone while maintaining access to persistent data managed through PersistentVolumeClaims and PersistentVolumes. Before placing a datastore into maintenance mode, administrators should migrate active

PersistentVolumes to an alternate datastore to maintain workload access to data. When PersistentVolume issues are identified, remediation can be performed by reapplying the storage policy or migrating the volume to another datastore. Periodic snapshots of apiserver backing volumes are recommended to support recovery from backing storage loss events.

VKS cluster backup includes support for filesystem freeze hooks that complete pending disk I/O operations prior to backup, producing consistent snapshots of stateful workloads. Deployment rollback is available through Kubernetes revision history, allowing administrators to revert to a prior stable state when a software update causes instability. The Harness CI/CD service, available as a Supervisor Service, extends this capability with rollback strategies that can revert to a previous stable state when deployment failures are detected.

VCF provides the technical mechanisms for sustaining operational continuity, but the organization remains responsible for defining the contingency plan itself, setting recovery time and recovery point targets, testing recovery procedures regularly, training personnel, establishing communication protocols, and maintaining the operational processes that tie these platform capabilities together into a working continuity strategy.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to business continuity by designing the Security Services Platform (SSP) for operational resilience. SSP deployments use vSphere HA for host-level failure recovery, keeping security analytics and detection services available during host failures.

In 9.1, vDefend introduces Private Mode licensing, in which the system prioritizes service availability by bypassing license validity checks and expiration timelines. This keeps security services operational during license connectivity interruptions or administrative maintenance windows.

The Security Services Platform includes backup and restore capabilities for the platform configuration, tokens, Bare Metal servers, and Bare Metal server interfaces. Organizations should back up the SSP system before performing scale-out operations. Backup and restore operations require the platform to be in a healthy state; if internal services restart unexpectedly, the backup or restore operation may fail.

Broader continuity capabilities, including workload high availability, data replication, and RTO/RPO management for business applications, are outside vDefend's scope and require complementary platform and organizational controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical mechanisms for disaster recovery orchestration that help organizations continue essential missions and business functions during a site disaster and sustain operations at the recovery site until primary site restoration is possible.

During failover, PNR coordinates the recovery process through recovery plan execution. Disaster recovery failover continues without failing if an error occurs on the protected site during operations, allowing recovery to proceed even when the source environment is degraded. A cleanup operation must be successfully completed after testing a recovery plan before a failover or another test can be run, maintaining plan integrity and configuration consistency across recovery events. Recovery plans carry defined states including Cleanup Incomplete and Cleanup Interrupted; when errors arise during cleanup, PNR provides a Force Cleanup option that allows cleanup to be run multiple times until it completes, enabling administrators to restore plan readiness.

The VCF Operations orchestrator plug-in for Protection and Recovery provides automated workflows to start test, cleanup, failover, reprotect, planned migration, or cancel recovery plan operations, with an initial state check before execution. After a disaster recovery operation, a planned migration must be performed when both sites are running again, providing a structured path back to the primary processing site. Planned migration requires both the protected site and recovery site to be running and fully functioning.

In 9.1, PNR extends disaster recovery coverage to VCF Automation continuity: when a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that organization users can recover workloads. Organization Administrators in PNR for VCF Automation can perform all multi-

tenant disaster recovery operations that Project Administrators and Project Advanced Users are authorized to run, providing administrative continuity across a disaster event.

PNR dashboards in VCF Operations display alerts that inform administrators about configurations and deployments that need attention, supporting situational awareness during and after recovery operations.

Continuity of essential missions also requires organizational processes: decisions to invoke failover, configuration and regular testing of recovery plans, staffing of the recovery site, and management of the return to primary operations. PNR provides the technical orchestration layer for disaster recovery; the organizational process of activating and sustaining those mechanisms completes the full control requirement.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to continued essential mission and business function continuity through two layers of application-layer resilience: Service Engine high availability within a site and Global Server Load Balancing (GSLB) for multi-site continuity.

At the local site level, Avi Service Engines provide data plane resilience across multiple HA modes. In legacy HA active/standby mode, service continuity depends on initialized standby virtual services on the surviving Service Engine that are capable of assuming traffic with a single command. In elastic HA configurations, when a Service Engine fails, virtual service instances placed on other Service Engines continue to operate with reduced capacity until the Avi Controller restores full capacity. If a Service Engine on a failed host is not recovered by vSphere HA within a predetermined timeout, the Avi Controller resumes its own recovery processes. Service Engines on a failed host that have no operational virtual services transition to OPER_DOWN state, making degraded capacity visible to operators.

Avi GSLB addresses multi-site and disaster recovery scenarios. GSLB supports an active disaster recovery deployment mode that directs application traffic to alternative endpoints when a site experiences an outage. Global application services continue on surviving GSLB sites when a leader site fails, and sites that rejoin the federation assume the role of designated backup leader. Operators can enable maintenance mode on the GSLB leader Controller before performing planned maintenance or a manual leader change using the `gslb maintenancemode enabled` CLI command, which provides controlled failover. Maintenance mode must also be enabled on the GSLB leader Controller before starting a GSLB cluster upgrade to prevent issues. GSLB service configuration supports a manual resume option for controlled failover and recovery management. GSLB health monitors direct traffic to alternative endpoints during planned maintenance operations, enabling continuity without downtime.

Virtual service definitions should cover the full set of mission-critical applications at the primary location so that GSLB health monitors can accurately assess availability and direct traffic to alternative sites when needed.

Avi for VCF includes upgrade guidance specific to the integrated deployment: operators should plan a remediation strategy before re-attempting an upgrade after a rollback, and post-upgrade validation should confirm that no degraded or disconnected Service Engines remain before treating the upgrade as complete. Pre-upgrade assessment and communication of virtual service disruption is required before starting upgrade operations.

Application continuity through the Avi layer depends on the underlying compute, storage, and network resilience of VCF, including vSphere HA for Service Engine VM recovery and platform networking. Organizational BC/DR planning, documented recovery procedures, and recovery time objectives are required in addition to these technical mechanisms.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(a)(7)(ii)(D)

Implementation specifications: Testing and revision procedures (Addressable). Implement procedures for periodic testing and revision of contingency plans.

SCF Controls: BCD-04, BCD-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several infrastructure-level capabilities that support an organization's contingency plan testing and exercise program, though the planning, scheduling, execution, and evaluation of formal contingency tests remains an organizational responsibility.

VCF includes built-in recovery and high-availability mechanisms that organizations can exercise during contingency tests. vSAN stretched clusters can be exercised by simulating site failures through host maintenance mode operations, validating that the surviving availability zone continues storage and compute operations. A vSAN stretched cluster continues to function if a failure or scheduled maintenance occurs at one zone, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSphere HA can be tested by deliberately failing hosts to observe VM restart behavior and confirm that admission control policies reserve sufficient capacity. vSphere HA uses admission control so that a cluster has sufficient resources to support virtual machine recovery when a host fails.

VCF Operations HCX supports workload migrations between sites through Mobility Groups, allowing organizations to exercise mobility procedures and validate that workloads can be moved to alternate processing locations. Migration activity, progress, and history are tracked through the Migration Planning interface, providing visibility into the results of migration exercises.

Management component backup and restore procedures can be tested by performing restore operations for VCF Operations, VMware vCenter, and NSX components. VCF documents the prerequisites and sequencing for file-based restore of these components, allowing organizations to validate their recovery procedures against documented expectations. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated solutions that can be tested independently, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

VCF Operations includes a What-If Analysis capability under its capacity planning module that allows administrators to model hypothetical scenarios against current infrastructure. Administrators can create, save, and run scenarios cumulatively to evaluate the demand and supply for capacity on resources and assess potential risk to current capacity. This supports both Traditional and Hyperconverged deployment models. Scenarios can be committed as planning tools for capacity analysis, helping organizations with separate capacity management and operations teams understand current capacity and upcoming capacity requirements. These what-if scenarios can be used as part of contingency testing to model failover capacity needs, validate that sufficient resources exist to absorb relocated workloads, and verify that planned recovery configurations are viable before an actual event occurs.

To support the separation of test and production environments during contingency exercises, VCF Operations allows administrators to configure custom groups with differentiated alert thresholds and capacity calculations. This allows a test environment to operate under different operational policies than production, which is useful when conducting DR drills or failover exercises that temporarily shift workloads between sites or clusters.

VCF also provides built-in pre-check and validation capabilities that verify component connectivity, version compatibility, and component status among other environment readiness checks. These pre-checks run automatically during lifecycle operations such as upgrades and remediation, and they help confirm that the environment is in a known-good state before changes are applied. While these are not contingency plan tests in themselves, they contribute to readiness assessment by confirming that infrastructure components are healthy and correctly configured before and after contingency exercises.

Organizations deploying VCF should establish a formal contingency plan testing program that includes scheduled DR drills, failover exercises, backup restoration validation, and tabletop exercises. VCF's recovery mechanisms, what-if analysis, and

pre-check capabilities can inform and support these activities, but the test plan itself, its schedule, success criteria, scenario design, evaluation criteria, and after-action review process must be defined and managed by the organization.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides non-disruptive testing of disaster recovery plans as a core operational capability. Recovery plans organize protected workloads into sequenced, dependency-aware execution groups, and these plans can be tested without affecting production operations on either the protected or recovery site.

Testing a recovery plan in PNR validates that virtual machines recover correctly to the recovery site and exercises nearly every aspect of a recovery plan to validate disaster recovery readiness. Testing has no lasting effects on either the protected or recovery site, which means exercises can be repeated at any frequency without risk to production workloads. PNR requires that recovery plans be tested before use for planned migration or disaster recovery operations. Recovery plan tests can be canceled at any time; however, a successful cleanup operation must be completed before running a failover or initiating another test.

Recovery plan test execution is tracked through the Test task in Recent Tasks, which monitors overall progress of the test operation. Recovery plans support two types of custom steps: Test Steps that run during recovery plan testing, and Recovery Steps that run during planned migration or disaster recovery operations. The Configure Test Networks step in the recovery plan workflow supports using a separate test network at the recovery site to keep test VMs isolated from production network segments during testing.

Recovery plan testing can be automated through the VCF Operations orchestrator Plug-In for Protection and Recovery. The Initiate Test Recovery Plan workflow starts a test of a selected recovery plan and performs a state check to verify the recovery plan is in ready state before allowing test execution. The Initiate Cleanup Recovery Plan workflow cleans up a test when the recovery plan is in needsCleanup state.

The organizational elements of contingency plan testing, including exercise scheduling, scenario design, evaluation criteria, and after-action reviews, are outside PNR's scope. Recovery plan testing supports two distinct pre-production rehearsal modes: test recovery, which validates failover into an isolated environment without disrupting production, and planned migration, which performs an orderly, validated move of workloads. Tests can be used to verify that recovery time and recovery point objectives are met, and can be run unattended through the VCF Operations Orchestrator plug-in and the REST API for scheduled or scripted execution.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(7)(ii)(E)

Implementation specifications: Applications and data criticality analysis (Addressable). Assess the relative criticality of specific applications and data in support of other contingency plan components.

SCF Controls: AST-01, AST-01.1, BCD-02, TPM-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support the identification and documentation of critical technology assets, applications, services, and data within a virtualized infrastructure.

VMware vCenter maintains a real-time inventory of all managed objects, including hosts, VMs, clusters, datastores, and networks, and supports linking multiple vCenter instances for centralized inventory management. The vCenter inventory tracks multiple instances of ClusterComputeResource, ComputeResource, Datacenter, Datastore, DistributedVirtualSwitch, and Folder objects, providing a structured view of all infrastructure components. VCF Operations can export lists of resources, such as powered-off virtual machines, to CSV files for offline documentation and review.

VCF Operations includes a Business Applications feature that allows administrators to group related infrastructure objects and assign business criticality classifications. Each Business Application can be tagged with a criticality level of Critical, Medium, or Low, with Medium as the default. The Object Summary card within VCF Operations displays details including the application's source, application tag, environment, and business criticality rating. This classification capability allows infrastructure teams to maintain a structured view of which applications and their underlying resources are most important to the organization.

VCF Operations Service Discovery automatically detects running services across the environment. Service Discovery displays a list of all supported services that can be discovered and those currently discovered on VMs once configured. It also discovers performance metrics for individual service objects and service type objects, maintaining a catalog of known services and their relationships to underlying infrastructure. This automated discovery reduces manual effort in maintaining an accurate asset inventory.

VCF Operations also provides alert definitions with configurable Impact and Criticality metadata. The Impact setting can be configured to values such as Risk to indicate potential problems, while the Criticality setting can be set to values like Immediate for proper alert prioritization. Alert notifications can be filtered by impact category and criticality level, helping teams classify infrastructure resources by their importance and focus attention on the most important infrastructure components. VCF Operations Insights data tracks resource capacity and can notify project owners of changes affecting their assets.

VCF Automation provides complementary asset identification capabilities through its resource discovery and tagging system. The discovery process automatically identifies machines, storage volumes, networks, load balancers, and security groups for each cloud account region that has been added. Once discovered, these resources can be organized using tags that facilitate search and identification. Tags placed on cloud zones, network profiles, storage profiles, and individual infrastructure resources function as capability tags that define desired capabilities and support governance by expressing capabilities and constraints. Using logical, human-readable tags for storage, network, and infrastructure items is recommended to facilitate search and identification functions.

VCF Automation organizes infrastructure through projects, which link users, catalog items, and IaaS resources to the locations where items are deployed. The Overview tab displays infrastructure and consumption metrics, providing a consolidated view of resource usage. Resource details views support filtering based on attributes such as project membership, enabling administrators to locate and review specific subsets of the infrastructure.

Blueprints in VCF Automation allow users to model complex IT services by visually designing infrastructure components such as VMs, networks, storage, and software components. Resource objects in blueprints represent the infrastructure components and services that are provisioned and managed, providing an architectural record of how assets support business functions.

Together, these inventory, discovery, classification, tagging, and visualization capabilities give operations teams the tools to identify, classify, and document the technology assets that support essential business functions. However, VCF provides the technical tooling for asset identification and classification rather than the organizational processes needed to define which assets are critical to the business mission. Establishing criticality criteria, maintaining asset documentation, and conducting periodic reviews of critical asset designations require organizational processes that operate alongside the platform's capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to identifying and documenting critical technology assets through the Security Services Platform (SSP) and its Security Intelligence feature, which provide asset inventory, classification, and visualization capabilities oriented toward network security segmentation planning.

Security Services Platform maintains a Platform Inventory of infrastructure assets, collecting status information for each asset including identification of assets that are timed out or out of sync. The inventory view provides filtering by Name and Status to locate specific infrastructure assets and identify their operational state. Tags assigned to each infrastructure asset are displayed for verification of tag assignments.

Security Intelligence gathers infrastructure services and servers from CSV files and discovers additional services and servers based on traffic flows analyzed from ESX hosts. During CSV import, Security Intelligence parses and validates the content format and inventory asset data. Security Intelligence also maps discovered unique assets during segmentation analysis, including workloads, groups, IP addresses, distributed virtual port groups (DVPGs), segments, tiers, infrastructure services, and infrastructure servers.

Security Services Platform identifies and publishes application assets, classifying them as either critical or regular applications. This criticality classification supports the identification of mission-critical technology assets within the environment. The inventory hierarchy spans regions, zones, environments, applications, and tiers, with each level displaying the total number of assets within its scope.

Security Intelligence organizes discovered and imported assets into structured Asset Collections: groups, infrastructure assets, environments (such as Production, Non-Prod, DMZ, PCI, and Development), applications, and application tiers. The Environment Asset Collection maps security zones to the operational contexts that support business functions. Application Asset Collections group workloads that provide enterprise functionalities, linking infrastructure resources to the business services they support. The Infrastructure Asset Collection node covers core networking services that enterprise workloads depend on, including LDAP, DNS, NTP, and DHCP. An Unknown Asset Collection surfaces compute entities that are not in the NSX inventory but are present in the data center and communicating to NSX entities, supporting discovery of assets that should be formally inventoried.

Security Intelligence Workload Classification can be set to "Infrastructure Service" to indicate that a compute entity provides infrastructure services such as DNS, DHCP, LDAP, and Syslog. Inferred infrastructure classifications for compute entities can be reviewed, accepted, or modified through the Monitor & Plan > Security Explorer interface.

These capabilities contribute to the control but do not fully satisfy it. vDefend's asset identification is scoped to network security segmentation planning rather than the enterprise-wide technology asset catalog this control requires. Identifying all critical technology assets, applications, services, and data across an organization requires broader inventory and configuration management capabilities within VCF, such as VCF Operations business application views, VMware vCenter inventory exports, and VCF Automation project tagging, which provide the enterprise-wide asset catalog that vDefend's security-focused inventory complements.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) organizes its protection model around identifying which assets are critical enough to warrant disaster recovery protection. Protection groups are an explicit declaration of critical assets, organizing virtual machines into logical units based on their replication and recovery requirements. Placing a workload in a protection group is a deliberate act of classifying it as essential to business operations.

Inventory mappings document how each protected-site asset (resource pools, folders, networks, datastores) corresponds to recovery-site resources, creating a structured record of the infrastructure that supports critical workloads. Site-wide inventory mappings apply defaults across all protected VMs, while per-VM customizations document specific recovery configurations for workloads with unique requirements.

The Protection and Recovery Configuration Import/Export Tool exports a complete record of the DR asset inventory, including site names, inventory mappings, placeholder datastores, advanced settings, array managers with SRA information, protection groups, and recovery plans. This export provides a structured, portable document of which assets are protected and how they are configured for recovery. The export is produced in XML format, enabling automated processing and retention as a configuration record.

PNR generates and exports reports documenting each run of a recovery plan, each test of a recovery plan, and each test cleanup operation. These reports provide an auditable record of which recovery plans executed and which protected workloads were involved.

PNR tracks site metrics including paired sites, pair names, vCenter addresses, site connectivity status, and counts of protection groups, recovery plans, protected virtual machines, and array managers. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, providing consolidated visibility into the DR infrastructure as a class of managed assets.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(a)(8)

Standard: Evaluation. Perform a periodic technical and nontechnical evaluation, based initially upon the standards implemented under this rule and, subsequently, in response to environmental or operational changes affecting the security of electronic protected health information, that establishes the extent to which a covered entity's or business associate's security policies and procedures meet the requirements of this subpart.

SCF Controls: CPL-03.2, IAO-01.1, IAO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.308(b)(1)

Business associate contracts and other arrangements. A covered entity may permit a business associate to create, receive, maintain, or transmit electronic protected health information on the covered entity's behalf only if the covered entity obtains satisfactory assurances, in accordance with § 164.314(a), that the business associate will appropriately safeguard the information. A covered entity is not required to obtain such satisfactory assurances from a business associate that is a subcontractor.

SCF Controls: TPM-01, TPM-04, TPM-05, TPM-05.2, TPM-05.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of access control, identity federation, tenant isolation, and monitoring to mitigate risks associated with third-party access to infrastructure assets, applications, services, and data.

VCF SSO integrates with federated identity providers through standards-based protocols, supporting SAML 2.0, OIDC, and AD/LDAP as authentication sources. LDAP-based directory services such as Active Directory are supported for identity management across the platform, including NSX Manager, which supports both Active Directory over LDAP and Open LDAP as identity sources. This allows organizations to extend their existing identity governance to VCF rather than maintaining separate credential stores for third-party users.

Role-based access control enforces least-privilege principles across the platform. VCF local accounts support configurable roles such as superAdmin, and VCF Automation assigns host switch-level permissions through the Cloud Administrator group (Cloudadmin role). The administrators role in VCF Operations is restricted to specific users who need access to objects and actions across the entire environment. For Kubernetes workloads, vSphere Supervisor namespaces support role-based access control with EDIT, VIEW, and OWNER roles that grant specific privileges to users or groups. The Namespace Owner/Edit/View role scopes consumers of a vSphere Namespace to provisioning VKS clusters and vSphere Pods using kubectl, while vSphere Administrator and Supervisor Administrator roles have broader access to cluster and namespace resources. This layered role model restricts third-party access to specific workload boundaries.

VCF Automation implements a provider-and-consumer model that separates the operators of services from the organizations that consume them. Partner services from external vendors are integrated through this model, where providers manage services and organizations consume the resulting business outcomes such as self-service provisioning of Kubernetes clusters, databases, and other resources. Service providers control the publication scope of service instances to selected organizations and decide which roles, rights bundles, and UI plug-ins to include when publishing services. Provider Consumption Organizations offer additional administrative capabilities on top of standard organizations, allowing provider administrators to provision workloads while maintaining separation from consumer tenants. This architectural separation limits third-party visibility and access to only the resources they need to operate.

For third-party application integration, VCF Automation supports dedicated service accounts that automate access for third-party applications. Organizations can generate and issue API access tokens that applications use on their behalf, providing a controlled mechanism for programmatic access rather than requiring shared user credentials. The VCF Operations orchestrator presents an open architecture for plugging in external third-party applications, with integration points managed through the platform rather than through direct infrastructure access.

Tenant isolation is enforced through VCF Automation Organizations, which provide secure infrastructure isolation, quotas, and chargeback across multiple tenants. Within each organization, further isolation exists at the project and namespace levels. IT teams and cloud service providers can monitor resource usage, control permissions, and provide managed services through these organizations while network isolation at the NSX segment level restricts lateral movement between tenants. An Enterprise Admin can share resources with projects in a controlled manner, making objects available for consumption only within designated boundaries. App isolation policies in VCF Automation allow deployments that require on-demand security

groups to enforce vDefend firewall rules at the application level. Data-in-transit communications default to TLS encryption for platform services.

VCF Operations monitors resource usage and policy compliance across the environment, providing visibility into third-party activity. VCF Operations supports firewall hardening that restricts network access to internal services, limiting the network paths available to third-party integrations. Service Discovery identifies permanent listening TCP ports and established UDP connections, and service discovery dashboards provide ongoing visibility into the services operating in the environment. VCF also provides capabilities to discover objects that are not compliant with a security standard, supporting ongoing risk identification for configurations affected by third-party access.

VMware Private AI Services (PAIS) provides technical mechanisms that contribute to mitigating risks associated with third-party access to AI-related assets, services, and data. These mechanisms operate at the trust validation, authentication, authorization, and content approval layers.

Trust Establishment for External Integrations

PAIS uses a CA trust bundle to establish secure HTTPS communication with external services and databases. Administrators must import CA trust bundles for the OIDC provider, Private Harbor registry, content management systems used as data sources in Data Indexing and Retrieval, MCP servers providing tools for agents, and the database server when those entities are not supplied at activation. Without an explicitly configured CA trust bundle, PAIS will not establish connections to those services, so third-party integrations require deliberate administrative action rather than automatic open access. PAIS supports updating certificate content for trusted entities through the same trust bundle mechanism, allowing administrators to refresh trust material as provider certificates change.

Access Control for Services and Data

PAIS access is controlled through OIDC group-based authorization. User accounts must be members of specified authorized groups (configured via the `authorizedGroups` setting) to access the service, and the `oidc-groups-claim` setting controls which OIDC claim is consulted for group identification in the organization namespace. PAIS requires HTTPS-based communication for OIDC provider integration. SharePoint data sources used as Knowledge Base inputs require user name and password authentication, with support limited to SharePoint On-Premises deployments, so the credential and connectivity posture for that integration is explicit rather than implicit.

Harbor Access and Model Storage

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. These controls help administrators scope which users and workloads can push to or pull from a registry used by PAIS.

Model Validation Before Deployment

Before uploading a model to a PAIS Model Gallery, the platform recommends evaluating the model's performance and safety for the intended business use case, including examining inference requests for malicious behavior and performing hands-on functional tests. PAIS guidance directs administrators to distribute models within the organization that have been validated on a Deep Learning VM rather than models pulled from the Internet, which could contain malicious code or be tuned for malicious behavior. This workflow helps administrators verify third-party or externally sourced models before they become available for production use.

VMware vDefend (Contributes)

VMware vDefend contributes to mitigating risks from third-party access to organizational technology assets, applications, services, and data through network-level access controls, threat detection, and security posture reporting. Identity governance, authentication, and administrative access controls are handled by other VCF components (VMware vCenter, VCF SSO). vDefend enforces the network security boundary that constrains what third parties can reach once they have been granted access.

vDefend enforces microsegmentation policies at the vNIC level, allowing administrators to define granular network access rules that restrict third-party workloads or connections to only the specific application tiers and services they require. Context-aware rules allow policies to incorporate workload-level attributes, limiting the network reach of third-party connections to defined sets of addresses, ports, and protocols. In multi-tenant VCF environments, the VPC Isolation with Essential Services strategy allows enterprise administrators to enforce strict inter-project isolation at the Distributed Firewall level while delegating more granular control to application owners within each project. This architecture is suited to environments where third-party development teams or external service providers operate within shared infrastructure, because Distributed Firewall policy at the project boundary can be set independently of what individual tenants configure inside their own VPCs.

vDefend provides north-south traffic filtering at the perimeter of logical network segments. Enterprise administrators can enforce isolation between projects by denying inter-project communication except for specified infrastructure protocols, adding an enforcement point for controlling inbound and outbound access from external or third-party networks. This policy layer applies regardless of what routing exists at the NSX level, giving security teams a dedicated control plane for third-party network boundaries.

vDefend IDS/IPS monitors east-west and north-south traffic for malicious activity, detecting exploitation attempts that may arise from compromised third-party connections. Signature rules support storing TLS and SSL certificates on disk for forensic analysis and threat investigation. Custom signature sources, including those derived from cybersecurity advisories, can be deployed to address threats specific to proprietary or custom applications that third parties introduce into the environment.

Security Services Platform Security Segmentation capabilities identify risky application protocols, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP, in use across the environment. This flags workloads, including those operated by third parties, that transport data without encryption, and allows administrators to restrict or block them as part of the security baseline. The Security Segmentation Report identifies at-risk workloads across categories including Public Traffic, Obsolete OS, Risky Application Protocols, and Inter VDI Server Connections, providing a structured view of workload-level risk that is directly relevant to understanding the exposure introduced by third-party access. Application monitoring in Security Services Platform surfaces security risks identified across workloads, allowing administrators to take targeted remediation steps against risky or non-compliant third-party workloads.

Security Services Platform certificate management supports importing CA bundles and web proxy certificates to establish trust for external service connections, including those used by the Malware Prevention Service. This controls which external services the platform can reach and provides a configuration point for managing trust relationships with third-party service endpoints.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(b)(2)

A business associate may permit a business associate that is a subcontractor to create, receive, maintain, or transmit electronic protected health information on its behalf only if the business associate obtains satisfactory assurances, in accordance with § 164.314(a), that the subcontractor will appropriately safeguard the information.

SCF Controls: TPM-05, TPM-05.2, TPM-05.6

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.308(b)(3)

Implementation specifications: Written contract or other arrangement (Required). Document the satisfactory assurances required by paragraph (b)(1) or (b)(2) of this section through a written contract or other arrangement with the business associate that meets the applicable requirements of § 164.314(a).

SCF Controls: IAO-03.2, TPM-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered set of technical controls for protecting sensitive and regulated data across its storage, compute, networking, and automation subsystems. While the organizational aspects of contract-driven data protection, including data classification schemes, contractual obligations, and data handling agreements, fall outside VCF's scope, the platform supplies encryption, access control, and monitoring capabilities that enforce those organizational policies at the infrastructure layer.

VCF addresses data-at-rest protection through multiple mechanisms. vSAN data-at-rest encryption protects data on storage devices in the event a device is removed from the cluster, and encryption is applied to all data added to the vSAN datastore when enabled. Virtual machines on a vSAN datastore can be assigned a storage policy that defines data protection characteristics, and the platform monitors ongoing compliance of volumes against these policies. At the VM level, vSphere virtual machine encryption protects VM files containing sensitive information, including NVRAM, swap, snapshot, and virtual disk files. vSphere Native Key Provider enables encryption technologies such as virtual TPMs (vTPM) without requiring an external key management server, and vSAN also supports vSphere Native Key Provider for encrypting virtual machines in vSAN clusters. VMware vCenter provides an extensive set of Cryptographic Operations privileges that allow fine-grained control over who can perform encryption tasks, including the ability to create and update encryption-related storage policies through the PBM Profile Manager API. Organizations can also configure separate key providers for different departments or organizational units, enabling more granular access control over encryption keys when multiple groups share the same VCF environment.

For data in transit, vSAN data-in-transit encryption uses AES-256 bit encryption for all data and metadata traffic between VMware ESX hosts in the cluster. Data-in-transit and data-at-rest encryption can be enabled or disabled independently. Management plane API communications also use TLS encryption; for example, basic authentication for the JSON protocol transports credentials over HTTPS with TLS encryption, NSX Manager API service supports TLS, and the VCF Operations API establishes connections using SSL. vSphere also supports encrypting Fault Tolerance log traffic, which replicates VM memory state between hosts and may contain sensitive application data from running workloads.

The VCF Automation subsystem includes several mechanisms for handling sensitive data during provisioning and ongoing operations. VCF Automation encrypts sensitive data such as passwords in cloud configuration scripts using a secret versioning scheme, and its APIs support encryption for sensitive data in image profiles, projects, and provisioned entities. Administrators can explicitly designate values for encryption during machine provisioning using a dedicated sensitive data marking syntax, and such data is encrypted by default in responses. VCF Automation for VM Apps extends this with a secrets capability that encrypts input values for extensibility actions, which is useful for managing passwords, certificates, and other credentials programmatically.

VCF Operations provides additional controls for sensitive information management. Sensitive information can be stored in VCF Operations orchestrator configuration elements or in external password vaults, keeping credentials and secrets out of plain text. The orchestrator signs and encrypts packages for data protection during distribution. Sensitive information within HTTP-REST plug-in objects is scoped internally and intended for use only in scenarios involving those objects, limiting exposure. Role-based access control in VCF Operations allows administrators to assign specific permissions to user accounts, restricting access to views and objects so that users without appropriate privileges cannot view collected data.

The platform also provides guidance and safeguards around data exposure risks. Data sets in vSphere should not contain sensitive data such as passwords or private keys in plain text. Administrators should be aware that vSAN support bundle data may contain sensitive information, including personal, health care, or financial data, and that uploading support bundles may expose regulated data. Core files and audit logs from NSX can also contain sensitive information such as passwords or encryption keys, which should be factored into log handling and retention procedures.

The VCF Security Baseline document builds on VCF's security fundamentals to address frequently requested compliance standards, regulations, and frameworks, providing a reference for organizations that need to align their VCF deployments with contractual security requirements.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to protecting sensitive and regulated data in support of contracts by enabling microsegmentation through the Distributed Firewall (DFW), which enforces least-privilege network access controls around workloads that collect, process, transmit, or store contract data. In 9.1, privileged labels provide a tamper-proof mechanism for anchoring firewall rules to immutable labels, preventing virtual machines from leaking out of security groups and maintaining the integrity of network isolation boundaries around protected workloads.

DFW packet logs capture rule set, rule ID, direction, protocol, and source and destination addresses and ports, providing an audit trail for traffic flows around workloads handling contract data. The Gateway Firewall extends this protection to north-south traffic flows.

Security Services Platform (SSP) supports a structured approach to coverage: the Application Inventory prioritizes securing critical applications before regular ones, and Security Policies gives operators visibility into protected and unprotected network flows with drill-down into individual flow details. The Security Segmentation report breaks down unique traffic flows by protection status and workload type, allowing operators to verify that workloads handling contract data are fully covered by policy.

VMware vDefend can identify and control risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP, supporting detection and restriction of unencrypted data paths. Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to the cloud, and SSP stores collected data using encryption at rest.

Data governance obligations, including contractual data handling requirements, access agreements, and regulatory compliance documentation, remain organizational responsibilities outside vDefend's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer mechanisms relevant to protecting sensitive and regulated data in transit at the application delivery tier.

For data in transit, each virtual service that handles encrypted connections is configured with an SSL/TLS profile that specifies the accepted cipher suites and protocol versions. These profiles are configurable per virtual service, allowing organizations to enforce strong cryptographic standards on connections carrying sensitive or regulated data. The System-Secure-HTTP application profile provides an additional layer of protection by enforcing HTTPS, protecting cookies, managing client IP handling, and controlling protocol behavior for HTTP virtual services.

TLS session persistence state is stored in encrypted form at the Service Engine so that session data is not exposed when a client reconnects to a different Service Engine. Communication between Avi Controllers and Service Engines uses encrypted channels.

Avi's Analytics Profile includes a sensitive log profile capability that controls how sensitive data appearing in client requests is handled in application logs. Operators configure this setting to suppress or mask fields that may contain regulated information, reducing the risk of sensitive data being written to log storage in cleartext.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) supports PKIProfile resources that enable certificate-based authentication and encryption for communication with backend services. The RouteBackendExtension custom resource

definition provides backend TLS configuration capability, supporting encryption of traffic between Service Engines and backend servers. The System-Standard SSL Profile can be applied through AKO to enable SSL/TLS re-encryption for backend traffic using modern cipher suites.

The Avi Cloud Console Application Rules service allows organizations to protect applications from known vulnerabilities by enabling managed application security rules on their Avi Controllers.

Fully satisfying this control also requires an organizational data classification program that identifies which data is sensitive or regulated under applicable contracts, maps that data to the application flows handled by Avi virtual services, and verifies that Avi's encryption and logging controls are applied to those flows. Avi provides the technical mechanisms; the organizational program determines how and where they are applied.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(a)(1)

Standard: Facility access controls. Implement policies and procedures to limit physical access to its electronic information systems and the facility or facilities in which they are housed, while ensuring that properly authorized access is allowed.

SCF Controls: GOV-02, PES-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(a)(2)(i)

Implementation specifications: Contingency operations (Addressable). Establish (and implement as needed) procedures that allow facility access in support of restoration of lost data under the disaster recovery plan and emergency mode operations plan in the event of an emergency.

SCF Controls: BCD-09.2, HRS-03, PES-02, PES-02.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support alternate processing site accessibility planning, though the organizational processes of identifying physical site risks, selecting alternate locations, and developing mitigation plans remain outside the platform's scope.

VCF includes application disaster recovery functionality that enables failover to a secondary site to maintain operations during major disruptions. This capability allows workloads to be redirected to an alternate processing location when the primary site becomes unavailable due to an area-wide event. The platform recommends combining real-time high availability with sitewide disaster recovery for maximum resilience, which directly supports maintaining access to alternate processing resources during extended outages. Disaster recovery may also be implemented for fleet-level components, extending protection beyond individual workloads to the management infrastructure itself. For large clusters, VCF documentation recommends having a disaster recovery plan in place, as an unexpected cluster-wide outage can impact many virtual machines simultaneously.

For environments requiring continuous availability across geographically separated locations, vSAN stretched clusters provide site-level disaster tolerance. A vSAN stretched cluster consists of two data sites and a witness host, with ESX hosts distributed evenly between sites. Each site resides in a separate fault domain, and the site disaster tolerance storage policy rule can be set to site mirroring so that data remains accessible even when one entire site fails. Stretched clusters require independent routing and connectivity between the data sites and the witness host. When a site goes down or loses network connectivity, the surviving site can continue to serve workloads and perform component repairs locally. If one site goes down due to maintenance or failure and the witness host also fails, objects become non-compliant but remain accessible at the surviving site, preserving workload availability during partial failures. Administrators should be aware that selecting the "Ensure accessibility" evacuation mode does not reprotect data during failure, and unexpected data loss may occur under certain conditions. vSAN monitors connectivity between sites and provides monitoring capabilities that allow administrators to examine cluster performance and virtual machine accessibility to diagnose problems. This visibility into object accessibility status helps identify when workloads may be at risk and supports proactive mitigation before a full site failure occurs.

VCF supports distributing compute resources across different fault domains, which helps manage workload placement during site failure. This fault domain architecture allows administrators to map infrastructure to physical locations, making the relationship between compute resources and site accessibility visible and manageable.

NSX supports multisite networking deployments where a secondary site stands by to take over if a catastrophic failure occurs at the primary site. NSX Federation allows stretched tier-0 and tier-1 gateways to be moved between sites using a network recovery workflow, maintaining network connectivity for recovered workloads. This networking layer is important for alternate site accessibility because workloads recovered at a secondary site need functioning network paths to remain reachable.

VCF Operations HCX provides workload mobility capabilities, supporting migrations between sites through Mobility Groups. The Migration interface allows administrators to select sets of virtual machines, configure transfer and placement, and monitor migration progress and history. This supports planned migrations to alternate processing sites and can assist with workload redistribution during disruption scenarios.

VCF Operations offers what-if analysis that can model workload planning scenarios for capacity changes, including traditional and hyperconverged deployments. By committing a scenario, administrators can determine capacity requirements before implementing actual changes. Saved scenarios can be edited and run again cumulatively, providing an iterative planning

capability. This helps identify potential accessibility problems at recovery sites before a disruption occurs, such as whether the alternate site has sufficient compute, memory, and storage resources to absorb relocated workloads.

VCF provides monitoring, multi-site architecture, workload mobility, and capacity planning tools that collectively help identify and mitigate accessibility problems at alternate processing sites. However, the organizational activities of site risk assessment, alternate site selection, physical accessibility evaluation, and mitigation plan development require processes and decision-making that fall outside VCF's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides mechanisms that help identify and mitigate accessibility problems at the alternate processing site before and during area-wide disruptions.

PNR supports recovery plan execution under both planned and unplanned circumstances. Planned migration exercises let organizations validate that the recovery site is accessible and replication infrastructure is functioning before an actual disruption occurs. Recovery plans can be configured with different steps for emergency scenarios versus planned migration of services from one site to another, allowing administrators to account for the distinct operational conditions of each. When the protected site goes offline unexpectedly during disaster recovery operations, failures on the protected site are reported but otherwise ignored, allowing recovery to proceed without requiring both sites to be simultaneously available. PNR documentation also acknowledges that connectivity between sites can be lost, preventing status determination; administrators should account for this when designing recovery procedures.

PNR's multi-region topology design addresses area-wide disruption containment. Deploying with separate management domains for each region is designed to contain the impact of a disaster event to one particular region. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so users can recover workloads. This cross-domain recovery capability extends accessibility mitigation beyond individual site failover.

The recovery site must have hardware, network, and storage resources capable of supporting the same virtual machines and workloads as the protected site. PNR documentation states that recovery sites should be located in a facility unlikely to be affected by environmental, infrastructure, or other disturbances that affect the protected site, directly addressing area-wide disruption scenarios. In shared recovery site configurations, users with appropriate permissions must be able to access the site to create, test, and run recovery plans. Advanced configuration options let administrators customize PNR to support a broader range of site recovery requirements beyond the default configuration.

Broader accessibility planning, including physical network path redundancy, physical site selection, and capacity modeling for large-scale disruption scenarios, is provided by the underlying VCF platform or remains an organizational planning responsibility.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(a)(2)(ii)

Implementation specifications: Facility security plan (Addressable). Implement policies and procedures to safeguard the facility and the equipment therein from unauthorized physical access, tampering, and theft.

SCF Controls: GOV-02, PES-01, PES-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(a)(2)(iii)

Implementation specifications: Access control and validation procedures (Addressable). Implement procedures to control and validate a person's access to facilities based on their role or function, including visitor control, and control of access to software programs for testing and revision.

SCF Controls: IAC-01, PES-02, PES-03, PES-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcidentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID

Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given

database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.310(a)(2)(iv)

Implementation specifications: Maintenance records (Addressable). Implement policies and procedures to document repairs and modifications to the physical components of a facility which are related to security (for example, hardware, walls, doors, and locks).

SCF Controls: GOV-02, MNT-01, MNT-02, PES-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated lifecycle management capabilities for conducting controlled maintenance activities across the full infrastructure stack, spanning host servicing, component updates, and operational monitoring.

VCF Operations includes a maintenance mode capability that allows administrators to place managed objects into maintenance mode either manually or on a defined schedule. Manual maintenance mode can be applied indefinitely or for a specified duration in minutes, and it can be started or stopped independently of any assigned recurring schedule. For recurring maintenance windows, administrators can create maintenance schedules that place objects in maintenance mode at fixed intervals, such as from midnight until 3:00 a.m. on a specific night each week. These schedules are configured per policy through the Policy Definition interface in VCF Operations. When objects are in maintenance mode on schedule, VCF Operations suppresses alerts and status indicators for those objects, preventing misleading data that would otherwise result from objects being offline or in an unusual state during planned maintenance.

VCF Operations also supports automation of maintenance tasks through Automation Central, which allows administrators to create jobs that schedule actions to run automatically. Jobs can be configured with daily, weekly, or monthly recurrence and set to end after a specific date or number of occurrences. The VCF Operations orchestrator further supports scheduling of workflow runs at specified dates, times, and intervals. These capabilities allow maintenance tasks to run during defined windows without manual supervision.

Lifecycle management in VCF provides tools for planning and executing updates across the software stack. Starting with VCF 9, component lifecycle management is performed through the VCF Operations UI, which centralizes update and patch deployment for all VCF components. Administrators can schedule maintenance windows and coordinate changes to reduce disruption to services. Configuration updates are required to be performed during a maintenance window. VCF lifecycle management automates the process of applying updates and patches to software components within the stack, and it manages version compatibility across VCF components to maintain stability during and after updates.

VCF delivers maintenance releases as scheduled, cumulative updates focused on platform stability and support. These releases are synchronized among VCF components through a new Bill of Materials, which coordinates versioning across the stack so that components remain compatible after each update cycle. Patch releases, by contrast, are not synchronized among all components and do not require a new Bill of Materials.

For workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, the platform provides structured lifecycle management procedures at both the cluster and workload levels. Cluster-level lifecycle operations are performed through the Cluster API resource, which manages provisioning, scaling, and upgrades of VKS clusters. Node maintenance follows a defined sequence: operators cordon a node to prevent new workload scheduling, then drain it using `kubectl drain` to safely evict running pods before performing maintenance. Maintenance should not begin until the drain command completes, and operators should select worker nodes rather than control plane nodes when performing tasks such as checking for updates, preserving control-plane stability during the maintenance window. On shared clusters, operators should verify that cordoning and draining a node will not adversely affect other tenants before executing the operation.

For application updates within VKS clusters, Kubernetes rolling update strategies on Deployments, DaemonSets, and StatefulSets allow workloads to be updated with maintained availability. The `kubectl rollout` command manages the rollout lifecycle, supporting pausing, resuming, and rolling back changes. StatefulSet controllers use `ControllerRevision` objects to track historical configuration changes and maintain a revision history that enables rollback when updates need to be reversed.

StatefulSet pods retain their identity and persistent storage when rescheduled to available nodes during maintenance, allowing stateful applications to survive node maintenance events without losing state. The DaemonSetUpdateSurge feature gate enables DaemonSet workloads to maintain per-node availability during updates. Declarative object management using kubectl apply with version-controlled configuration files provides a controlled change mechanism that supports tracking what changed and restoring prior state if needed.

Kubernetes Operators running on Supervisor extend these capabilities by automating lifecycle procedures for stateful applications, including snapshot creation, StatefulSet and volume management, backup scheduling, and version upgrade orchestration. Operators allow complex, application-specific lifecycle procedures to be codified and applied consistently across environments. The Kubernetes TTL controller automatically removes finished Jobs based on configurable time-to-live settings, supporting lifecycle hygiene for batch workloads without manual intervention. Finalizers provide an additional mechanism for controlling the lifecycle and cleanup of resources owned by deleted objects.

The VCF Automation self-service catalog allows consumers to deploy IT resources and independently manage workloads through day-2 actions including updates and patches. Catalog items are scoped to projects, and lifecycle and day-2 actions for custom resources in a deployment must be shared with all relevant projects to support continued management after a deployment moves between projects. VCF building-block services have independent lifecycles, enabling individual components to be updated or maintained without requiring a complete platform maintenance window.

For backup data lifecycle maintenance, Velero on VKS clusters includes a configurable maintenance job system through the backupRepository.maintenanceJobConfig setting, which supports both global configuration and per-backup-repository maintenance job configuration. The fullMaintenanceInterval defaults to normalGC, and resource limits for maintenance job pods are tunable.

Supervisor system components, including the vmware-system-tkg controller manager, state metrics, and webhook components, are deployed across multiple replicas for high availability. This design allows component-level updates to proceed without requiring a complete platform maintenance window. Cluster health visibility is available through Kubernetes cluster conditions, including a Remediating condition that surfaces details about ongoing remediation of controlled machines. Readiness probes run throughout a container's lifecycle and allow the platform to detect and respond to recovery from temporary faults during or after maintenance events.

For host-level maintenance, VMware ESX hosts support a formal maintenance mode with dedicated API methods (EnterMaintenanceMode_Task and ExitMaintenanceMode_Task) that allow hosts to be taken offline for servicing in a controlled manner. Maintenance mode can also be managed through the ESXCLI interface. Administrators can verify whether a host is in maintenance mode using `esxcli --server=<server_name> system maintenanceMode get`, and access to maintenance mode operations is governed by the `Host.Config.Maintenance` privilege, which controls the ability to place a host in and out of maintenance mode and to shut down and restart the host. When remediating hosts through Update Manager, administrators can configure maintenance mode settings to control how hosts enter and exit maintenance mode during patching operations. For vSAN clusters, placing a host in maintenance mode requires selecting a data evacuation mode, such as Ensure accessibility, Full data migration, or No data migration.

At the network layer, routine maintenance tasks for NSX Manager appliances include running backups, adding licenses and certificates, and changing passwords, providing a defined set of maintenance activities for the networking infrastructure.

VMware vDefend (Contributes)

VMware vDefend provides lifecycle management and operational visibility capabilities through its Security Services Platform (SSP) that support controlled maintenance activities for the vDefend security infrastructure.

SSP's Platform Inventory Monitor gives administrators status visibility across environments, regions, zones, and virtual machines, identifying assets in success, timeout, or out-of-sync states. Filtering by name and status allows administrators to assess operational health before and after maintenance activities. The View details of external rollouts option in SSP displays progress details for Refresh operations covering Bare Metal servers, NDR Sensors, and Service VMs at both the individual and overall feature status levels, providing granular visibility into rollout state.

SSP enforces sequencing constraints on maintenance operations: Bare Metal Service operations such as onboarding, offboarding, and upgrading Bare Metal servers should not be performed while a backup or restore is in progress. After restoring a backup in either a disaster recovery or in-place scenario, agent health status must be confirmed as Up on Bare Metal servers before proceeding. The vDefend CLI provides a command to display the health of all services and agents running on a Bare Metal server, giving administrators a mechanism to verify service state before and after servicing. SSP also includes Depot and Registry services that run as systemd-managed services and can be restarted and monitored via systemctl commands.

SSP proactively manages its Platform CA certificate lifecycle. The certificate manager and security intelligence services within SSP can be queried for operational status to diagnose service availability issues during and after maintenance events.

NDR Sensor management operations, including activating or deactivating features and offboarding sensors, are restricted to the Enterprise Admin or Security Engineer role, limiting who can execute maintenance actions on detection infrastructure. Tokens, Bare Metal servers, and Bare Metal server interfaces are included in the full inventory backup, supporting recovery after maintenance activities.

When using vDefend Intelligent Assist or Network Detection and Response remediation workflows, objects that encounter errors during remediation require manual cleanup, which is a constraint administrators should account for in maintenance planning.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports controlled maintenance through two configurable policy mechanisms: a maintenance policy for the DSM plug-in software itself, and per-database maintenance windows for database engine upgrades.

For plug-in software updates, administrators configure a maintenance policy that specifies a start date, start time (in hours and minutes), and a permitted duration for applying updates. The policy is accessible from the Version & Upgrade section under the DSM System tab in the DSM UI, as well as from the vSphere Client. This policy governs automatic upgrades of the DSM Provider Appliance plug-in, allowing organizations to schedule maintenance during off-peak hours and bound the duration of any resulting downtime. The policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the revised settings. If an automatic upgrade fails, administrators can reconfigure the maintenance policy to reschedule or perform a manual update.

For database engines, each database supports an individually configurable maintenance window that controls when minor version upgrades are applied. The default schedule is Saturday at 23:59 UTC with a six-hour duration, adjustable through the Edit Maintenance Window dialog. MySQL databases include an Enable Maintenance Window toggle with the same default schedule. SQL Server databases support configurable maintenance windows for both software version upgrades and operating system patching. In 9.1, DSM adds a Monthly Occurrences setting that refines the maintenance schedule from a standard weekly cadence to specific weeks within a month, allowing selection of a particular day and one or more specific occurrences of that day. If no specific occurrence is selected, the maintenance window runs every week. Maintenance window settings, including Monthly Occurrences, are also configurable when provisioning databases through VCF Automation. Administrators are prompted to define maintenance window schedules during database creation alongside backup policies.

The DSM controller manages component dependencies through status monitoring and automated remediation. DSM also provides operational visibility into maintenance activity through the database Status indicator and the Operations tab, which display in-progress operations, configuration changes, disk extension tasks, and restore operations. This allows administrators to confirm that maintenance actions have been applied and to identify those that have failed.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support controlled maintenance activities across its application delivery infrastructure.

For back-end server pools, Avi's health monitoring framework includes maintenance mode detection. Health monitors can be configured so that when a back-end server enters maintenance mode (signaled by returning a designated response code or

response string), Avi automatically changes the server's health status to "down for maintenance" and stops routing traffic to it. This behavior is supported across TCP, UDP, HTTP, HTTPS, HTTP/2, and POP3/POP3S health monitor types. TCP and UDP monitors use the `tcp-udp-maintenance-mode-filters` setting; HTTP monitors use the `maintenance_response` and `maintenance_code` CLI parameters; HTTP/2 monitors use the `maintenance-server-response-data` setting; POP3/POP3S monitors match a configured string such as `MAINTENANCE_ACTIVE` against the health-check response body. The maintenance mode detection monitor must be associated with the pool the server belongs to. Administrators and application developers can inspect health-check responses directly to validate server maintenance state. When the maintenance string or code is no longer returned, subsequent health checks restore the server to active rotation.

For Global Server Load Balancing (GSLB) operations, Avi enforces a controlled pre-maintenance step before a manual leader change. The CLI command `gslb maintenancemode enabled` must be run in GSLB configuration mode to place the leader Controller into maintenance mode before the leader change proceeds; the corresponding `gslb no maintenancemode` command exits maintenance mode. Avi GSLB can also direct traffic to alternative endpoints during planned maintenance, supporting service continuity while primary endpoints are offline.

For cloud-level maintenance, the Avi Controller provides a CLI workflow to place an entire cloud into maintenance mode using `configure cloud <name>` followed by the `maintenance_mode` directive. This is used during Controller upgrades and patch operations. The cloud exits maintenance mode via the `no maintenance_mode` directive.

For Kubernetes deployments using the Avi Kubernetes Operator (AKO), maintenance mode detection is available through the HealthMonitor custom resource definition (CRD). AKO HealthMonitor TCP monitors support a `maintenance_response` value, enabling Kubernetes-native maintenance workflows where health-check responses trigger traffic drain before maintenance begins.

For bare-metal Linux Server Cloud deployments hosting both Controller and Service Engine components, Avi defines a sequential maintenance procedure: Service Engines must be deactivated before hardware maintenance, host OS upgrades, security patching, or kernel updates on the host. Controller cluster nodes must be serviced one at a time to preserve cluster quorum and availability throughout the maintenance window.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.310(b)

Standard: Workstation use. Implement policies and procedures that specify the proper functions to be performed, the manner in which those functions are to be performed, and the physical attributes of the surroundings of a specific workstation or class of workstation that can access electronic protected health information.

SCF Controls: END-01, GOV-02, HRS-05, HRS-05.1, HRS-05.3, OPS-01.1, OPS-03, PES-03.4, PES-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(c)

Standard: Workstation security. Implement physical safeguards for all workstations that access electronic protected health information, to restrict access to authorized users.

SCF Controls: END-02, PES-03, PES-03.4, PES-04, PES-04.1

Aggregate Coverage: Meets

VCF (Meets)

VCF protects endpoint device confidentiality, integrity, availability, and safety through layered controls spanning hardware trust, hypervisor integrity, encryption, workload isolation, storage resilience, agent management, network security, monitoring, and lifecycle management.

At the hardware layer, VCF supports Secure Boot, Trusted Platform Modules (TPM), and technologies such as AMD Secure Encrypted Virtualization (SEV-ES) for confidential computing. VMware vCenter can retrieve TPM event logs to validate boot-time measurements, and host attestation state can be monitored to verify that hosts have booted in a known good configuration. TPM modules must run the latest 2.0 firmware when in use, or be disabled in the BIOS if not used. Confidential vSphere Pods can use SEV-ES to provide hardware memory encryption and help prevent CPU register state from leaking information to other components. Virtual machines support UEFI Secure Boot for guest operating system integrity verification. vSphere also supports adding a virtual Trusted Platform Module (vTPM) to virtual machines, which reduces the risk of exposing guest operating system secrets if a guest is compromised. For Windows guest operating systems, vSphere supports Virtualization Based Security (VBS), which provides hardware-backed isolation for security features including Device Guard and Credential Guard within the VM.

The VMware ESX hypervisor enforces workload isolation between virtual machines and between VMs and the hypervisor itself. VCF Operations verifies the digital signatures on management pack PAK files to confirm authenticity and publisher identity before installation. OVF and OVA packages can be signed, and the system validates digital signatures during upload. Content libraries support security policies that enforce controls on VM images.

VCF protects the confidentiality of data through several encryption mechanisms. vSAN data-at-rest encryption protects data on storage devices in case a device is removed from the cluster, and administrators can enable the Secure Erasure feature alongside it. When data-at-rest encryption is enabled, vSAN encrypts data after all other processing (such as deduplication) is performed. VMware software and services encrypt network traffic between components, and VCF Operations for Networks supports FIPS validated cryptographic modules for both internal and external connections, with the ability to restrict cryptographic module usage to FIPS validated modules by enabling FIPS mode. For compute-layer confidentiality, vSphere supports hardware memory encryption for confidential pods, providing memory encryption for workloads running within those pods.

vSphere Configuration Profiles and vSphere Lifecycle Manager (vLCM) provide desired-state configuration management for ESX hosts. vLCM defines a desired software specification for a cluster or standalone host, checks compliance against that specification, and can remediate hosts that have drifted. VCF Operations extends this with scheduled configuration drift detection for vCenter instances and clusters, comparing current settings against assigned desired values and reporting deviations.

vSAN protects stored data through end-to-end checksums that verify data integrity during read and write operations. If a checksum mismatch is detected, vSAN automatically repairs the data by overwriting the incorrect copy with correct data. RAID-5 and RAID-6 erasure coding protects against capacity device failures while providing space efficiency. vSAN tracks component failure states, distinguishing between temporary failures (network connectivity loss, host failure) and permanent failures (device failure, controller failure), and rebuilds affected data once the configurable object repair timer expires (default 60 minutes). This timer can be tuned to balance between transient and sustained failure response.

For network-level endpoint protection, NSX segments and isolates workloads through distributed switching and routing.

VCF includes ESX Agent Manager, which automates the deployment and lifecycle management of agents on ESX hosts. ESX Agent Manager uses the AgentOvfEnvironmentInfo object to pass configuration properties, such as IP addresses and credentials, so that agents can connect back to their managing solution once deployed. It installs one agent instance per agency per host, and can resolve deployment issues if the solution or administrator requests it. VCF Operations requires guest operation privileges to install monitoring agents on endpoint virtual machines.

For container and virtual machine workloads, VMware Kubernetes Service (VKS) with Supervisor provisions workload clusters that are secure by default by inheriting the vSphere security features built into vCenter and ESX. VKS validates TLS certificates when fetching images from registries, helping to confirm the authenticity and integrity of container image sources. Container supply chain security is supported through Harbor, available as a standard package on VKS clusters, which provides vulnerability scanning, content trust, and policy-based replication. Pod-level security is enforced through VKS Cluster Management Security Policies, powered by Open Policy Agent (OPA) Gatekeeper, which include a Restricted profile that allows administrators to harden the cluster estate with minimal operational friction; administrators can apply stricter Pod Security Standards based on the risk posture of each cluster. For service-to-service communications, the Istio service mesh standard package available on VKS clusters provides mutual TLS authentication and encryption alongside Layer 7 network policies based on workload identity, extending isolation beyond namespace boundaries to the workload level. Secrets management for containerized workloads is provided through Kubernetes Secrets, with the Secret Store Service enforcing role-based access control for administrators, DevOps engineers, and application tenants; VKS clusters establish a default role that grants service accounts read access to guest cluster secrets in the Secret Store service. For virtual machine workloads running via VM Service, Supervisor integrates with HashiCorp Vault through agent-based secret injection configured via VirtualMachine resource annotations, with secrets delivered through a disk-based sidecar mechanism. VCF Automation provides predefined roles to establish a baseline security posture for VKS cluster management. Security Technical Implementation Guides (STIGs) for Supervisor components and VKS runtime releases (VKrs) are available to guide hardening of the workload platform layer.

VKS Cluster Management supports backup and restore of VKS clusters and their constituent namespaces to address the availability of containerized workloads. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure. For on-premises deployments, CSI volume snapshots can be offloaded to external S3-compatible endpoints, providing durability where local storage arrays lack native snapshot replication across sites. Platform engineers establish authenticated connections to storage providers to enable secure backup orchestration across VKS clusters and their resident resources.

For availability and ongoing security posture management, VCF Operations discovers and monitors application services on endpoint virtual machines where agents are installed, collecting metrics for supported operating systems and services on monitored endpoints. It displays Guest OS Services Authentication Status to reflect the authentication state of guest operating systems and tracks VM authentication status with possible values including Unknown, Failed, Guest Alias, Common Credentials, or Credential-less. VCF Operations provides visibility into virtual machines with security tags applied, displaying VM counts by security tag and showing security groups assigned to VMs. The VCF Operations Security Operations dashboard provides visibility into security across multiple areas including user security and component security for VMs, ESX hosts, and vSAN, along with compliance checks and alerting capabilities. VCF Operations also supports firewall hardening that restricts network access to its own internal services through the Administrator Settings Security Settings interface, reducing the attack surface of the management plane itself.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to endpoint device protection by providing the network security layer that shields workloads from threats traversing the virtual network. While the full scope of endpoint protection spans hardware trust, hypervisor integrity, storage resilience, and lifecycle management addressed by other VCF components, vDefend addresses the network-facing attack surface that endpoints are exposed to.

The Distributed Firewall (DFW) enforces security policies at the vNIC level, meaning every virtual machine's network interface is individually protected regardless of network topology. Administrators can define microsegmentation policies using object tagging, security tags, workload-centric grouping, IP-based groups, MAC-based groups, and tag-based groups. This allows

organizations to establish both broad zone-based segmentation and granular per-workload rules that restrict lateral movement between endpoints. The Distributed Firewall supports layer 2 through layer 7 filtering, enabling policies based on application identity and context rather than just IP addresses and ports. Gateway Firewall extends this protection to north-south traffic at the edge, applying consistent security policies to traffic entering and leaving the environment. The Identity Firewall extends policy enforcement to physical devices through event log scraping, enabling consistent identity-based rules across virtual and physical endpoints.

vDefend IDS/IPS provides signature-based intrusion detection and prevention on both the Distributed Firewall and Gateway Firewall. The IDS/IPS engine evaluates network flows against intrusion detection rules and generates alert events based on protocol and application identification. Organizations can upload custom signature bundles to detect threats specific to their environment. This capability helps protect endpoint confidentiality and integrity by detecting and blocking exploit attempts, command-and-control communications, and other malicious network activity before it reaches the endpoint.

Malware Prevention Service adds file-based and fileless malware detection to the Distributed Firewall and Gateway Firewall. The distributed malware prevention architecture uses a Host Agent (MUX) component running on each ESX host together with Guest Introspection thin agents installed on guest VMs to collect file, network, process, registry, and system events from within the endpoint. Guest Introspection supports thin agents on both Linux and Windows virtual machines. When traffic passes through a firewall rule with a malware prevention profile, intercepted files are analyzed for malicious content. The service includes cloud sandboxing with artifact analysis for unknown files, running suspicious files in isolated environments to observe their behavior. When files are identified as malicious, the service can take active remediation actions on the endpoint, including denying access to suspicious files or deleting confirmed malware. Fileless malware detection identifies attacks that operate within system memory using existing binaries. This provides a network-inline layer of malware defense that complements any endpoint-resident security tools.

Network Detection and Response (NDR) correlates events from IDS/IPS, malware prevention, and suspicious traffic analysis to identify multi-stage attack campaigns targeting endpoints. NDR uses detectors to classify suspicious network traffic and associates detections with specific MITRE ATT&CK techniques and tactics. This correlation capability helps identify threats that individual detection mechanisms might miss when viewed in isolation.

Security Services Platform (SSP) provides security segmentation scoring that measures how well endpoints are protected. The scoring system evaluates environment protection, checking whether workloads are covered by environment-specific segmentation policies such as Dev, Prod, and Test, and infrastructure protection, assessing whether infrastructure workloads like DNS, NTP, and DHCP are explicitly protected. This gives administrators visibility into endpoint protection posture and identifies gaps in segmentation coverage. SSP is deployed with high availability by default to maintain continuity of security services.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(d)(1)

Standard: Device and media controls. Implement policies and procedures that govern the receipt and removal of hardware and electronic media that contain electronic protected health information into and out of a facility, and the movement of these items within the facility.

SCF Controls: AST-01, AST-11, DCH-01, DCH-03, DCH-07, DCH-07.1, DCH-13.2, GOV-02, MNT-01, MNT-04.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(d)(2)(i)

Implementation specifications: Disposal (Required). Implement policies and procedures to address the final disposition of electronic protected health information, and/or the hardware or electronic media on which it is stored.

SCF Controls: AST-01, AST-09, GOV-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(d)(2)(ii)

Implementation specifications: Media re-use (Required). Implement procedures for removal of electronic protected health information from electronic media before the media are made available for re-use.

SCF Controls: AST-09, DCH-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support media sanitization workflows for virtualized infrastructure, though the full control requires organizational procedures for physical media handling, verification, and documentation.

Encryption-based cryptographic erasure

VCF supports encryption of virtual machine disk (VMDK) files, where data in an encrypted VMDK is never written in cleartext to storage or transmitted in cleartext over the network. For storage environments using vSAN data-at-rest encryption or VM Encryption, cryptographic erasure is available as a sanitization method: destroying the encryption keys associated with the storage renders the encrypted data unrecoverable without requiring block-level overwriting. This approach is recognized by industry-standard best practices as an acceptable sanitization technique for encrypted media. Administrators configure VM encryption through VMware vCenter and the key management infrastructure, which supports both KMIP-compatible external Key Management Servers and vSphere Native Key Provider.

The vSphere Web Services API provides `removeKey` and `removeKeys` methods for programmatic removal of cryptographic keys by ID, each with an optional `force` parameter. The `force` option is intended for cases where a key has been compromised or expired, removing it from use across the environment. These API methods support automated key destruction workflows as part of a cryptographic erasure process. On VMware ESX hosts, calling `removeKey` without the `force` option deletes the key from the host's key cache and renders any encrypted virtual machine using that key unusable, because ESX hosts do not track which keys are in use.

The No Cryptography Administrator role separates cryptographic privileges from routine administrative operations. This role includes all Administrator privileges except Cryptographic Operations, and it can be cloned to create custom roles with only specific cryptographic privileges. This separation helps restrict who can modify encryption settings or remove keys during media lifecycle activities.

vSAN disk sanitization features

vSAN includes a disk wipe capability for securely wiping storage devices. Before wiping ineligible disks, administrators must check the partition table and verify the data stored on those disks. When encryption is enabled on an existing vSAN cluster, the "Erase disks before use" option wipes existing data from storage devices as they are brought into encrypted disk groups. Devices added to a vSAN disk group that contain residual data or partition information must be cleaned before they can be claimed, providing a built-in sanitization step during device onboarding. vSAN also supports re-encrypting all data using new keys through a rolling disk reformat, which generates a new Key Encryption Key and new Data Encryption Keys.

ESX host configuration protection

ESX stores its configuration data in encrypted form on boot devices. When a Trusted Platform Module (TPM) 2.0 is available, encryption keys can be persisted in the TPM across reboots using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter. This means host decommissioning can include clearing the TPM to render the stored configuration unrecoverable.

Orphaned disk identification and reclamation

VCF Operations provides capabilities for identifying orphaned virtual disks, defined as VMDKs on datastores that are not connected to any registered virtual machines and have not been modified during a defined period. Administrators can configure a reporting threshold that sets the minimum number of days before unattached VMDKs are flagged as orphaned. The Reclaim Resources feature allows execution of resource reclamation processes, and administrators should verify the

accuracy of reported orphaned disks before performing reclamation. A Reclaimable Orphaned Disks metric displays potential savings from removing orphaned VMDKs across all datastores. Identifying and removing orphaned disks that may contain residual sensitive data is a relevant step in the media sanitization lifecycle.

Datastore removal and virtual disk controls

When a VMFS datastore is destroyed via the RemoveDatastore API, the partitions that compose the VMFS volume are removed and the datastore becomes unavailable to all ESX systems after a rescan. Datastore resignaturing is irreversible because it overwrites the original VMFS UUID. These operations provide mechanisms for decommissioning storage volumes as part of a media reuse or disposal workflow. The delete operation for a VMFS datastore permanently deletes all files associated with virtual machines on the datastore. Before initiating deletion, Storage DRS and Storage I/O Control should be disabled for the datastore to prevent automated storage management processes from interfering with the deletion workflow.

VCF also provides the `isolation.tools.diskWiper.disable` setting, which controls whether guest operating systems can issue virtual disk wiper operations. In hardened environments, this setting is typically configured to restrict disk wiper access, giving administrators centralized control over disk sanitization activities rather than allowing individual virtual machines to initiate wipe operations.

Protecting sensitive data in operational files

Backup files for VCF Operations, VMware vCenter, and NSX are encrypted using AES-256-CBC encryption with SHA256 message digest. After file-based restore operations, administrators are directed to securely delete decrypted backup files and control access to them during the restore process.

Core dumps on vCenter systems are not encrypted and can contain memory contents that include credentials, encryption keys, or other sensitive data. Administrators should consider disabling core dumps on vCenter systems to restrict sensitive information from persisting in diagnostic files. Managing the lifecycle of these operational files is part of a complete media sanitization program.

VCF does not include dedicated media sanitization workflow tools, inventory tracking for media disposal, or chain-of-custody documentation capabilities. These organizational processes, along with physical media destruction procedures and verification of sanitization effectiveness, must be addressed through enterprise asset management and data governance programs outside of VCF.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(d)(2)(iii)

Implementation specifications: Accountability (Addressable). Maintain a record of the movements of hardware and electronic media and any person responsible therefore.

SCF Controls: AST-02, AST-02.1, AST-02.9, AST-03, AST-03.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.310(d)(2)(iv)

Implementation specifications: Data backup and storage (Addressable). Create a retrievable, exact copy of electronic protected health information, when needed, before movement of equipment.

SCF Controls: BCD-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly

started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds. VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the

retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages, including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period.

PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy

Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control 164.312(a)(1)

Standard: Access control. Implement technical policies and procedures for electronic information systems that maintain electronic protected health information to allow access only to those persons or software programs that have been granted access rights as specified in § 164.308(a)(4).

SCF Controls: GOV-02, HRS-02, HRS-03, IAC-01, IAC-08, IAC-21

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization namespace, administrators populate the authorizedGroups setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the oidc-groups-claim setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types,

and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the `oidc-extra-audiences` setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration

rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control 164.312(a)(2)(i)

Implementation specifications: Unique user identification (Required). Assign a unique name and/or number for identifying and tracking user identity.

SCF Controls: IAC-02, IAC-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides centralized authentication, authorization, and auditing through VCF SSO, which acts as the identity broker for all VCF management components. All user and service authentication flows through VCF SSO, providing a single point of control for identity management across VMware vCenter, VMware ESX, NSX, VCF Operations, and VCF Automation. VCF SSO is configured via the VCF Operations console and provides a unified authentication source for VCF components.

VCF supports multiple authentication mechanisms for organizational users. VCF SSO issues SAML tokens for authenticated sessions and supports multiple authentication context methods, including PasswordProtectedTransport (password over HTTPS) and holder-of-key tokens that embed security artifacts for delegation scenarios. vCenter supports built-in identity source authentication using local domain credentials and basic authentication through the OAuth 2.0 Password grant type when federated to an external identity provider. VCF SSO also supports the use of SSPI (Security Support Provider Interface) for client authentication.

Identity federation with enterprise identity providers (via SAML or OIDC) enables organizations to extend their existing AAA infrastructure to VCF. Federating vCenter to an enterprise identity provider supports multifactor authentication and automatic registration and termination of users across services. vCenter has documented federation configurations for specific providers including Okta and PingFederate. VCF SSO also supports the System for Cross-domain Identity Management (SCIM) protocol for automating the exchange of user identity information between identity domains and external identity providers.

Organizations using Microsoft Active Directory can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure. VCF Automation allows each organization to define its own identity provider that it shares with other applications; users authenticate to the identity provider to obtain a token that they then use to log in to the organization. Every organization in VCF Automation has its own identity source for user import. The Supervisor component supports registration of external OIDC identity providers for authentication using Pinniped, which inspects upstream identity tokens from the external provider to determine user identity and group membership before passing that information to the Kubernetes API server. Supervisor can be configured with any OIDC-compliant provider, including Okta, Workspace ONE Access, and Dex, to authenticate users connecting to VMware Kubernetes Service (VKS) clusters. Custom ClusterClass configurations for VKS clusters can be used to authenticate developers using existing corporate identity systems. The Kubernetes API server also supports integration with organizational authentication infrastructure such as LDAP or Kerberos through authentication plugins, enabling Supervisor to participate in existing centralized identity management. An Identity API is available to programmatically authenticate and manage the authorization provider, supporting automated identity lifecycle management.

Authorization is enforced through role-based access control across all VCF components. vCenter maps authorization levels to groups and roles, providing consistent security controls regardless of operational context. VCF verifies what objects principals have access to as part of its authorization model. NSX has a set of built-in roles including Enterprise Admin, Auditor, Cloud Admin, Cloud Operator, Network Admin, Network Operator, Project Admin, Security Admin, and others. Local guest user accounts in NSX have the Auditor role by default, and only a user with the Enterprise Admin role can create new local guest user accounts. VCF Automation provides Organization Administrator, Organization Auditor (read-only), and Organization Owner roles, along with the ability to create custom roles scoped to an organization. Organization Administrators can view the rights associated with roles and create roles local to their organization. For Kubernetes workloads, vSphere Supervisor supports Namespace Owner, Edit, and View permission roles that allow consumers of vSphere Namespaces to provision VKS clusters and vSphere Pods using kubectl. Kubernetes RBAC evaluates Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings against the username, UID, group membership, and extra fields supplied by authenticator modules to determine whether a request is permitted. Users authenticated through external OIDC providers are referenced in

ClusterRoleBindings using the `oidc:user@example.com` naming convention; users authenticated through VCF SSO use the `sso:<username>@<domain>` convention. The `AuthorizeWithSelectors` feature gate passes field and label selector information to authorization webhooks, supporting more granular per-resource authorization decisions. User impersonation is governed by Kubernetes RBAC: the "impersonate" verb on user, group, and ServiceAccount resources under authentication.k8s.io allows designated administrators to act on behalf of other principals in a traceable manner. Kubernetes also distinguishes human user accounts, whose identities are managed externally by the identity provider, from ServiceAccounts, which are namespace-scoped API objects used by automated workloads and processes; separating their lifecycle management supports differentiated audit strategies for each category. IAM role trust policies for VKS clusters can be scoped to specific service accounts and namespaces to enforce least privilege.

VCF provides role-based visibility into policy enforcements. The Organization Administrator and Organization Auditor roles can view policy enforcements within their organizations. VCF's logging infrastructure captures authentication and authorization events across management components. The Kubernetes API server records API server activity with structured per-event metadata. Audit annotations include `authorization.k8s.io/decision` and `authorization.k8s.io/reason`, which record each authorization decision and its human-readable justification in the audit log, providing per-request traceability of who performed what action and how the authorization decision was reached. An audit event is logged for each impersonation request, enabling tracking of how impersonation is used over time. Audit rules can be configured to alert on specific events, such as concurrent reading of multiple Secrets by a single user. Authentication context, including username and group memberships, can be retrieved and logged using `kubectl auth whoami` for verification purposes. Administrators can use `kubectl auth can-i` with user impersonation to determine what actions other users are permitted to perform.

Service-to-service authentication uses certificate-based Principal Identity users rather than password credentials. Principal identity user certificates must be SHA256-based and use RSA/DSA message algorithm with 2048 bits or above key size. Each VCF component registers with VCF SSO as a solution user. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and also supports LDAP authentication sources for additional monitoring and management access.

Additional Consumption-layer services extend the AAA model to workload infrastructure. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control for container image artifacts and artifact security policies. The Secret Store Supervisor Service enforces RBAC across administrators, DevOps engineers, and application tenants for access to secrets and credentials. Argo CD, deployable as a Supervisor Service, supports OIDC authentication with PKCE via the `enablePKCEAuthentication` field and defines access through global RBAC policies using policy rules and group mappings.

While VCF provides the technical mechanisms for authentication, authorization, and audit, centralizing these capabilities requires the organization to deploy and manage an external identity provider (such as Active Directory or an OIDC-compliant provider), define identity governance policies, and establish processes for user lifecycle management including provisioning, periodic access reviews, and de-provisioning. Role assignment procedures and access review processes are organizational responsibilities that fall outside VCF's direct control.

VMware Private AI Services (PAIS) integrates with an external OIDC identity provider to authenticate organizational users accessing AI infrastructure on VCF. The `PAISConfiguration` custom resource is configured with an OIDC authentication block specifying the issuer URL, the client ID (`'pais-authentication-id'`), and the scopes `'openid'`, `'groups'`, and `'offline_access'`. When a region is created for a supervisor in PAIS, an identity provider is automatically created in VMware vCenter for that supervisor, establishing a consistent authentication entry point for AI workloads. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator, who supplies the issuer URL and client ID.

Authorization for PAIS is enforced through OIDC group-based access control. The `'authorizedGroups'` setting in the `PAISConfiguration` restricts service access to user accounts that belong to designated OIDC groups (for example, `'group-for-pais-access-01'` or `'group-for-pais-access-02'`). The `'oidc-groups-claim'` setting names the claim used to identify group membership in the Access Token, and `'oidc-extra-audiences'` accepts additional OAuth 2.0 client IDs that PAIS will recognize when validating tokens. Grafana, used for PAIS metrics visualization, extends the same model through the `'grafana-oidc-role-`

mapping` configuration: users in a designated PAIS access group are assigned the Admin role automatically, while remaining authenticated users receive the Viewer role.

Harbor Registry imposes its own credential boundaries for AI artifact access. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. Processes that push artifacts to Harbor authenticate using the `oras login` command with username and password credentials. Knowledge Base integrations support per-source authentication: Confluence connections accept a user name and password or a personal access token, and SharePoint On-Premises connections use user name and password authentication. These mechanisms restrict access to organizational AI artifacts and reference data to authorized accounts.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) addresses the authentication component of this control through a two-tier identity model. DSM supports both local user accounts and LDAPS-integrated directory service accounts, and administrators can configure one or both identity sources simultaneously. Local users are authenticated by matching their email address and validating their password directly within DSM. LDAPS users are authenticated by matching the email domain name against the registered LDAPS server and validating credentials against the directory service. DSM can be configured to use an LDAP server for both authentication and authorization of platform-level users.

Authentication for the managed databases is handled through database-native mechanisms that DSM exposes and configures. PostgreSQL databases use host-based authentication (HBA), with rules managed through DSM. The HBA configuration applies ordered matching rules where the first entry matching the connection type, client address, requested database, and user name is applied. The default final entry uses SCRAM-SHA-256, providing strong password-based authentication; an optional LDAP entry can also be included. MySQL databases support LDAPS integration using a simple authentication plug-in, with a unique LDAPS user entry per user and support for Active Directory authentication. PostgreSQL and MySQL databases also support LDAPS user accounts linked to organizational directory services, with LDAPS user creation managed through the DSM interface.

DSM adds SQL Server as a supported database engine. SQL Server clusters support two administrator identity types: SQL User credentials and Windows Principal accounts for clusters integrated with Active Directory. DSM's Active Directory integration supports Kerberos-based authentication for domain-joined SQL Server clients, allowing tools such as SQL Server Management Studio running on a Windows machine to authenticate using domain credentials. DSM maps the dbo user, the database object owner, to administrator-controlled identities for SQL Server database access. SQL Server clusters can also use contained database users, where each user authenticates directly against the database rather than a server-level login, keeping identity information self-contained within the database.

Authorization is handled through a role-based model. DSM provides two platform-level roles, DSM Admin and DSM User, which determine the capabilities available to each user within the DSM management interface and API. Custom user roles can be configured for directory service group members, providing scoped monitoring and management access. The Permissions view in DSM supports the creation, monitoring, and management of configured users, giving administrators visibility into who has access. Role assignments also affect behavior in database operations; DSM automatically establishes trust between primary and secondary PostgreSQL instances for Admin-role users, while User-role accounts require manual trust establishment.

DSM produces audit records covering both user-initiated and system-initiated actions. Audit events are generated for actions performed through the DSM UI and API, and each audit log entry includes a Source field identifying the initiating entity: either a user's email address or "System" when the action was initiated by DSM itself. Gateway Audit Logs provide visibility into gateway-level events, and the System Audit Events view is the designated location in the DSM UI for tracking nondatabase-related operations and tasks. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create a simple audit for login events.

In self-service consumption deployments, the DSM Consumption Operator authenticates with the DSM infrastructure using a dedicated authentication secret (dsm-auth-creds), providing a defined authentication path for Kubernetes-native database provisioning.

DSM's authentication, authorization, and audit capabilities are scoped to the DSM platform and its managed databases. Centralized AAA for the broader organizational user population, including account lifecycle management, privileged access governance, and enterprise-wide log aggregation, requires organizational identity governance programs and security tooling outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the enterprise_admin role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the auditor role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC UserInfo endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.312(a)(2)(ii)

Implementation specifications: Emergency access procedure (Required). Establish (and implement as needed) procedures for obtaining necessary electronic protected health information during an emergency.

SCF Controls: IAC-15, IAC-15.2, IAC-15.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several account management capabilities that support the establishment and control of emergency access accounts, though the organizational policies and procedures governing when and how such accounts are used must be defined separately.

VCF includes built-in accounts that act as break-glass paths into platform management. The NSX Manager root account cannot be renamed, deactivated, or deleted, and the NSX Manager admin account similarly cannot be deleted or deactivated. These protections mean that even if the external identity provider becomes unavailable, administrators retain a local access path to network management. VMware vCenter also continues to have local accounts for administrative access and error recovery, providing a comparable break-glass path into vCenter management when external authentication is unavailable. At the hypervisor level, VMware ESX hosts provide Direct Console User Interface (DCUI) access through the root account for emergency host network configuration and administrative tasks. The DCUI.Access setting controls which users can override lockdown mode and access the DCUI, allowing organizations to restrict emergency console access to authorized personnel.

Beyond these permanent break-glass accounts, VCF provides mechanisms for creating and controlling additional emergency accounts. In NSX, the admin user or any user with the Enterprise Admin role can activate or deactivate local user accounts, which allows emergency accounts to be pre-provisioned in a deactivated state and activated only when a break-glass scenario requires them. VCF Automation supports similar account lifecycle management, where provider users can be deactivated to block login and reactivated when needed. Deactivating a VCF Automation organization prevents users from logging in and terminates sessions of currently logged-in users, providing an organization-level emergency lockout capability. This activate/deactivate pattern across both NSX and VCF Automation allows organizations to keep emergency accounts dormant during normal operations and enable them on demand.

VCF Operations supports single-use temporary passphrases that are random alphanumeric strings with a configurable expiration time in hours. These provide a controlled mechanism for emergency access that is inherently time-limited and automatically invalidated after use. Administrator password resets in VCF Operations from the CLI require root account credentials, establishing a chain of accountability for emergency access events. VCF Operations also supports password resets through the administration UI as an alternative recovery path.

Each VCF Operations user must have a unique account with one or more roles assigned through role-based access control, which means emergency accounts can be scoped to only the permissions required for the emergency scenario rather than receiving blanket administrative access. Users can be created locally with roles assigned during account creation, or imported from external authorization sources such as LDAP directories or single sign-on servers, allowing organizations to manage emergency accounts through their existing identity governance infrastructure.

VCF password management provides a consolidated view of all accounts, their current statuses, and any remediation needs. This visibility allows administrators to monitor the state of emergency accounts and confirm they remain deactivated during normal operations.

For service-oriented emergency access, VCF supports service account authentication using API access tokens. Access tokens normally last one hour and are based on a refresh token that normally lasts 90 days. When rotation is activated, each refresh token grant call returns a new access token along with a new refresh token, invalidating the original. Refresh tokens can also be revoked earlier if needed, which provides a mechanism to time-limit emergency service account access and revoke it promptly once the emergency is resolved.

All emergency access activity is captured in audit records. VCF Operations audit events report on authentication and security-related events, including login and logout activity, capability checks, and configuration modifications, and track the last person to modify a user account along with the timestamp of that modification. NSX audit logs record security-related events in the operating system audit log. Authentication events for the admin and root accounts appear in component-level logs, providing an audit trail of when emergency access was used and by whom.

VMware vDefend (Contributes)

Within its own management plane, VMware vDefend (vDefend) Security Services Platform (SSP) maintains two built-in local user accounts: an admin user with the Enterprise Admin role providing full management access, and an audit user with the Auditor role providing access to APIs and services for system auditing. In vDefend, SSP defines five roles at the platform level: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector, enabling separation of duties across administration, auditing, security engineering, security operations, and diagnostic support functions.

SSP enforces password policies for local accounts; passwords must meet defined complexity requirements and can be changed or reset through the Platform and Instance Management interfaces. Remote users and remote user groups are managed through the System > User Management interface, where administrators assign and modify roles. SSP supports directory-managed accounts through external identity providers such as Active Directory over LDAP and OpenLDAP, extending account management to enterprise identity sources; local accounts remain available even when external identity providers are disconnected.

This coverage is limited to vDefend's own management-plane accounts. Organization-wide account management for individual, group, system, service, application, guest, and temporary accounts across all technology assets is outside vDefend's scope and must be addressed through dedicated identity and access management platforms.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides account management mechanisms for the accounts it directly governs: the DSM administrator account, DSM user accounts (local and LDAPS-federated), database owner accounts, and the internal service account DSM uses to authenticate to VMware vCenter.

DSM supports two identity sources for user accounts. Local users are created directly within DSM using an email address as the login username and a password. LDAPS users are federated from a configured directory server, allowing organizations to manage DSM access through their existing identity infrastructure. Administrators can configure one or both identity sources depending on organizational requirements. For LDAP-federated accounts, DSM supports group-based access control by assigning roles to Directory Service Groups, so that group membership in the directory server determines DSM access. This is configured under Administering Data Services Manager > Managing LDAP Users in Data Services Manager.

DSM implements role-based access control with two role types. The DSM Administrator role has full visibility and maintenance capabilities across all data services and is responsible for managing DSM settings including LDAPS and SMTP configuration, database backups, and high availability settings. The DSM Administrator also manages namespaces and permissions for database ownership. The DSM User role allows individuals to provision and manage their own databases and perform database lifecycle operations while having no visibility into other users' data services. DSM User roles support namespace-level access controls that can be configured at the time a user account is created, scoping access to specific Supervisor namespaces. This separation restricts administrative capabilities to designated personnel and scopes each user to the resources they own.

DSM user accounts maintain `failed_login_count`, `last_failed_login_time`, `locked_state_start_time`, and `force_password_change` attributes to enforce account lockout and password management policies. These fields track authentication failures, record when an account entered a locked state, and flag accounts that must change their password at the next login. This is configured under Administering Data Services Manager > Managing LDAP Users in Data Services Manager > Create Directory Service Groups Using the Data Services Manager UI.

The initial DSM administrator account is created during deployment of the DSM Provider Appliance and is mandatory; it cannot be deleted. When access needs to be suspended without disrupting running databases, administrators can reset a local user's password and delegate management of the user's databases to a different user rather than deleting the account.

For database-level accounts, DSM allows database owners to set or change the database administrator password at any time while the database is online. DSM also supports LDAPS user creation for PostgreSQL database authentication and access control, enabling directory-managed credentials for database access rather than locally maintained passwords.

DSM introduces SQL Server as a managed database engine, with specific account management controls for SQL Server instances. DSM deactivates the default sa account and uses a reserved internal account, `dsm_mgmt`, with sysadmin privileges for management operations. The `dsm_mgmt` account restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context. DSM uses contained database users for SQL Server database access, so users authenticate directly against the database rather than through a server-level login. For SQL Server clusters in Active Directory environments, DSM requires a service account that is a standard Active Directory user and a member of the Domain Users group. DSM can also be configured with a privileged Active Directory account to automate the management of service principal names (SPNs) and DNS records for SQL Server clusters. The `dbo` user is mapped to administrator-controlled identities for SQL Server database access.

DSM maintains an internal service account for authentication to vCenter. This account is required for DSM to provision and manage infrastructure resources. DSM maintains service account rotation logs that administrators can review to diagnose vCenter authentication failures. Administrators should monitor for alerts indicating that the service account has expired, as an expired service account causes ongoing DSM operations to fail.

DSM's account management capabilities address the technical layer of this control within its scope. Broader account governance (including formal provisioning and deprovisioning procedures, periodic access reviews, approval workflows for account creation and role changes, and lifecycle management for temporary or guest accounts) requires organizational processes that operate outside DSM. Organizations should establish procedures for reviewing DSM account assignments, managing LDAPS group membership to reflect current job roles, and deprovisioning access when personnel change responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides mechanisms within its own administrative identity plane that support the establishment and control of emergency access accounts.

The most significant mechanism is the locally authenticated admin account. The Avi Controller admin account is the standard administrative account for the system and is maintained as a locally authenticated account even when the Controller is configured for remote authentication services such as LDAP. This design means the admin account remains a functional break-glass path when external identity providers are unavailable, without requiring any reconfiguration.

Beyond the built-in admin account, Avi supports creating additional local user accounts that authenticate against a local database rather than external AAA servers. Each local account can be restricted to specific tenants and assigned roles within each tenant, enabling administrators to create dedicated emergency accounts with the minimum access scope required for their intended purpose. The roles assigned to an account determine which management actions, including modifications to other user accounts, the account holder can perform. Account management requires write access to the Accounts section, which is itself a role-based control.

Account lifecycle management is available through the Controller's Administration interface. Administrators with write privileges to user objects can reset passwords for local accounts under Administration > Account > Users by entering a new password or generating a random one. Accounts that have been suspended can be reactivated through the same interface. Separate account security profiles can be created with customized password policy thresholds beyond the default profile, which can be applied selectively to emergency accounts.

Associating an email address with the admin account is recommended to support password recovery if credentials are lost. Password recovery for local accounts uses the email address configured on the account and requires the Avi Controller to have access to an SMTP server.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control 164.312(a)(2)(iii)

Implementation specifications: Automatic logoff (Addressable). Implement electronic procedures that terminate an electronic session after a predetermined time of inactivity.

SCF Controls: CFG-02, IAC-25

Aggregate Coverage: Meets

VCF (Meets)

VCF provides automated session termination and inactivity timeout mechanisms across its management interfaces, APIs, and component products. These controls operate at multiple layers of the platform to log out users after configurable periods of inactivity or at session end.

At the hypervisor layer, VMware ESX includes a Host Client Session Timeout setting that controls the duration before an inactive Host Client session is terminated. Administrators can configure this value through the ESX security configuration to align with organizational inactivity policies. The ESX Shell, used for console and SSH administrative access, has a separate idle timeout controlled by the ESX-Shell-idle-timeout advanced system setting (UserVars.ESXiShellInteractiveTimeOut), which independently terminates inactive shell sessions.

VMware vCenter uses token-based session management through VCF SSO. Security tokens have a default expiration interval of 30 minutes, after which the session is no longer valid and the user must re-authenticate. The vCenter SessionManager managed object controls user access to the server through methods for logging in, obtaining a session, and logging out, providing both automatic expiration and programmatic session termination capabilities. When any session ends, the associated authentication token is invalidated. The vCenter Appliance Management Interface also enforces a session timeout, expiring idle login sessions after 10 minutes by default. The vSphere Client enforces its own session timeout that defaults to 120 minutes of inactivity and is configurable through the session.timeout parameter.

NSX Manager supports session timeout and automatic user logout. Idle sessions time out automatically, and upon session termination or user logout, users are redirected to the login page. The idle session timeout is configurable, and administrators can also delete idle sessions using the /api/session/destroy API command. When a user logs out, NSX Manager immediately destroys the session identifier and removes the session cookie from the reverse-proxy, limiting session identifier reuse. Session IDs and tokens for each session are unique and expire after the user logs out or after a period of inactivity.

VCF Operations enforces a user session timeout that defaults to 15 minutes and can be modified to match organizational requirements. VCF Operations for Networks allows configuration of the user session timeout with a value range from 15 minutes to 24 hours, giving administrators flexibility to set inactivity thresholds appropriate for their environment. VCF Operations also recommends defining a Release Session Request when using session authentication to log out sessions and reduce session leaks.

The VCF Automation Provider Management Portal automatically logs out users after more than 25 minutes of inactivity. VCF Automation also supports API token expiration, with access tokens expiring after 30 days and API tokens expiring after 90 days by default. At the organization level, deactivating a VCF Automation organization terminates the sessions of all users currently logged in to that organization, providing an administrative mechanism for bulk session termination.

At the Kubernetes consumption layer, the VMware Kubernetes Service (VKS) and vSphere Supervisor enforce bounded session lifetimes through multiple token expiration mechanisms. The Kubernetes API server enforces a maximum validity duration for all service account tokens through the --service-account-max-token-expiration parameter, which caps token lifetimes server-side regardless of what a requesting client specifies. Tokens generated via the TokenRequest API accept an expirationSeconds parameter, and the TokenRequestStatus includes an expirationTimestamp confirming when the credential expires. Projected service account tokens mounted into pods default to one hour of validity, with a minimum enforced duration of 600 seconds, and are automatically rotated by the kubelet before expiry; when rotation is not possible, the token expires and subsequent requests from the workload are rejected. User access to vSphere namespaces and VKS clusters is

authenticated through VCF SSO, which provides the OIDC token that kubectl and other API clients use; when that token expires, the user must re-authenticate without administrator intervention.

Streaming sessions opened through the Kubernetes API, including kubectl exec, kubectl attach, and port-forward connections, are governed by the kubelet's streamingConnectionIdleTimeout parameter, which automatically closes any streaming connection that has been idle for the configured duration. In VKS clusters provisioned through the ClusterClass API, streamingConnectionIdleTimeout is exposed as a configurable variable in the kubeletConfiguration ClusterClass variable block, with a default of 10 minutes. For ingress traffic routed through the Contour package, idle HTTP connections are terminated when they exceed the timeouts.connection-idle-timeout value, and idle HTTP streams are closed when they exceed timeouts.stream-idle-timeout; both are configurable in the Contour package configuration and apply to all traffic passing through the ingress layer.

At the API layer, the vSphere Web Services API provides a SessionManager with explicit logout methods to close authenticated sessions. The VCF Operations PowerShell plug-in offers a closeSession method to terminate sessions by session ID. These programmatic interfaces allow automated tools and scripts to enforce session cleanup as part of operational workflows.

Across all components, VCF provides both configurable inactivity timeouts for interactive sessions and explicit session termination capabilities through management interfaces and APIs. The default timeout values vary by component but are set to enforce session termination within reasonable inactivity windows, and all are adjustable to meet organization-defined policies. Auditors evaluating a VCF deployment should verify the timeout values configured for each management component as well as the Kubernetes API server --service-account-max-token-expiration parameter and the kubelet streamingConnectionIdleTimeout for VKS clusters.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database

instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use scram-sha-256 as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support scram-sha-256, reject, and cert authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides session termination through two distinct planes: the management plane (Avi Controller) and the data plane (Service Engines handling application traffic).

For management sessions, the Avi Controller enforces a configurable Session Timeout that specifies the maximum number of minutes an administrative session can remain idle before the Controller terminates it automatically (Administration > System > Access Settings). When a UI session expires due to timeout or logout, the Controller displays a login screen requiring reauthentication. When an API session ends due to timeout or logout, the next API call fails validation. CLI sessions are terminated silently on expiration; the next command typed triggers re-validation of a new CLI session. The Controller also enforces the `api_force_timeout` setting, which bounds the maximum duration of portal API sessions (24 hours by default). The Avi Controller generates `USER_LOGOUT` events in the audit event log, providing a record of session termination activity for administrative users. When the maximum concurrent session count is reached, administrators can also forcibly invalidate existing sessions using the shell `-clear-sessions` command.

For application sessions proxied through Avi virtual services, the TCP Fast Path Profile includes a configurable Session Idle Timeout parameter. When an application-layer flow is idle for the configured period, the Service Engine terminates it and sends a TCP reset to both the client and the server.

For applications using OAuth 2.0 and OpenID Connect (OIDC) for client authentication, Avi supports Relying Party (RP)-initiated logout. When a user logs out, Avi, acting as the OAuth client, redirects the user agent to the Identity Provider's end session endpoint (configured via the `end_session_endpoint` parameter in the `oauth_profile`) to terminate the session at the Identity Provider level. The logout URI is configurable via the `logout-uri` parameter, and a `post_logout_redirect_uri` can be configured to direct users to a defined location after logout. Upon logout, Avi clears the user's session details from the session database. After RP-initiated logout completes, the user must provide credentials again to access resources.

In Kubernetes environments using the Avi Kubernetes Operator (AKO), the SSORule CRD provides OAuth/OIDC session cookie timeout configuration via the cookieTimeout property in oauthVsConfig (specified in minutes, with a default of 120 seconds). The /oauth/logout endpoint is available for OAuth session termination through the SSORule CRD configuration.

When Avi is deployed with Avi Cloud Console, session logout from the Cloud Console is separate from Broadcom IDP session logout. Users who log out of the Cloud Console must also log out from the Broadcom support portal to fully terminate their Broadcom IDP session. Auditors evaluating organizations using Avi Cloud Console should verify that users understand this distinction and that operational procedures account for it.

Auditors should verify the Session Timeout setting in the Avi Controller under Administration > System > Access Settings and confirm that the api_force_timeout value aligns with organizational policy. For virtual services using OIDC client authentication, auditors should review the OAuth Profile configuration to confirm that the end_session_endpoint and logout-uri parameters are set.

Control 164.312(a)(2)(iv)

Implementation specifications: Encryption and decryption (Addressable). Implement a mechanism to encrypt and decrypt electronic protected health information.

SCF Controls: CRY-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware

that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that

organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS

version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the PGCRYPTO_PASSWORD and PGCRYPTO_ALGORITHM keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport

Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control 164.312(b)

Standard: Audit controls. Implement hardware, software, and/or procedural mechanisms that record and examine activity in information systems that contain or use electronic protected health information.

SCF Controls: MON-01, MON-01.16, MON-01.4, MON-01.8, MON-03, MON-03.2, MON-16

Aggregate Coverage: Meets

VCF (Meets)

VCF links system access to individual users and service accounts through identity-aware audit logging across all platform components. Auditable events are logged across these components to provide a baseline of audit trail coverage.

VCF Operations event auditing records user interactions with the platform, including searches, logins, logouts, capability checks, and configuration modifications, registering each action as an audit event tied to the specific user who performed it. Each audit event has a detailed view containing information that helps analyze events in the virtual infrastructure for suspicious user actions or system issues. Audit logs can be filtered by User ID, User Name, Auth Source, Session, Client IP, Category, and Message, making it straightforward to trace activity back to a specific identity. Auditing reports in VCF Operations provide traceability of the objects and users in the environment. VCF Operations also provides a unified view of audit events collected from VMware vCenter instances across the infrastructure, giving visibility into platform interaction changes. VCF Operations can import user accounts from external identity sources such as LDAP directories and single sign-on servers, enabling centralized identity management that ties access events back to known identities.

VCF Automation creates audit logs when reportable actions are performed, such as deploying a blueprint or catalog item, performing Day 2 actions on resources or deployments, or creating, deleting, or updating property groups. Each audit log entry contains a timestamp, message, user name, project name, and trace ID value, along with a description of the event and its result. VCF Automation events record the user who triggered each event in the Owner field, and event logs record API access token usage by including the UUID of the token that performed the action.

VCF distinguishes between individual user accounts and service accounts as separate identity types. Service accounts are created by system administrators who hold the View Service Accounts and Manage Service Accounts privileges, and can be provisioned through either the VCF Automation user interface or the API. Service accounts access the system exclusively through APIs and have no user interface access, making their actions distinct and traceable in audit logs. The service account authorization process is designed so that only the application assigned the token has access to it, and service accounts cannot be impersonated by other actors unless credentials are disclosed. In production environments with virtual machines and container-based microservices, VCF recommends using service accounts rather than normal user accounts to maintain clear identity attribution.

At the vSphere layer, authenticated users can view objects or invoke operations on the server depending on the permissions associated with their account. The AuthorizationManager API manages permissions and roles, and users can be members of multiple groups for permission application. The UserDirectory service in vCenter provides a lookup mechanism that returns user-account information to the AuthorizationManager and other requesting components, supporting user identity resolution. The vCenter EventEx interface accepts a userName parameter when constructing event records, associating user identity with the logged action at the API level. VMware ESX hosts can transmit audit records to remote syslog collectors by enabling the Syslog.global.auditRecord.remote parameter, which directs records to the destination defined by Syslog.global.logHost; vCenter can stream events to a remote syslog server by enabling vpxd.event.syslog.enabled through the vCenter Management Interface.

VMware Kubernetes Service (VKS) clusters provisioned on VCF extend identity-aware audit logging to the Kubernetes workload layer. The Kubernetes API server generates audit events conforming to the audit.k8s.io API group; each event includes the identity of the requesting user or service account, a unique audit ID, timestamps, the resource being accessed, and the action taken. Operators configure what is recorded through an audit policy that supports four levels: None (no logging), Metadata (user, timestamp, resource, and verb), Request (adds the request body), and RequestResponse (adds both request and response bodies), allowing administrators to tune the scope of attribution data captured for each type of API

request. Audit backends deliver records to log files via the `--audit-log-path` flag or to an external endpoint via a webhook backend. Within vSphere Namespaces, workload logs are streamed to a remote syslog server after a `LogAgentConfiguration` Custom Resource is applied to the namespace, and syslog messages from vSphere Pods include metadata fields that identify the namespace name, pod UID, pod name, container name, and ESX host name. For VKS clusters running standard packages, Fluent Bit agents deployed in the `vmware-system-logging` namespace collect logs from across cluster nodes and forward them to destinations including Syslog, HTTP, Elasticsearch, Kafka, and Splunk. Kubernetes distinguishes between human users, who authenticate through VCF SSO or external identity providers, and service accounts, which are namespaced objects that authenticate with the structured username format `system:serviceaccount:(NAMESPACE):(SERVICEACCOUNT)`, making each service account uniquely identifiable in audit events. VKS Supervisor namespaces integrate with VCF SSO so that human user identities are federated through the enterprise identity provider before reaching the Kubernetes API server, maintaining traceability from Kubernetes API actions back to individual organizational accounts. Kubernetes audit policy also supports a Pod Security admission audit mode that records namespaces and pods violating a policy level in audit logs without blocking workload execution, providing additional attribution data for security review.

For NSX components, audit logs are generated for events such as logon, logoff, and access to resources, with each entry containing the timestamp, source, result, and event description. NSX Manager audit logs record user operations including `UserName`, `ModuleName`, `Operation`, and `Operation status` with timestamps and request identifiers. Audit logs for vDefend firewall policy changes capture the identity of users making changes through `_create_user` and `_last_modified_user` fields. NSX audit logging also captures network configuration changes such as logical switch create, update, and delete operations, as well as logical switch port events, recording the identity of the user who performed each change.

VCF Operations for Networks supports exporting audit log data in CSV format for external analysis and long-term retention.

VMware Private AI Services (PAIS) links system access to individual users and service accounts through the OIDC-based authentication and authorization framework built into the service. Activating PAIS in a VCF Automation organization namespace requires configuring the `PAISConfiguration` custom resource with an OIDC provider's issuer URL, client ID such as `pais-authentication-id`, and scopes including `openid`, `groups`, and `offline_access`. Access to PAIS endpoints is then restricted to user accounts whose OIDC Access Token carries a `groups` claim matching an entry in the `authorizedGroups` field. Administrators specify one or more authorized groups, such as `group-for-pais-access-01` or `group-for-pais-access-02`, when activating the service using either the VCF Automation UI or the `kubectl` command. The OIDC groups claim name is itself configurable for compatibility with the OIDC provider's group identification scheme.

The Grafana observability dashboard extends this linkage to the monitoring layer. Using the `grafana-oidc-role-mapping` property, Grafana assigns the Admin role to OIDC users whose group claims match a specified attribute path and the Viewer role to remaining authenticated users. The mapping expression contains `groups[*], 'pais-access-group' && 'Admin' || 'Viewer'` is configured during Grafana setup for PAIS observability. A single Grafana instance can visualize metrics from multiple PAIS instances when they share the same OIDC provider. PAIS Controller metrics are exposed at the Prometheus metrics endpoint on the `pais-controller-manager` service for collection by monitoring systems. PAIS can also send LLM traces to an OpenTelemetry Collector by uncommenting the `spec.observability.IlmTraces` section of the `PAISConfiguration` custom resource, which supports MLOps engineers in analyzing traces from agents and knowledge base indexing.

At the data layer, PAIS scopes access to external knowledge base data sources through named service accounts and account-bound credentials. Google Drive folders used as knowledge base data sources must be shared with a dedicated service account with view-only permissions. Confluence data sources support authentication using either a user name and password or a personal access token generated from user account settings. Microsoft SharePoint On-Premises data sources require user name and password authentication. Personal access tokens are issued per user account and used for programmatic access to Knowledge Bases and data sources, associating ingestion activity with an identifiable account. Service account key file data sources require the key file information during data source creation.

PAIS catalog items in VCF Automation are shared with project members through project-based permissions, restricting access to the AI infrastructure provisioning workflow to named individuals within the relevant project. The DSM database underlying PAIS knowledge bases can be configured to be shared between developers and catalog users by enabling a toggle, which creates a new DSM database catalog item.

Deep Learning VMs record cloud-init script logs in `/var/log/dl.log` and vGPU or NVIDIA data center GPU driver installation logs in `/var/log/gpu-install.log`, providing local records that connect installation and operational events to specific workload sessions. JupyterLab instances on Deep Learning VMs can be examined to verify installation and operation of components.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through several mechanisms that associate security-relevant access and activity to named accounts.

The Security Services Platform (SSP) provides two predefined local user accounts: an admin user with the Enterprise Admin role and an audit user with the Auditor role. The Auditor role has read-only access to view information and track activity across the platform without the ability to make changes, providing a named account to which audit activity is attributed. SSP also supports role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Roles can be assigned to remote users or user groups defined in an external identity provider such as LDAP, allowing management plane access to be tied to directory accounts.

The Distributed Firewall's Identity Firewall feature collects Windows Event Log data from configured Event Log Sources or from VCF Log Management, associating network traffic with the user identity obtained from directory login events. This provides a mechanism to link east-west firewall policy enforcement to the individual user identity behind a workload, attributing network access decisions to specific users or service accounts.

VMware vDefend IDS/IPS generates detection event logs that can be forwarded to external syslog consumers for centralized collection and integration with organization-level audit trail systems. IDS/IPS syslog forwarding is disabled by default and must be explicitly configured. Events are written in RFC-compliant syslog format.

The Malware Prevention service logs file inspection events, allowlisted file verdicts, and process inspection verdicts with timestamps on the Malware Prevention Dashboard. These records are retained in history and provide a traceable record of security events associated with inspected workloads.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) links disaster recovery operations to individual users and service accounts through identity-aware audit logging and role-based permission management.

PNR captures audit events that record user actions including configuration changes and recovery plan executions. Each event includes the event name, user identity, and source IP address of the session that initiated the action. Specific named events are generated for protection group changes: `SPCgUnprotEvent` is recorded when a user removes a consistency group from a protection group, capturing description, cause, category, and event target. Recovery plan executions, tests, and test cleanups each generate a user-attributed record; PNR can also generate and export detailed reports about each run for audit trail purposes. vSphere Replication generates typed audit events for replication state changes, including `com.vmware.vcHms.replicationConfiguredEvent` and `com.vmware.vcHms.replicationUnconfiguredEvent` for VM-level operations, and `com.vmware.vcHms.hostConfiguredForHbrEvent` and `com.vmware.vcHms.hostUnconfiguredForHbrEvent` for host-level operations.

PNR includes an `auditd` service that writes audit records to disk. This service is stopped by default and must be manually started before it can record events persistently. vSphere Replication audit logs are maintained at `/opt/vmware/support/logs/hms/hms-audit.log` on the appliance; replication broker logs are stored at `/opt/vmware/support/logs/hbr` on the appliance and at `/var/run/log` on VMware ESX hosts. Authorization errors and certificate verification events are also written to security-related log files with timestamps and component information.

Access to PNR is managed through role-based access control with predefined roles including Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. PNR administrators can grant access to additional users through the vSphere Client. For cross-site authentication, PNR uses service accounts: in VCF SSO environments with Enhanced Linked Mode, PNR uses a domain-level service account created by VMware vCenter; for sites that do not use Enhanced Linked Mode, PNR creates a dedicated service account on each remote site during the pairing process. Creating separate users on storage arrays for each PNR server is a recommended practice to maintain logical

separation of array-level operations. In shared recovery site configurations, customer resources can be separated by assigning a dedicated datastore per customer or by placing VMs in separate folders within a common datastore; the 9.1 documentation notes that all customers on a shared recovery site can potentially access other customers' folders, so network and datastore isolation should be evaluated for multi-tenant deployments.

The PNR Appliance can forward log files to a remote syslog server for centralized log analysis and monitoring. The Live Cyber Recovery (LCR) clean room component supports forwarding events to VCF Log Management 9.0 and above. Forwarded events include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. The clean room also supports integration with external security platforms through Microsoft Azure Monitor Data Collection Rules configured for an Entra Application, providing a path to route user-attributed recovery events to external monitoring systems.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides several capabilities that support ongoing event log review. The primary interface for reviewing non-database-related operations is the System Audit Events view, accessible through the System Audit section of the Provider interface. This view records and displays DSM management-plane operations in a structured format, including the Component field (which DSM component performed the operation), Event Type (the type of audited event or operation), Event Details (operation-specific details for the event), Event Time in UTC, Status, and Source. The Source field records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user intervention. Administrators can review these events directly in the UI or export them in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view. Exports include all audit events visible to the reviewing user, regardless of how many events appear on a single page, enabling complete off-platform analysis and reporting.

In addition to the System Audit Events view, DSM provides Gateway Audit Logs accessible through the Audit Logs section. Gateway Audit Logs track user read and write operations to DSM data services and infrastructure objects performed in the DSM UI or the DSM Gateway Kubernetes interface. Gateway audit log files are stored on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and are retained for the last five days on the Provider VM. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit," supporting log retention for ongoing and retrospective review. The gateway audit logs contain standard Kubernetes audit events but do not record the content of secrets.

DSM generates a structured set of alerts to support proactive monitoring and help surface conditions that may require investigation. At the infrastructure level, DSM raises an `INFRASTRUCTURE_POLICY_VC_ALARMS` alert when one or more active infrastructure resource alarms are detected in VMware vCenter, and generates alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates a `VCENTER_CONNECTIVITY` alert when vCenter connectivity fails; troubleshooting steps include verifying vCenter connectivity, checking vCenter authentication logs, and verifying that the service account is not locked. At the database level, DSM provides an Alerts pane in the Monitoring tab where administrators can monitor alerts triggered on databases, covering conditions such as CPU Health, Data Disk Health, System Disk Health, Max Connections, Custom Config Health, and Database Engine Health. Administrators can configure and edit alert threshold values and time limits for warning and critical severities on these conditions, allowing organizations to tune alerting sensitivity to their operational requirements. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations, enabling integration with external notification systems.

Organizations that deploy the VCF Operations integration can extend monitoring visibility. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state, displays active alerts and inventory items on the Data Services View dashboard, and surfaces performance data at three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for database-specific metrics such as Active Connections, Commits, Rollbacks, and Deadlocks.

DSM provides the audit event records, alert generation, export capabilities, log archival, and optional VCF Operations integration needed to support a log review program. The review cadence, escalation thresholds, escalation workflows, and

incident management procedures are organizational responsibilities that must be defined and operated separately. Integration with a SIEM or centralized log management platform is also an organizational decision.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides mechanisms within the Avi control plane to link configuration activity and system access to individual user accounts.

The primary mechanism is the Config Audit Trail, accessible in the Avi Controller via Operations > Events > Config Audit Trail. The Config Audit Trail presents a filterable view of user activity events and configuration changes over a configurable time window, recording which account performed each action. Avi Event Logs provide detailed records of system activities, configuration changes, and operational events, including an audit trail that tracks changes to configurations with information about who made them and when. Avi Controller and Avi Service Engine log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk.

Audit events can be forwarded to external syslog infrastructure through the Syslog-Audit-Persistence alert action, which streams events to configured syslog servers for centralized retention and compliance review. Configuration events are queryable through the Avi Controller API with a configurable duration parameter, enabling programmatic retrieval of the audit trail for extended periods. Note that syslog notifications push alert events to external servers but do not automatically export virtual service logs; those must be pulled from the Controller via API or pushed separately.

Avi supports both local user accounts and remote users authenticated through external authentication, authorization, and accounting (AAA) servers, including LDAP, SAML, TACACS+, and OIDC. TACACS+ integration allows authorization attributes from the server to map Avi users to specific roles and tenants. Auth Mapping Profiles can map user groups to roles with varying permission levels, maintaining identity linkage across role assignments. In multi-tenant deployments, each session is scoped to a specific tenant context, so audit records carry tenant identity alongside user identity. Within each user account, the role selected for the user is mapped to a tenant, allowing access to resources to the extent allowed by that role.

The Avi License Hub includes a dedicated local Audit account with the auditor role, which has full access to APIs and services for system auditing.

Note that access to the underlying VCF platform infrastructure is recorded by VCF-level audit mechanisms rather than by Avi.

Control 164.312(c)(1)

Standard: Integrity. Implement policies and procedures to protect electronic protected health information from improper alteration or destruction.

SCF Controls: DCH-01, DCH-01.2, GOV-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label,

and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The `etcdctl` snapshot save command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During `kubeadm` upgrades, backup folders for etcd state and cluster manifests are written automatically to `/etc/kubernetes/tmp` with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides `VolumeSnapshotContent` and `VolumeSnapshot` resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a `PersistentVolumeClaim` using a `VolumeSnapshotClass` that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new `PersistentVolumeClaim` with the target `VolumeSnapshot` as its `dataSource`, referenced via the `snapshot.storage.k8s.io` API group. Kubernetes `PersistentVolumes` have a configurable reclaim policy; setting the policy to `Retain` preserves volume data in a `Released` state after the associated `PersistentVolumeClaim` is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to protecting sensitive and regulated data by maintaining replicated copies at geographically separated sites and providing orchestrated recovery when primary copies are compromised or corrupted. Bidirectional protection is implemented by protecting datastore groups or storage policies using array-based replication, or by protecting individual virtual machines using vSphere Replication, allowing organizations to keep regulated workloads recoverable across paired sites.

Protection groups allow administrators to organize regulated workloads and apply consistent replication and snapshot policies across the virtual machines and datastores subject to the same data protection requirements. PNR protection groups support an immutability mode that, when enabled, prevents the data protection group from being modified or deleted, which addresses tamper resistance for the configuration that governs how regulated workloads are protected. For multi-tenant or

shared recovery scenarios, PNR maps resources, networks, folders, and datastores on protected sites to separate datacenters, networks, folders, and placeholder datastores on the shared recovery site, preserving customer data isolation across the recovery boundary.

vSAN Snapshots and Replication provides VM restore and clone operations from existing snapshots, supporting recovery of regulated workloads to a known-good point in time. PNR records operational information into log files that do not contain sensitive information such as private keys or passwords, which limits the recovery tooling itself as a source of disclosure. The Protection and Recovery dashboards in VCF Operations provide cross-site visibility into protected and recovery sites, vSAN snapshot and replication state, and VCF Protection and Recovery Cloud regions, supporting monitoring of regulated workload protection.

Encryption at rest for primary storage, data classification, granular access controls at the data layer, and key management are provided by the underlying VCF platform rather than PNR itself.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the protection of sensitive and regulated data through several database-platform mechanisms covering data in transit, data retention, storage policy enforcement, tenant isolation, and application-level cryptographic capabilities.

For data in transit, DSM requires TLS connections to database clusters. Clients establish these connections by adding the relevant certificate authority to the OS trust store, or by retrieving the CA certificate from a custom certificate secret through the DSM API for automated workflows. Beginning with DSM, DSM enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. A TLS certificate for secure communication between the Consumption Operator and the DSM provider must be obtained and configured by the cloud administrator before enabling self-service consumption.

For backup and data retention, DSM includes automated backup capabilities with configurable schedules supporting both full and incremental backups. Database administrators configure backup storage locations and retention periods on a per-database basis. DSM retains automated backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. Control plane backups are stored in S3-compatible object storage with a unique identifier tied to the control plane ID. DSM supports point-in-time recovery (PITR), restoring a backup at a specified point in time to a newly created database VM. PITR is accessible through both the DSM interface and the VCF Automation UI. If an incremental backup in a backup chain is deleted, DSM cannot restore data from later incremental backups in that chain, so maintaining a consistent backup schedule is important for recoverability.

For storage placement and access constraints, DSM infrastructure policies control which storage types and storage policies are available for database virtual machines and govern VM placement within the infrastructure. Storage policies in DSM determine the datastore placement of database VMs and filter available storage options to those compatible with the specified compute resource. Data service policies can be defined and enforced across tenants for MySQL, PostgreSQL, and SQL Server databases, including allowlists that restrict users to approved provisioning parameters. In multi-tenant deployments using VCF Automation, administrators can assign object stores and data service policies to specific tenants or organizations, enforcing isolation and resource constraints across database clusters.

For application-level data protection, PostgreSQL databases in DSM support the pgcrypto extension (version 1.3), which provides cryptographic functions that can be applied to secure specific data fields. DSM also stores its own internal user credentials encrypted using PGCrypto symmetric encryption with a dedicated encryption key. For SQL Server databases, DSM uses an internal management login that restricts user-defined triggers to a database-level security context, blocking access to server-level permissions during management operations.

Because this control asks whether mechanisms exist to protect sensitive and regulated data wherever it is processed or stored, DSM's contribution is at the database platform tier. The organization remains responsible for classifying what data is sensitive or regulated, configuring database-level access controls that restrict which authenticated users can read or write protected data, selecting storage and backup policies that satisfy encryption and data residency requirements for specific regulated categories, and maintaining a governance program that maps data classification to handling requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control 164.312(c)(2)

Implementation specification: Mechanism to authenticate electronic protected health information (Addressable). Implement electronic mechanisms to corroborate that electronic protected health information has not been altered or destroyed in an unauthorized manner.

SCF Controls: CFG-08, CFG-08.1, MON-01.15, MON-01.7, MON-16

Aggregate Coverage: Meets

VCF (Meets)

VCF restricts access to sensitive and regulated data through layered access controls across its component stack, spanning centralized authentication, role-based access control, encryption privilege management, API-level data protection, and secrets management.

VCF SSO provides centralized, token-based authentication for all user access. VCF SSO supports multiple identity sources and federation with enterprise identity providers through standard protocols such as AD FS, centralizing authentication decisions and reducing direct access to individual VMware ESX hosts. Federating VMware vCenter to an enterprise identity provider enables multi-factor authentication (MFA) for administrative access through the vCenter Client and VCF Operations interfaces. Both on-premises and cloud-based identity providers are supported for user and programmatic access. Solution users authenticate using certificates for secure service-to-service communications.

Role-based access control (RBAC) spans vCenter, ESX, NSX, and VCF Operations. Administrators assign granular permissions that govern what data and operations each user can access. The CloudAdmin role model restricts platform-level operations while providing the administrative capabilities users need. VCF Operations implements RBAC that allows assignment of specific roles and permissions to user accounts, restricting access to defined objects in the VCF Operations cluster hierarchy. Users can only perform the actions that their assigned permissions allow, which means administrators can scope access so that individual operators see only the data relevant to their responsibilities. VCF Operations enforces privilege-based access control that restricts users without the appropriate privileges from viewing collected data for managed objects. The Roles tab under Infrastructure Operations allows granular selection of permissions when adding or editing a role. For third-party device data sources in VCF Operations for Networks, a read-only user requires read-only credentials and the Network Operator role, with passwords added during data provider configuration. This layered role assignment restricts who can view or modify sensitive monitoring and network configuration data. The Datastore > Browse datastore privilege should be assigned only to users who require the ability to view, upload, or download files from datastores, so that general administrative roles do not have access to stored data files beyond what is necessary.

For encryption of sensitive data, vCenter provides an extensive set of Cryptographic Operations privileges that offer fine-grained control over encryption tasks. Administrators can assign these privileges selectively so that only authorized personnel can perform encryption and decryption operations. Custom roles can grant only specific cryptographic operations, such as allowing encryption without permitting decryption. For vSAN data-at-rest encryption, only administrators who hold encryption privileges can perform encryption and decryption tasks, restricting access to encrypted data stores to a defined set of privileged users. vSAN also provides data-in-transit encryption to protect data as it moves across the cluster, reducing the risk of interception during internal communication. Fault Tolerance log traffic, which carries the memory state of running virtual machines, can also be encrypted to protect against exposure of sensitive data in high-availability configurations. Separate key providers can be configured for different departments or organizational units, enabling granular access control over encryption keys so that each group accesses only the keys relevant to their workloads.

The VCF Automation IaaS API includes a mechanism to mark certain data fields as sensitive in a request body. When data is marked sensitive, the platform stores it in encrypted form and only the encrypted representation is visible in API responses. This applies to cloud configuration data used during machine provisioning as well, where sensitive portions of the cloud config are encrypted before storage. These API-level controls restrict exposure of sensitive data even to users who have general API access.

VCF Automation enforces organizational isolation so that each organization operates in a separate environment where users can access only their allocated services and resources. Organizations provide infrastructure isolation, quotas, and chargeback capabilities for multi-tenant deployments, with dedicated network setup and network isolation to support security boundaries between tenants.

For Kubernetes workloads running on VMware Kubernetes Service (VKS) and vSphere namespaces, VCF provides a layered set of access restriction mechanisms. At the namespace level, vSphere Namespaces support three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings. Both VCF SSO and external OpenID Connect (OIDC) providers are supported for Kubernetes authentication, allowing organizations to extend their existing identity infrastructure to container workloads.

Within VKS clusters, Kubernetes RBAC uses Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects to control which subjects can access specific resources. Role objects can restrict permissions to specific resource names and subresources, enabling access control at a finer granularity than the resource type level. RBAC can scope access to the nodes API and its sub-resources so that only authorized services, such as monitoring agents, receive the necessary permissions. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least-privilege access for workloads on VKS clusters provisioned through the Cluster API. Attribute-Based Access Control (ABAC) policy rules provide an additional authorization layer that restricts users or groups to read-only operations on specific resources within particular namespaces.

Kubernetes Secrets provide a mechanism for storing sensitive data such as credentials, API keys, and certificates separately from application code. Kubernetes RBAC can enforce least-privilege access to Secret objects, and access can be restricted to specific containers within a pod. Short-lived Secrets are recommended to limit the impact of accidental or intentional credential exposure. For confidential data, the platform supports using Secrets rather than ConfigMaps. Secrets used in continuous integration and delivery pipelines, such as those managed through the Argo CD Supervisor Service, should be managed outside of source control with access controls enforced across all components. Third-party tools can also manage sensitive data by running within or outside a VKS cluster and exposing Secrets to pods over HTTPS upon correct client authentication, such as with a ServiceAccount token. The Secret Store Service, available as a Supervisor Service, enforces RBAC for administrators, DevOps engineers, and application tenants who manage and distribute sensitive data. The etcd datastore that backs the Kubernetes control plane should be configured with access controls and not publicly exposed on the network; access controls for managed encryption services, whether relying on local encryption keys or authentication tokens for Key Management Service calls, must be appropriate to the security requirements of the deployment.

Pod Security Admission (PSA) is supported on VKS clusters with three enforcement standards: Baseline, Restricted, and Privileged. These standards are applied per namespace, allowing organizations to enforce stricter policies in namespaces that handle regulated data. The Restricted PSA level applies pod hardening practices, reducing the scope of what containers can access at runtime. Pod security contexts can be configured per workload with settings such as runAsUser, capability dropping, seccomp profiles, and readOnlyRootFilesystem to further limit container access. On VKS nodes, AppArmor provides mandatory access control that restricts container capabilities, limits filesystem and network access, and enforces security policies on Ubuntu and Photon OS nodes through per-container profiles that dictate the rules and restrictions the containerized process must follow. Kubernetes taints can be applied to nodes to dedicate them for exclusive use by a particular set of users or workload classifications, with corresponding tolerations on pods enforcing the access control at the scheduling layer. Seccomp profiles and SELinux provide additional runtime security restrictions on Linux nodes.

When Harbor is deployed as a standard package on VKS clusters, it enforces RBAC to secure container artifact management, restricting which users and teams can pull or push container images. This helps organizations control what images are deployed in environments that handle regulated data. The Istio service mesh package available for VKS clusters includes a pluggable policy layer and configuration API that supports access controls, rate limits, and quotas at the service communication level, allowing organizations to restrict inter-service communication based on workload identity and policy.

VCF addresses data handling practices for sensitive information at the application layer. Data sets in vSphere are not intended for storing sensitive data such as passwords or private keys in plain text. For secrets management, VCF Operations provides

the option to store sensitive information in orchestrator configuration elements or in external password vaults, directing sensitive credentials away from general-purpose storage.

VCF Automation and VCF Automation for VM Apps both enforce privacy compliance controls when exposing user identity information. The platform requires explicit consent to data compliance before displaying user names, providing a configurable enforcement point that restricts the display of regulated personal data until the appropriate authorization is in place.

VCF also integrates with third-party Privileged Access Management (PAM) solutions and federated identity providers through standards-based APIs. NSX Manager supports principal identity authentication using certificates with role-based access control, and supports LDAP identity source integration for remote user authentication.

VMware Private AI Services (PAIS) provides configurable access control mechanisms across its AI infrastructure components to restrict access to sensitive data, including training datasets, model artifacts, and knowledge base sources.

The Model Gallery uses Harbor project access capabilities to restrict access to sensitive data that is used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval, and is compatible with OCI-compliant registries from other vendors so the same project-scoped controls extend to customer-selected registries.

Access to PAIS itself is controlled through OIDC group membership, with authorized groups specified in the PAISConfiguration through the `authorizedGroups` setting on the `kubectl` path or the `oidc-authorized-groups` setting on the VCF Automation UI path. User accounts must be members of the specified groups (such as `group-for-pais-access-01` or `group-for-pais-access-02`) on the OIDC provider to reach the service, so organizations align PAIS service access to existing identity provider groups and revoke access by changing group membership. PAIS requires HTTPS-based communication with the OIDC provider and HTTPS trust bundles configured for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and Model Context Protocol (MCP) servers that provide tools to models, so authenticated channels are required at each integration point. A separate CA trust bundle is used for secure database connections to the pgvector server provided by DSM.

Model endpoints used for completion and embedding workloads authenticate to private registries through `harbor-pull-secret-readonly`, controlling which clients can pull container images for inference workloads on GPU and CPU resources.

At the catalog layer, PAIS catalog items in VCF Automation are scoped through project-based permissions, and the DSM database backing PAIS data indexing can be configured for sharing between developers and catalog users through a toggle that creates a new DSM database catalog item, with associated storage policies and infrastructure policies defining resource allocation. Knowledge Base data sources require source-specific credentials: SharePoint On-Premises sources require user name and password authentication, service account key file sources require the information from the key file during data source creation, and programmatic access to Knowledge Bases and data sources is performed using personal access tokens generated from user account settings.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes several security event logging mechanisms applicable to sensitive data segments, generating network-layer and security inspection event records that support this control.

The Distributed Firewall supports logging of dropped traffic with custom tags for audit trail purposes. DFW rules can be scoped to segments hosting sensitive data, and policy-matched events are recorded with sufficient metadata to support forensic review. VCF Log Management provides centralized log management for vDefend by receiving forwarded syslog output and supports querying using Interactive Analytics for post-event analysis.

vDefend IDS/IPS can be configured to send IDS events to external syslog consumers by enabling the `ids_events_to_syslog` setting (disabled by default). Syslog must be configured on ESX hosts to receive these events. Syslog messages from vDefend appliances conform to RFC 5424, and messages from ESX hosts conform to RFC 3164, enabling integration with standard log management and SIEM platforms.

The Malware Prevention Service, hosted on the Security Services Platform, logs file analysis lifecycle events including file intercepted, verdict cache hit, file submitted for local static analysis, file submitted for cloud dynamic analysis, verdict obtained, and policy enforced. Event logs include fields for file type, file size, inspection timestamp, client VM ID, server information, submission source, detection status, verdict, risk score, malware classification, malware family, HTTP domain, HTTP method, user agent, and file upload status. Remote logging can be configured on Malware Prevention Service VMs to forward these logs to an external syslog server. This produces a detailed audit record for file objects traversing protected workloads, which may include sensitive data files.

Network Detection and Response (NDR) integrates with SIEMs to send security-related event logs about network activity, generating events when detections occur and when campaign data is updated. NDR anonymizes sensitive customer information when sharing data to cloud analysis services.

Identity Firewall Event Log Sources can be configured to collect authentication events from Windows event log sources or VCF Log Management, enabling user-identity context in policy-matched events. Security Intelligence, within the Security Services Platform, includes a default rule that records allow and drop actions for traffic that does not match any explicit policy rule, providing visibility of unclassified flows on monitored segments.

The Security Services Platform can collect and transmit log messages to a remote syslog server.

vDefend operates at the network and security inspection layer. It does not classify regulated data at rest or generate application-layer audit records for data lifecycle actions such as collection, creation, modification, deletion, or archival.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access control mechanisms that restrict who can configure and manage disaster recovery operations for virtual machines, including those containing sensitive or regulated data.

PNR defines a tiered set of predefined roles for access management. The Provider Administrator role holds system-level access for overall PNR administration. Organization Administrators manage access and resources within their organization's scope. Project Administrators and Project Advanced Users hold narrower permissions scoped to project-level operations. These roles govern both the appliance-based management interface and VCF Automation-integrated deployments.

In VCF Automation-integrated environments, the RBAC model extends to control over replication configuration options: Provider Administrators select which replication classes each Organization can use, restricting which recovery configurations are available to each tenant organization. Organization Administrators manage the pairing of namespaces and the assignment of replication classes to their Organizations.

In shared recovery site configurations, PNR isolates customer resources by mapping protected-site resources, networks, folders, and datastores to separate datacenters, networks, folders, and placeholder datastores on the recovery site. RBAC in these configurations also restricts users from renaming, moving, or deleting data centers or hosts, limiting the scope of what any individual user can modify within shared recovery infrastructure.

PNR is designed to record operational information into log files without capturing sensitive information such as private keys or passwords, limiting inadvertent exposure of credentials in administrative log output.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to this control through role-based access control, configurable infrastructure policies, data service policies, and database-engine-level access restrictions that limit who can access database resources and under what conditions.

DSM implements role-based access control at the service level. Administrators can create, monitor, and manage all data services in the environment, while users are restricted to managing and monitoring only the data services assigned to them. DSM User roles also carry namespace-level access controls that restrict permissions to specific namespaces, confining each user's actions to the namespaces they are authorized for. This separation is configured during DSM deployment through directory service group assignments in the vSphere Client, and it provides the foundation for restricting access to databases that hold sensitive or regulated data.

DSM infrastructure policies create configurable guardrails around the compute and storage resources that database instances can consume. They filter available storage options to only those compatible with the specified compute resources, and users must hold appropriate DSM permissions before they can configure infrastructure policies. The Infrastructure Policies view in the DSM administrative dashboard provides visibility into available policies, including CPU, memory, storage policies, IP pool, VM classes, and associated resources. Cloud Administrators can enforce namespace-specific restrictions to allow or disallow the use of infrastructure policies and backup locations in individual namespaces, providing an additional layer of access scoping.

Data service policies define which infrastructure policies, placements, and versions are permitted for a given data service. DataServicePolicy custom resources used by the Consumption Operator require the allowedInfrastructurePolicies field to be populated, scoping database provisioning to administrator-approved resource boundaries. The allowed placements, versions, and infrastructure policies available in a given namespace result from the intersection of all matching data service policies for that namespace. In multi-tenant deployments, administrators can assign data service policies and object stores to specific tenants, maintaining isolation between tenant workloads. DSM adds SQL Server data service policies, which can be enforced across tenants and tailored to specific organizational requirements before assignment.

All database connections in DSM require TLS. Clients connecting to PostgreSQL, MySQL, and SQL Server clusters must have the appropriate certificate authority in their trust store, restricting connectivity to clients that have been configured with the correct trust material.

DSM adds database-engine-level access restrictions for SQL Server. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full administrative access. An internal management login (dsm_mgmt) restricts user access to system-level objects, keeping administrative operations within a controlled, isolated context. For PostgreSQL, DSM supports the pgcrypto extension, which provides cryptographic functions that enable column-level data protection within the database engine.

DSM provides a Compliance tab on data service policy detail pages. This view displays compliance reports and allows administrators to expand each policy violation to identify the noncompliant database, data service, and namespace, supporting targeted remediation.

Achieving full compliance with this control requires organizational decisions about which data is considered sensitive or regulated, mapping that classification to the database instances and tenants where such data resides, and configuring DSM roles, policies, and tenant assignments accordingly. DSM provides the technical mechanisms to enforce those access restrictions once the data classification and access decisions have been made by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides an automated event logging framework that can be configured to generate log records when application traffic or configuration actions involving data the organization designates as sensitive or regulated occurs.

The Avi Controller's configuration audit log records all object lifecycle events, including CONFIG_CREATE, CONFIG_UPDATE, and CONFIG_DELETE, with each record capturing the event type, object name, tenant, timestamp, and the user who performed the action. These configuration events are queryable through the /api/analytics/logs REST API endpoint, which supports filtering by event type, time range, and duration and can retrieve records covering up to one year of history. Event logs can be filtered using parameters such as event_id=CONFIG_CREATE or event_id=CONFIG_UPDATE to isolate specific changes. The Event Logs interface in the Controller UI provides records of system activities and configuration changes, including tracking of who made changes and when. The Avi Controller also maintains a permanent log of the underlying events and metrics that triggered alerts, preserving a record beyond the alert expiry period.

The Avi Controller and Avi Service Engine log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing coverage for connection-level events that may involve regulated data in transit.

For application-layer data events, the DataScript framework allows inspection of HTTP requests and responses and can trigger custom log entries via the avi.vs.log() function when patterns matching the organization's definition of sensitive or regulated data are detected. Avi WAF extends this with rule-based logging; WAF rules can be configured with audit log parts

(ctl:auditLogParts=+E) to capture matched variable names and content when rules fire, allowing logging of the specific data patterns that triggered a match. The Analytics Profile supports creation of a sensitive log profile, which controls how sensitive data appears within the client logs generated by the platform.

Avi streams event and application logs to external platforms. The Syslog-Audit-Persistence template forwards audit compliance events to external syslog servers. Operators should note that configuring syslog notifications pushes alert events but does not directly export virtual service logs; virtual service logs must be pulled via the API or scripted to push from the Controller to a remote logging server. Logs can be streamed to external SIEM platforms such as Splunk for centralized collection and analysis. VCF Log Management can be configured as a syslog destination to receive event streams from the Avi Controller.

Control 164.312(d)

Standard: Person or entity authentication. Implement procedures to verify that a person or entity seeking access to electronic protected health information is the one claimed.

SCF Controls: HRS-01, HRS-04, IAC-28, IAC-28.2, IAC-28.3, TPM-01

Aggregate Coverage: Contributes

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides configurable identity evidence validation mechanisms at the application proxy boundary, supporting certificate-based validation, federated identity through SAML, and token-based validation through OAuth, OpenID Connect (OIDC), and JSON Web Tokens (JWT).

For certificate-based identity evidence, Avi's Client SSL Certificate Validation feature requires a PKI Profile when the Validation Type is set to Request or Required. The PKI Profile defines the trusted certificate authorities and validation parameters, allowing organizations to specify which certificate-based identity evidence is acceptable. The Avi Service Engine performs server certificate verification including CA certificate validation, CRL checking, certificate chain validation, hostname matching, and validity period checking, enforcing these checks at the proxy boundary. DataScript provides access to the `avi.ssl.check_client_cert_validity()` function with a configurable fingerprint-type parameter supporting Full, Filtered, and Normalized JA3 modes for programmatic certificate validity checking against application-specific requirements. Certificates require a trusted chain of authority to be considered valid by clients.

For federated identity scenarios, Avi acts as a SAML Service Provider, accepting and verifying SAML assertions from a trusted organizational Identity Provider (IdP). After successful user credential validation at the IdP level, the IdP's SSO service returns an XHTML document containing a SAML Response with authentication statements and user attribute assertions. Avi validates that the Entity ID matches between the IdP and the Service Provider configuration as part of the assertion verification process. SAML 2.0 metadata provides an interoperable format for bootstrapping the trust process between the Service Provider and Identity Provider. The Avi Controller's SAML Authentication Profile supports IdP metadata configuration via direct metadata upload or metadata URL. The SAML integration supports external identity providers including PingFederate, where administrators can configure standard identity mapping or custom user attribute mappings to align with organizational identity schemas. Federated authentication is recommended to centralize the authentication process by delegating to the organizational Identity Provider rather than managing authentication locally within Avi.

For token-based identity, Avi supports OAuth 2.0, OIDC, and JWT flows, enabling organizations to require access token presentation for application access. Avi can extract user identity information from the OIDC UserInfo endpoint by accepting the access token, or from claims in the ID token. JWT validation includes verification of token claims: the not-before time (nbf), issued-at time (iat), and unique token identifier (jti), allowing organizations to enforce token freshness and uniqueness requirements at the application boundary.

For Kubernetes workloads, the Avi Kubernetes Operator (AKO) extends these identity validation capabilities through SSORule Custom Resource Definitions (CRDs), which support OAuth/OIDC configuration for virtual services. When configured with `SAML_AUTHN_REQ_ACS_TYPE_URL`, the single sign-on URL endpoint is sent in the AssertionConsumerServiceURL attribute of the authentication request to the Identity Provider. AKO also monitors certificate files and Kubernetes secret updates, logging certificate and secret update events for operational visibility.

DataScript provides additional programmatic access control, enabling checks against approved user ID lists and redirecting unauthenticated users to a login page based on identity.

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.312(e)(1)

Standard: Transmission security. Implement technical security measures to guard against unauthorized access to electronic protected health information that is being transmitted over an electronic communications network.

SCF Controls: CFG-02, CRY-03, NET-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides cryptographic protection for data in transit across management, compute, storage, and inter-site networks. The architecture applies encryption at multiple layers using validated cryptographic modules and current TLS protocol versions.

VCF management and monitoring communications use TLS as the transport protocol. VCF Operations for Networks supports modern TLS protocol versions, with the ability to restrict cryptographic module usage to FIPS-validated modules by enabling FIPS mode for external connections. Telegraf, the metrics collection agent, is configured to require a modern minimum TLS version for its communication channels. When using the databus for on-premises environments, HTTPS is the recommended transport to protect data during transmission and to verify subscriber authenticity. The TLS implementation includes customizable PKI options ranging from fully automated certificate management within VCF to integration with enterprise PKI infrastructure such as Microsoft Active Directory Certificate Services. VCF Operations provides centralized certificate lifecycle management across VCF components, supporting auto-renewal for VMCA, MSCA, and OpenSSL CA, handling automated renewal, monitoring, and replacement. Machine SSL certificates can be renewed through the API for a specified period up to 730 days. Starting in vSphere 9.0, all vSphere TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic operations including AES, ECDSA, HMAC, RSA, and SHA-2 variants.

NSX, which provides networking services within VCF, uses FIPS 140-3 validated cryptographic modules by default. These modules are validated through the NIST Cryptographic Module Validation Program. NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. For site-to-site connectivity, the NSX L2 VPN FIPS compliance suite uses FIPS-approved encryption with Perfect Forward Secrecy enabled and standardized Diffie-Hellman key exchange, providing transmission confidentiality for tunneled traffic. VCF Operations for Networks supports modern ECDSA and RSA signature algorithms for data source connections.

VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses the BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009. These validated modules underpin the cryptographic operations used for securing communications across the automation and operations components.

At the storage layer, vSAN provides data-in-transit (DIT) encryption that protects data as it moves between hosts within the cluster. DIT encryption is a cluster-wide setting that, when enabled, encrypts all data and metadata traffic across hosts. Forward secrecy is enforced for vSAN data-in-transit encryption, meaning that compromise of a long-term key does not expose previously encrypted traffic. DIT encryption operates independently of data-at-rest encryption and does not require external key management servers. The behavior differs by storage architecture: in vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the target host's Local Object Manager layer, so data traverses the network before encryption, making DIT encryption strongly recommended. In vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements.

VM Encryption provides confidentiality protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. VM encryption is implemented on the ESX host rather than on the storage array, so it protects data both at rest and in transit to the storage backend. Disk encryption uses AES-256 as the disk encryption key.

Encrypted vSphere vMotion protects VM data during live migrations. For encrypted VMs, vMotion always uses encryption and cannot be disabled. For unencrypted VMs, encrypted vMotion offers three settings: Disabled, Opportunistic (default, uses

encryption when supported), and Required. AES-NI significantly improves encryption performance for these operations. Cross-vCenter vMotion supports encryption when source and destination use shared key providers; vCenter Crypto Manager provides an `importProvider` method to import a vSphere Native Key Provider configuration between sites. vSphere Fault Tolerance log traffic, which synchronizes VM state between primary and secondary instances, can also be encrypted to protect this synchronization data in transit.

Storage protocol support varies by type. vSAN File Service supports NFS4 Kerberos authentication with security options `krb5`, `krb5i`, and `krb5p`, where `krb5p` provides authentication plus encryption of data in transit. iSCSI uses CHAP for session authentication but does not encrypt data natively, so VM Encryption or in-guest encryption is needed for confidentiality on iSCSI networks. Fibre Channel Gen 7 supports end-to-end encryption with secure Host Bus Adapters.

HCX Network Extension services support transport encryption for data between site pairs, and this encryption is enabled by default. VCF Operations HCX tunnel encryption similarly uses transport encryption by default to protect Network Extension data and migration traffic between sites. This default-on approach reduces the risk of data being transmitted in cleartext during workload migrations or network extensions.

High-quality entropy generation on ESX hosts supports the proper functioning of security-related operations such as generating encryption keys for secure network communication. This foundational capability helps maintain the strength of cryptographic keys used across all transmission encryption functions in the platform.

VMware Kubernetes Service (VKS), which runs on vSphere Supervisor, applies TLS encryption across all control-plane communication paths. The Kubernetes API server enforces encrypted transmission within the control plane and between the control plane and its clients by default, so all API server interactions travel over TLS. Cipher suites are configurable at each component layer: the `kube-apiserver` `--tls-cipher-suites` parameter accepts a comma-separated list of permitted cipher suites; the `kube-scheduler` exposes the same `'tls-cipher-suites'` parameter to keep its API endpoint aligned; and the `kubelet` exposes `'tlsCipherSuites'` and `'tlsMinVersion'` settings in `'KubeletConfiguration'` to scope the permitted cipher algorithms and minimum protocol version at the node level. Antrea, the CNI plugin included with Supervisor, supports configurable TLS cipher suites for its own secure communication channels through the `'tlsCipherSuites'` setting, and the vSphere Cloud Provider Interface (CPI) exposes the same capability through a configurable cipher suite list.

For environments with strict cryptographic requirements, VKS supports FIPS mode through the `ClusterClass` variable `'fips.enabled'`, which controls which encryption algorithms are permitted at the node level. Tanzu Kubernetes Release references carrying the `'-fips.1'` suffix indicate that FIPS cryptographic modules are active for that node pool. The Istio service mesh package, available as a standard package on VKS clusters, ships with FIPS compliance and supports mutual TLS (mTLS) between pods within the mesh; the `'meshMTLS.minProtocolVersion'` setting controls the minimum acceptable protocol version for all inter-service traffic. Ingress-layer encryption for workloads is handled by the Contour package, which exposes `'tls.minimum-protocol-version'` and `'tls.maximum-protocol-version'` settings so operators can define a bounded range of acceptable protocol versions for inbound HTTPS traffic. The Supervisor secret injection agent automatically configures mutual TLS for its communication with the vault agent injector service using auto-generated certificates. Harbor, available as a Supervisor Service, accepts custom TLS certificates through its `'tlsCertificate.tls.crt'` and `'tlsCertificate.tls.key'` configuration fields, supporting encrypted access to the container registry for image distribution.

Defining the encryption policy for customer workload traffic, selecting cipher and FIPS configurations for environments with stricter requirements, and validating that data transmitted from customer applications and containerized workloads meets confidentiality standards are organizational data-policy decisions.

VMware Private AI Services (PAIS) provisions VKS clusters using a FIPS-enabled Kubernetes build for cryptographic compliance across both control plane and worker node communications. The VKS cluster topology version is `v1.33.1--vmware.1-fips-vkr.2` with FIPS compliance enabled, running on an Ubuntu 24.04 OS image, covering the cryptographic modules that protect data in transit within the cluster fabric.

PAIS, activated through the `PAISConfiguration` custom resource on the Supervisor, requires HTTPS for all external integrations. The `spec.clientTls.caBundleRefs` section of the `PAISConfiguration` YAML references CA trust bundles supplied as `ConfigMap` resources. Operators must configure HTTPS trust bundles for the OIDC provider, the Harbor container registry,

content management systems hosting Knowledge Base data sources, MCP servers providing tools to models, and the pgvector database. Separate trust bundles are recommended per application, with periodic updates required before certificate expiration.

The PAIS Supervisor endpoint uses HTTPS on port 6443 with certificate-based authentication. The PAIS ingress endpoint is protected by a self-signed certificate stored in the `pais-ingress-default` Kubernetes Secret. Administrators retrieve the CA certificate using `kubectl get secrets/pais-ingress-default -o yaml` and distribute it to clients that connect to the service, including Grafana when configured to scrape the PAIS Prometheus endpoint. CA trust bundles for external entity connections are managed through ConfigMaps and updated as certificate content changes.

VCF Automation Provider Management for PAIS uses a base64-encoded certificate (`TM_CERT_BASE64`) obtained by running `openssl s_client` against the VCF Automation FQDN on port 443, enabling authenticated HTTPS communication between AI catalog tooling and the PAIS environment. MCP server integrations require the MCP server's issuer certificate to be added as a CA trust bundle before connecting over HTTPS using either Streamable HTTP or Server-Sent Events transport.

Telemetry sent from PAIS to the OpenTelemetry Collector is authenticated using a Kubernetes Secret containing Authorization Bearer tokens and custom authorization headers. LLM trace transport to the collector uses HTTP/protobuf or gRPC, both protecting trace traffic in transit.

One configuration detail that auditors should verify: PAIS Prometheus TLS client authentication and certificate validation are turned off by default (the `tls-client-authentication` setting on the Prometheus endpoint). Organizations should review this setting and enable mutual TLS where their policy requires it. The underlying network transport encryption between VMs and workload domains is provided by VCF and is documented in VCF Coverage.

VMware vDefend (Contributes)

VMware vDefend contributes to transmission confidentiality through inspection, visibility, and enforcement mechanisms at the network layer, while the underlying cryptographic protection of data in transit is the responsibility of endpoint applications and infrastructure components.

TLS Inspection uses a transparent TLS proxy to intercept and analyze encrypted traffic flows traversing the environment. This allows security policy to be applied to traffic that would otherwise be opaque and supports detection of threats embedded within encrypted sessions. TLS Inspection can be deployed to provide visibility into encrypted connections while preserving end-to-end encryption for flows not subject to a decryption policy, and supports both inbound and outbound inspection profiles.

Security Intelligence, integrated within the Security Services Platform (SSP), surfaces workloads communicating over application protocols that transport data without encryption. The Security Segmentation Report identifies communication chains containing at-risk unprotected members and quantifies the number of unprotected data flows hitting default-allow rules across observed traffic. Administrators can use this reporting to identify and prioritize remediation of encryption coverage gaps, including restricting or blocking cleartext protocols.

The Security Services Platform and its component services use FIPS 140-2 and FIPS 140-3 validated cryptographic modules for their own communications. Network Detection and Response (NDR) Sensors connect to the SSP using mutual TLS authentication (mTLS), with a dedicated certificate for each sensor signed by an intermediate certificate authority on the SSP. The SSP can be configured to forward log messages to a syslog server over TLS, and Malware Prevention Service remote logging likewise uses TLS to transmit log data to a remote log server. NDR also supports SSL verification for event logs sent over HTTPS. When NDR shares data to the cloud, it anonymizes sensitive customer information before transmission.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic protection for data transmitted during disaster recovery operations, covering management communications and replication data flows.

All communications between the PNR server and VMware vCenter (vCenter) instances take place over TLS connections. PNR requires an SSL/TLS certificate, with x509v3 Extended Key Usage indicating TLS Web Server Authentication, as the endpoint

certificate for all TLS connections to the PNR server. PNR defaults to the current TLS version for all communication endpoints and supports administrative configuration of the minimum acceptable protocol version. Administrators configure the minimum TLS protocol version by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file; when changing the minimum version, the update must be applied consistently across all occurrences in the system. PNR uses TLS certificates and private keys to protect network communication and authenticate with other servers.

For replication data, vSphere Replication encrypts replication traffic in transit for both new and existing replications. Network encryption is mandatory when using vSphere Replication 9.0.3 and later and is enabled by default. PNR also supports configuring network encryption of replication traffic as an option for replication scenarios where mandatory encryption does not apply automatically. PNR supports protection and recovery of encrypted virtual machines through both array-based and vSphere Replication protection groups, allowing VM disk encryption to persist through the replication process. Recovery of encrypted virtual machines requires that the protected and recovery sites share a common Key Management Server (KMS), or that the KMS clusters at both sites use common encryption keys, to maintain key availability after failover.

Defining the encryption policy for environments with stricter requirements and validating that workload traffic running on protected virtual machines meets confidentiality standards are organizational data-policy decisions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies TLS-based encryption across multiple communication paths, covering database client connections, management interfaces, service-to-service communication, and data migration traffic. Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms such as Ed25519.

For database client connections, DSM enforces a minimum TLS protocol version across all supported database engines. PostgreSQL instances enforce a configurable minimum TLS protocol version via the `'ssl_min_protocol_version'` setting and support certificate-based authentication with CA verification. PostgreSQL replication connections support SSL/TLS encryption with a configurable `'sslmode'` parameter to secure data in transit between source and target databases, and DSM validates SSL trust before establishing replication. MySQL locks TLS protocol enforcement at the platform level so users cannot weaken it. MySQL has `'require_secure_transport'` set to ON by default, which requires all client connections to use encrypted transport. MySQL supports FIPS mode via the `'ssl_fips_mode'` setting. DSM adds SQL Server as a supported database engine; SQL Server clusters use TLS to encrypt client connections, require a minimum TLS version for DSM operator management, and expose the `'network.tlsProtocols'` engine setting to configure the set of allowed TLS versions.

For management and service-to-service communication, the DSM Provider exposes an HTTPS endpoint. The Consumption Operator requires a TLS certificate for secure communication with the DSM provider. In network-isolated deployments, Consumption Operator image transfers to a private registry support optional TLS certificate authentication. Metrics forwarding from DSM to VCF Operations supports mutual TLS (mTLS) authentication, requiring a client certificate and private key. DSM SMTP settings include an Auto TLS option that establishes a secure connection to the SMTP server.

DSM provides certificate management capabilities to support the TLS infrastructure. Custom certificates are validated for FIPS 140-3 compliance at upload time; accepted key types are ECDSA P-256, ECDSA P-384, and RSA with a minimum key size of 2048 bits, and Ed25519 keys are rejected as non-compliant. Trusted root certificates added through the DSM UI must comply with FIPS requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides native, configurable cryptographic mechanisms to protect the confidentiality of data in transit at both the application data plane and the Controller management plane.

Each virtual service in Avi is associated with an SSL/TLS Profile, which defines the accepted protocol versions, cipher suites, and their priority order. SSL/TLS Profiles are managed at Templates > Security > SSL/TLS Profile in the Controller UI. Predefined profile templates are available, including a System-Standard template, and administrators can create custom profiles to enforce the cipher suites and protocol versions appropriate for their environment. Elliptic Curve (EC) cryptography is available for virtual services and supports Perfect Forward Secrecy with less computational overhead than RSA-based key

exchange. TLS persistence state exchanged between Service Engines when a client reconnects is carried in encrypted form. At the L4 proxy level, the Default-TLS protocol parser can be associated with a virtual service to inspect TLS handshake data using DataScript, supporting selective offload and re-encryption scenarios.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) supports a PKIProfile custom resource definition that enables certificate-based authentication and encryption for backend service communication. The System-Standard SSL Profile can be applied through the RouteBackendExtension CRD to enable SSL/TLS re-encryption for traffic to backend servers, providing modern cipher suites for Kubernetes ingress and routing scenarios. In VCF environments, the Avi load balancer uses secrets to handle encrypted HTTPS traffic, configured through the VCF IaaS Service Console.

When FIPS mode is enabled on the Avi Controller cluster, all cryptographic operations across the Controller and Service Engines are restricted to FIPS 140-3 approved algorithms. Avi uses the OpenSSL FIPS Provider version 3.1.2 in this mode, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP. Enabling FIPS mode is a cluster-level configuration that applies uniformly to all cryptographic material handled by the platform. FIPS mode does not support SSL Client Hello events in Avi DataScript, and post-quantum cryptographic capabilities are not available in FIPS mode.

The Avi Controller and Service Engines use SSH for secure management communication. The SE_SECURE_CHANNEL designation classifies traffic between the Controller and Service Engines to maintain a dedicated secure communication channel. Avi also integrates with Let's Encrypt via the ACME protocol to automate certificate issuance and renewal for virtual services, and with hardware security modules such as the Thales Luna HSM for external key management. Remote server file transfer supports Secure Copy Protocol (SCP) and Secure File Transfer Protocol (SFTP). For deployments requiring hardware acceleration, Avi Service Engine integrates with Intel QuickAssist Technology to offload bulk cryptographic operations following SSL/TLS handshake completion.

Avi DataScript exposes cryptographic functions for application-layer use cases. The `avi.crypto.encrypt()` function encrypts data using a caller-provided key, optional initialization vector, and algorithm parameter. The HTTP Cookie Encryption Gateway uses these functions to encrypt cookie values in HTTP responses, protecting session state carried between client and server. The `avi.utils.rand_bytes` function generates cryptographically secure random bytes for token and nonce generation.

Defining which application traffic requires encryption and configuring the virtual service profiles to apply protection at the appropriate boundary are organizational data-policy decisions.

Control 164.312(e)(2)(i)

Implementation specifications: Integrity controls (Addressable). Implement security measures to ensure that electronically transmitted electronic protected health information is not improperly modified without detection until disposed of.

SCF Controls: CFG-02, CRY-04, NET-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-

standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to

restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgm_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the

postgrescluster-allow-non-ssl-system-users setting in the advanced-system-config ConfigMap within the dsm-system namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control 164.312(e)(2)(ii)

Implementation specifications: Encryption (Addressable). Implement a mechanism to encrypt electronic protected health information whenever deemed appropriate.

SCF Controls: CFG-02, CRY-01, OPS-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware

that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that

organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS

version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the PGCRYPTO_PASSWORD and PGCRYPTO_ALGORITHM keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport

Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control 164.314(a)(1)

Standard: Business associate contracts or other arrangements. The contract or other arrangement required by § 164.308(b)(3) must meet the requirements of paragraph (a)(2)(i), (a)(2)(ii), or (a)(2)(iii) of this section, as applicable.

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(a)(2)(i)(B)

Implementation specifications (Required) Report to the covered entity any security incident of which it becomes aware, including breaches of unsecured protected health information as required by § 164.410.

SCF Controls: TPM-05.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(a)(2)(i)(C)

Report to the covered entity any security incident of which it becomes aware, including breaches of unsecured protected health information as required by § 164.410.

SCF Controls: TPM-05.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(a)(2)(ii)

Other arrangements. The covered entity is in compliance with paragraph (a)(1) of this section if it has another arrangement in place that meets the requirements of § 164.504(e)(3).

SCF Controls: CPL-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(a)(2)(iii)

Business associate contracts with subcontractors. The requirements of paragraphs (a)(2)(i) and (a)(2)(ii) of this section apply to the contract or other arrangement between a business associate and a subcontractor required by § 164.308(b)(4) in the same manner as such requirements apply to contracts or other arrangements between a covered entity and business associate.

SCF Controls: TPM-05, TPM-05.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(b)(1)

Standard: Requirements for group health plans. Except when the only electronic protected health information disclosed to a plan sponsor is disclosed pursuant to § 164.504(f)(1)(ii) or (iii), or as authorized under § 164.508, a group health plan must ensure that its plan documents provide that the plan sponsor will reasonably and appropriately safeguard electronic protected health information created, received, maintained, or transmitted to or by the plan sponsor on behalf of the group health plan.

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(b)(2)(i)

Implementation specifications (Required). The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to- Implement administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of the electronic protected health information that it creates, receives, maintains, or transmits on behalf of the group health plan;

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(b)(2)(ii)

Implementation specifications (Required). The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to- Ensure that the adequate separation required by § 164.504(f)(2)(iii) is supported by reasonable and appropriate security measures;

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(b)(2)(iii)

Implementation specifications (Required). The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to- Ensure that any agent to whom it provides this information agrees to implement reasonable and appropriate security measures to protect the information; and

SCF Controls: TPM-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.314(b)(2)(iv)

Implementation specifications (Required). The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to- Report to the group health plan any security incident of which it becomes aware.

SCF Controls: TPM-05.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.316(a)

Standard: Policies and procedures. Implement reasonable and appropriate policies and procedures to comply with the standards, implementation specifications, or other requirements of this subpart, taking into account those factors specified in § 164.306(b)(2)(i), (ii), (iii), and (iv). This standard is not to be construed to permit or excuse an action that violates any other standard, implementation specification, or other requirements of this subpart. A covered entity or business associate may change its policies and procedures at any time, provided that the changes are documented and are implemented in accordance with this subpart.

SCF Controls: GOV-01, GOV-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.316(b)(1)(i)

Standard: Documentation. Maintain the policies and procedures implemented to comply with this subpart in written (which may be electronic) form; and

SCF Controls: GOV-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.316(b)(1)(ii)

Standard: Documentation. If an action, activity or assessment is required by this subpart to be documented, maintain a written (which may be electronic) record of the action, activity, or assessment.

SCF Controls: CPL-03, GOV-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.316(b)(2)(i)

Implementation specifications: Time limit (Required). Retain the documentation required by paragraph (b)(1) of this section for 6 years from the date of its creation or the date when it last was in effect, whichever is later.

SCF Controls: DCH-18

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.316(b)(2)(ii)

Implementation specifications: Availability (Required). Make documentation available to those persons responsible for implementing the procedures to which the documentation pertains.

SCF Controls: OPS-01.1, OPS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 164.316(b)(2)(iii)

Implementation specifications: Updates (Required). Review documentation periodically, and update as needed, in response to environmental or operational changes affecting the security of the electronic protected health information.

SCF Controls: CPL-02, GOV-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

